

국가 망 보안체계 보안 가이드라인

보안통제 항목 해설서

2025. 9



국가정보원

NSR 국가보안기술연구소

국가 망 보안체계 보안 가이드라인

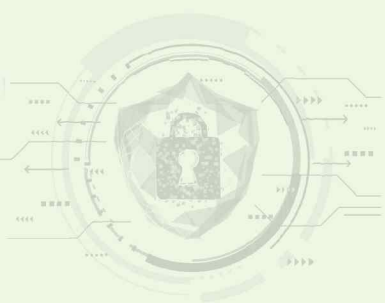
보안통제 항목 해설서

2025. 9



국가정보원

NSR 국가보안기술연구소



국가 망 보안체계
보안 가이드라인
| 보안통제 항목 해설서

부록 1

문서이력 ●

개정일	버전	내역	비고
2025.1.	Draft	「국가 망 보안체계 보안 가이드라인 – 보안통제 항목 해설서」 Draft 발간	
2025.9.	1.0	「국가 망 보안체계 보안 가이드라인 – 보안통제 항목 해설서」 발간	

■ 보안통제 항목 종합	5
--------------------	---

제1장 권한

1. 최소 권한 (Least Privilege, LP)	25
2. 신원 검증 (Identity Verification, IV)	29
3. 식별자 관리 (Identifier Management, IM)	31
4. 계정 관리 (Account Management, AC)	33

제2장 인증

1. 다중요소 인증 (Multi-Factor Authentication, MA)	38
2. 외부인증수단 (External Identity, EI)	41
3. 단말인증 (Device Authentication, DA)	42
4. 인증보호 (Authentication Protection, AU)	45
5. 인증정책 (Authentication Policy, AP)	48
6. 인증수단 (Authentication Method, AM)	50
7. 로그인 (Login, LI)	53

제3장 분리 및 격리

1. 분리 (Segregation, SG)	57
2. 격리 (Isolation, IS)	60

제4장 통제

1. 정보흐름 (Information Flow, IF) 63
2. 외부경계 (External Boundary, EB) 66
3. CDS (Cross Domain Solution, CD) 70
4. 원격접속 (Remote Access, RA) 74
5. 세션 (Session, SN) 76
6. 무선망 접속 (Wireless Network Access, WA) 79
7. 블루투스 연결 (Bluetooth Connection, BC) 81

제5장 데이터

1. 암호 키 관리 (Encryption Key Management, EK) 83
2. 암호 모듈 사용 (Encryption Technology Application, EA) .. 85
3. 데이터 전송 (Data Transmission, DT) 87
4. 데이터 사용 (Data Usage, DU) 89

제6장 정보자산

1. 모바일 단말 (Mobile Device, MD) 93
2. 하드웨어 (Device, DV) 96
3. 정보시스템 구성요소 (Information System Component, IN) ... 98

보안통제 항목 종합

대항목	중항목	N2SF ID	소항목	보안통제설명	N2SF 우선 검토사항		
					 기밀	 민감	 공개
권한	최소권한 Least Privilege (LP)	N2SF-LP-1	정보시스템 접근 권한 정의	업무정보(데이터)를 식별하고, 업무정보를 저장하고 있는 정보시스템 접근 권한을 정의한다.	●	●	
		N2SF-LP-2	보안통제 권한 제한	보안통제 권한은 정보보안담당관(자) 또는 이에 준하는 관리권한을 부여받은 인원에게만 부여한다.	●	●	●
		N2SF-LP-3	보안통제 계정 노출 방지	보안통제 목적으로 사용되는 계정이 다른 기능에 사용되지 않도록 하고, 불필요한 사용을 제한하여 계정의 노출을 방지한다.	●	●	●
		N2SF-LP-4	관리자 권한 제한	정보시스템 접근에 필요한 최소한의 관리자 및 운영자 등에게만 관리자 권한을 부여한다.	●	●	●
		N2SF-LP-4(1)	원격접속을 통한 관리자 권한 접속제한	기관 네트워크 내부에서 관리자 권한 접속이 제한되는 경우 등 불가피한 상황에서만 한시적으로 기관 네트워크 외부에서의 관리자 권한 접속을 허용하며, 목적이 달성된 경우 외부에서의 관리자 권한 접속을 즉시 차단한다.	—	●	●
		N2SF-LP-4(2)	기관 이외 인원의 관리자 권한 제한	기관 구성원 이외 인원에게 관리자 권한은 부여하지 않으며, 다만 정보보안 감사, 사이버보안 실태평가, 사고 조사 및 진단·점검 등에 필요한 경우 외부 인원에게 관리자 권한을 한시적으로 부여할 수 있다.	●	●	●
		N2SF-LP-4(3)	사용자에게 부여된 관리자 권한 관리	사용자에게 부여된 관리자 권한을 주기적으로 검토하고, 필요 없는 권한은 즉시 회수한다.	—		
		N2SF-LP-4(4)	관리자 권한 실행 로깅 및 감사	관리자 권한 기능 실행 내역은 로깅하고 주기적인 사용 내역 감사를 실시한다.	●	●	●
		N2SF-LP-5	코드 실행권한 제한	코드는 필요한 권한으로만 실행되도록 제한하고, 사용자 권한으로 실행되는 코드가 관리자 영역으로 접근되지 않도록 차단한다.	●	●	●
		N2SF-LP-M1	특별권한 사용자 지정	일반 사용 권한과 별도로 특별권한 사용자 그룹을 지정하고, 이들의 권한 부여와 변경을 통제한다.	●	●	
		N2SF-LP-M2	주요 사용자 위험 관리	주요 사용자의 권한과 활동을 모니터링하고 이상 징후를 탐지하여 위험을 사전에 관리한다.	●	●	
		N2SF-LP-M3	접근권한 사전 설정	기본적으로 필요 최소한의 권한만을 부여하는 사전 권한 설정 기준을 마련하고 운영한다.	●	●	●
		N2SF-LP-M4	접근권한과 정보 연계	접근권한 부여 시 정보 접근 범위를 명확히 연계하여 통제하며, 불필요한 정보 접근을 차단한다.	●	●	●

대항목	중항목	N2SF ID	소항목	보안통제설명	N2SF 우선 검토사항		
					 기밀	 민감	 공개
권한	신원검증 Identity Verification (IV)	N2SF-IV-1	관리자 승인	정보시스템 사용자 계정(대민서비스 등 서비스 이용자 계정 제외) 부여를 위한 계정 등록 절차에 정보시스템 관리자(정보화담당관 또는 이에 준하는 관리자)의 승인을 포함한다.	●	●	
		N2SF-IV-2	신원 증거 제출	개인은 신원을 증명할 수 있는 증거를 등록 기관에 제출한다.	●	●	
		N2SF-IV-2(1)	신원 증거 검증	제출된 신원 증거를 검증한다.	●	●	
		N2SF-IV-3	외부 신원 검증 수용	동등한 수준의 보증을 제공하는 외부 기관 또는 업체의 신원 검증 결과를 수용할 수 있다.	●	●	●
		N2SF-IV-M1	대면 신원 증거 검증	대면을 통한 신원 증거를 검증한다.	●		
	식별자관리 Identifier Management (IM)	N2SF-IM-1	공개된 식별자의 계정 사용 금지	정보시스템 계정 식별자로 개인의 공개된 식별자 사용을 금지한다.	●		
		N2SF-IM-2	사용자 상태 식별	개인과 조직의 구별, 사용자 상태(활성, 비활성, 임시계정 등)를 식별하고 관리한다.	●	●	
		N2SF-IM-3	기관 간 상호 관리	기관 간 식별자 관리를 위해 인증정보 관리기관, 외부 연동 정보시스템 관리기관 등과 주기적으로 관련 정보를 공유한다.	●	●	
		N2SF-IM-4	상호(쌍, Pairwise) 가명 식별자	사용자의 익명성 보장이 필요한 경우 사용자 간 식별을 위해 식별 정보가 없는 상호(쌍, Pairwise) 가명 식별자를 제공한다.	●		
		N2SF-IM-5	속성 유지관리 및 보호	안전하게 보호조치가 된 저장소에서 고유하게 식별된 각 개인, 그룹, 장치 또는 서비스에 대한 속성을 유지하고 보호한다.	●		
	계정관리 Account Management (AC)	N2SF-AC-1	계정 관리 자동화	정보시스템 계정 관리를 효율화하고, 인적 오류를 최소화하기 위해 자동화된 메커니즘을 사용하여 계정 관리를 수행한다.	●	●	
		N2SF-AC-1(1)	동적 계정 관리	사용자 상태(입사, 퇴사, 부서 이동 등)에 따라 계정 정보를 실시간으로 반영하고, 시스템 간 계정 동기화를 통해 계정 수명주기 관리를 자동화한다.	●	●	
		N2SF-AC-1(2)	계정 상태 모니터링	계정의 임시 생성, 수정, 활성화, 비활성화 및 삭제 등을 모니터링한다.	●	●	
		N2SF-AC-1(3)	계정 자동 비활성화	계정 사용 기간이 종료되거나 일정 기간 미사용된 계정은 자동으로 비활성화한다.	●		
		N2SF-AC-1(4)	계정 자동 로그아웃	비활동 시간이 일정 기간 지속되었을 때 정보시스템에서 자동 로그아웃 되어야 한다.	●	●	●
		N2SF-AC-1(5)	불필요한 관리자 권한 계정 제거	관리자 권한이 필요 없거나 활용이 종료된 계정은 비활성화 또는 삭제 조치한다.	●	●	●

대항목	중항목	N2SF ID	소항목	보안통제설명	N2SF 우선 검토사항		
					 기밀	 민감	 공개
권한	계정관리 Account Management (AC)	N2SF-AC-2	공유 및 그룹 계정 사용 제한	공유 및 그룹 계정 사용은 필요한 경우로 제한하며, 가능하면 개인별 계정 사용을 권장한다.	●		
		N2SF-AC-3	의심스러운 계정 모니터링	비정상적이거나 의심스러운 계정 접속 시도 및 활동을 지속적으로 모니터링한다.	●	●	
		N2SF-AC-3(1)	위험에 노출된 계정 비활성화	정보시스템 위험 탐지 시, 위험에 노출된 계정은 신속히 비활성화하거나 제한 조치를 한다.	●	●	●
		N2SF-AC-3(2)	내부 사용자 모니터링	내부 사용자의 계정 사용 및 활동을 지속적으로 모니터링한다.	●	●	
		N2SF-AC-3(3)	외부 사용자 모니터링	외부 사용자의 계정 사용 및 접속 활동을 지속적으로 모니터링한다.	●	●	
		N2SF-AC-M1	감사 활동 자동화	계정 사용 및 관련된 감사 활동을 자동화하여 관리한다.	●		
		N2SF-AC-M2	감사기록 생성	계정 활동에 대한 감사 기록을 생성하여 보관하고 분석할 수 있도록 한다.	●	●	●
		N2SF-AC-M3	세션 감사	세션 활동을 기록하고 주기적으로 감사하여 비정상적 행위를 탐지한다.	●	●	
인증	다중요소인증 Multi-Factor Authentication (MA)	N2SF-MA-1	관리자 계정 다중요소 인증 (MFA, Multi-factor Authentication)	관리자 권한 인증 수행 시 다중요소 인증을 적용한다. * 다음의 인증요소 중 2 가지 이상을 조합하여 활용 (1) 지식기반 요소: 사용자가 설정한 정보 (비밀번호, PIN, 패턴, 보안질문 등) (2) 소유기반 요소: 사용자에게 발급한 장치 (OTP, 기관 지급 인증장치 등) 또는 계정 사용자가 소유하고 있으며 기관이 승인한 장치 이용(SMS, 모바일 공무원증, 모바일 OTP 등) (3) 생체기반 요소: 사용자 고유 생체정보 (지문, 홍채, 얼굴, 정맥 등)	●	●	●
		N2SF-MA-2	사용자 계정 다중요소 인증 (MFA, Multi-factor Authentication)	지정되지 않은 접속 경로 또는 사전 승인되지 않은 단말을 통한 사용자 계정에 대해 다중요소 인증을 적용한다.	●	●	
		N2SF-MA-3	다중요소 인증 장치 분리	다중요소 인증시에는 인증을 요청한 장치와 물리적으로 분리된 별도의 장치(수단 등)를 활용하여 인증을 수행한다.	●	●	●

대항목	중항목	N2SF ID	소항목	보안통제설명	N2SF 우선 검토사항		
					 기밀	 민감	 공개
인증	다중요소인증 Multi-Factor Authentication (MA)	N2SF-MA-4	다중요소 인증 (MFA, Multi-factor Authentication) 경로 분리	다중요소 인증시에는 인증을 요청한 장치의 통신 경로와 분리된 별도의 통신 경로를 통해 인증을 수행한다.	●	●	●
		N2SF-MA-5	특정상황에서의 다중요소 인증	특정 상황 또는 조건에서는 다중요소 인증을 적용하여 사용자를 인증한다.	●	●	
		N2SF-MA-M1	다중인증요소 설정 및 관리	보안 정책 또는 조건에 따라 다중요소 인증(MFA)의 적용 대상, 방식, 조합 기준을 정의하고 주기적으로 검토 및 관리하며, MFA 설정 변경은 승인 절차를 거쳐 수행된다.	●	●	●
	외부인증수단 External Identity (EI)	N2SF-EI-1	외부 자격증명 수단 활용	안전성 및 신뢰성을 검증받은 외부 기관(또는 업체 등)에서 발급한 자격증명 수단을 활용한다.	●	●	
		N2SF-EI-2	외부 인증수단 활용	안전성 및 신뢰성을 검증받은 외부의 인증수단을 활용한다.	●	●	
		N2SF-EI-M1	외부 인증수단 관리	외부 인증수단의 등록, 변경, 폐지 등 전체 수명주기를 체계적으로 관리하며, 외부 기관과의 연계된 인증 프로파일의 보안 검증을 주기적으로 수행한다.	●		
	단말인증 Device Authentication (DA)	N2SF-DA-1	단말 무결성 검증	단말 내 신뢰 가능한 모듈(TPM 등)을 통한 구성정보(BIOS 설정정보, Disk 설치 정보 등) 등을 확인한다.	●	●	
		N2SF-DA-2	정보서비스 식별 및 제한	인증절차를 통해 사전 승인한 정보서비스만을 활용하도록 제한한다.	●	●	
		N2SF-DA-3	단말 식별 및 인증	단말의 고유 식별자(MAC, TPM, 인증서 등)를 통해 단말을 식별하고, 등록된 단말만 인증을 통해 시스템에 접근할 수 있도록 한다.	●	●	
		N2SF-DA-3(1)	인가 단말 인증	조직 내 등록되어 인가된 단말에 한해 인증수단(디지털 인증서, 장치지문 등)을 통해 접근을 허용한다.	●	●	
		N2SF-DA-3(2)	비인가 단말 인증	등록되지 않았거나 보안 기준을 충족하지 못한 단말은 인증 요청을 차단하거나 별도 네트워크 구역으로 격리한다.	●		
		N2SF-DA-4	인증된 단말의 접속 관리	인증된 단말이라 하더라도 접속 시간, 위치, 사용자에 따라 세부 접근 권한을 제어하고, 접근 이력을 기록하여 감사 가능하도록 한다.	●		
		N2SF-DA-5	외부 단말 접속 제어	외부에서 접근하는 단말은 보안 VPN, 다중요소 인증(MFA), 장치검증 등 추가 보안 절차를 거쳐서만 제한된 자원에 접근하도록 구성한다.	●	●	●

대항목	중항목	N2SF ID	소항목	보안통제설명	N2SF 우선 검토사항		
					 기밀	 민감	 공개
인증	인증보호 Authentication Protection (AU)	N2SF-AU-1	계정 인증 재전송 공격 방지	불법적인 계정 인증을 시도하는 재전송 공격 방지 대책을 적용한다.	●	●	●
		N2SF-AU-2	통합인증(SSO, Single Sign-on) 보호	통합인증 기능 적용 시 불법적인 계정 로그인 시도에 대한 기술적 대책을 적용한다.	●	●	
		N2SF-AU-3	권한 위임 토큰(OAuth) 보호	권한 위임 토큰(OAuth) 토큰이 탈취되거나 위조되지 않도록 제한 조건과 보호 조치를 설정한다.	●	●	
		N2SF-AU-4	생체 인증 공격 방지	생체 데이터를 암호화 하여 저장 및 전송하며, 변조 여부를 탐지할 수 있는 메커니즘을 사용한다.	●	●	●
		N2SF-AU-5	인증 시스템 구성 및 관리	인증 시스템의 구성 요소를 안전하게 설정하고 변경 시 보안에 영향이 없도록 관리한다.	●	●	
		N2SF-AU-5(1)	비밀번호 보안수준 점검	자동화된 도구를 이용하여 비밀번호 정책에 적합하게 설정·유지되고 있는지 점검한다.	●		
		N2SF-AU-5(2)	대체 보안수단 강구	보안 기능을 구현 또는 제공하는 주요 수단을 사용할 수 없거나 손상되었을 상황을 대비한 대체 보안수단을 강구한다.	●		
		N2SF-AU-6	공개키 기반구조(PKI) 인증서 관리	신뢰할 수 있는 공개 키 인프라(PKI)를 통해 발급된 인증서 사용을 인증서 유효기간 동안 관리하고 보호한다.	●	●	●
		N2SF-AU-M1	인증 정보 접근 권한 통제 및 관리	인증 정보는 최소한의 인원만 접근할 수 있도록 제한하고 기록을 남긴다.	●	●	●
		N2SF-AU-M2	인증 위험 및 취약점 관리	인증 관련 취약점을 점검하고 위험 대응 방안을 마련해 운영한다.	●	●	●
	인증정책 Authentication Policy (AP)	N2SF-AP-1	기관 발급 증명수단 인증 활용	기관에서 발급한 자격 증명수단(모바일 공무원증 등)을 활용하여 사용자를 인증한다.	●	●	
		N2SF-AP-2	인증 프로파일 활용	사용자의 직무나 역할에 따라 인증 기준을 정하고, 그에 맞게 관리한다.	●	●	
		N2SF-AP-3	그룹 계정 사용자 인증	그룹 계정 인증 시 해당 그룹 계정에 포함된 사용자를 식별할 수 있는 인증수단을 적용하여 사용자 인증을 추가로 수행한다.	●	●	
		N2SF-AP-4	재인증	주기적 또는 특정 상황·조건에서는 사용자에게 재인증을 요구한다.	●		
		N2SF-AP-5	동시 중복 인증 차단	정보서비스 특성을 반영하여 동시 중복인증을 차단한다.	●		
		N2SF-AP-M1	인증 정책 수립 및 절차 관리	인증 방식이나 기준을 정하고, 절차를 따라 관리한다.	●	●	

대항목	중항목	N2SF ID	소항목	보안통제설명	N2SF 우선 검토사항		
					 기밀	 민감	 공개
인증	인증정책 Authentication Policy (AP)	N2SF-AP-M2	인증 관리자의 역할 및 책임 관리	인증을 담당하는 관리자에게 역할과 책임을 분명히 정해 운영한다.	●	●	
		N2SF-AP-M3	인증 관련 보안사고 대응체계	인증 관련 문제가 생겼을 때에 대한 대응 절차를 마련해 둔다.	●	●	●
	인증수단 Authentication Method (AM)	N2SF-AM-1	암호모듈 기반 인증	관련 법규, 정책 및 규정 등을 준수한 암호모듈 인증체계를 적용한다.	●	●	●
		N2SF-AM-2	비밀번호 기반 인증	숫자·문자·특수문자 등을 혼합하고 주기적으로 변경하는 비밀번호 인증체계를 적용한다.	●	●	●
		N2SF-AM-3	공개키 기반 인증	신뢰할 수 있는 인증 기관(CA)을 통해 발급된 인증서의 유효성을 검증하고, 인증서의 발급, 갱신, 폐지 등을 관리한다.	●	●	●
		N2SF-AM-4	초기 인증수단 변경	시스템 설치 후 초기 설정된 비밀번호나 인증서는 반드시 사용자 지정값으로 변경하도록 하여 기본값 노출을 방지한다.	●	●	●
		N2SF-AM-5	인증수단 보호	정보시스템의 보안수준에 준하여 인증수단을 보호한다.	●	●	
		N2SF-AM-6	암호화 되지 않은 인증수단 내장 금지	암호화되지 않은 인증수단이 응용프로그램 또는 스크립트 등에 내장되거나 기능키 등에 삽입되지 않아야 한다.	●	●	●
		N2SF-AM-7	캐시된 인증수단 재사용 차단	캐시된 인증수단이 세션 유효 시간이 만료된 이후에 재사용되는 것을 차단한다.	●	●	●
		N2SF-AM-8	공개키 기반 저장소 관리	네트워크, 운영체제, 브라우저, 응용프로그램을 포함하여 모든 정보시스템에 설치된 PKI 저장소에 대해 관리방안을 수립한다.	●	●	
		N2SF-AM-9	소유기반 인증	생체인증, 모바일 인증 및 하드웨어 토큰 등을 활용한 인증체계를 적용한다.	●	●	●
		N2SF-AM-M1	인증 시스템 운영 감사	인증 서버와 구성요소가 안전하게 운영되고 있는지 주기적으로 점검하고, 이상 행위는 감사 대상에 포함한다.	●	●	
		N2SF-AM-M2	인증수단 정기적 보안 평가	사용 중인 인증 방식과 시스템에 대해 정기적으로 취약점 분석과 보안성 평가를 수행하여 보완한다.	●	●	
	로그인 Login (LI)	N2SF-LI-1	유효한 인증정보 노출 방지	인증 과정에서 유효한 인증 정보가 노출되지 않도록 한다.	●	●	●
		N2SF-LI-2	로그인 실패에 따른 접속 제한	정당한 횟수 이상 연속적으로 로그인을 실패한 경우 일정시간 계정을 차단(또는 잠금)하거나 접속을 제한한다.	●	●	

대항목	중항목	N2SF ID	소항목	보안통제설명	N2SF 우선 검토사항		
					 기밀	 민감	 공개
인증	로그인 Login (LI)	N2SF-LI-3	로그인 실패에 따른 인증요소 추가	정당한 횟수 이상 연속적으로 로그인을 실패한 경우 추가 인증수단(생체인증, OTP, ARS 등)을 적용한다.	●	●	
		N2SF-LI-4	계정 잠금 해제 인증요소 추가	계정 잠금 상태에서 해제 요청 시 기본 인증 요소 외 인증요소를 추가 사용한다.	●	●	
		N2SF-LI-5	정보시스템 사용 알림	로그인(사용자 인증 성공) 후 사용자 화면에 정보시스템(서비스 등)에 관한 정보를 알림으로 표시하고, 사용자가 명확하게 인지한 상황에서 표시를 종료하도록 적용한다.	●		
		N2SF-LI-6	직전 로그인 정보 알림	로그인(사용자 인증 성공) 후 사용자 화면에 사용자의 직전 로그인 정보를 사용자가 확인할 수 있도록 표시한다.	●	●	
		N2SF-LI-7	실패 로그인 정보 알림	로그인(사용자 인증 성공) 후 사용자 화면에 사용자의 로그인 실패 정보를 사용자가 확인할 수 있도록 알림을 표시한다.	●		
		N2SF-LI-8	로그인 이력 정보 제공	로그인(사용자 인증 성공) 후 사용자 화면에 로그인 성공 이력 정보를 제공한다.	●	●	
		N2SF-LI-9	계정 정보 변경 알림	로그인(사용자 인증 성공) 후 사용자 계정 관련 정보 변경 이력이 존재하는 경우, 일정 기간동안 사용자에게 해당 내용 알림을 표시한다.	●		
		N2SF-LI-10	로그인 부가 정보 제공	로그인(사용자 인증 성공) 후 이전에 성공한 로그인과 관련된 부가정보(접속위치, 단말 종류 등)를 제공한다.	●		
		N2SF-LI-M1	로그인 실패 모니터링 및 보고	반복 실패, 의심 로그인 시도 등의 실패 패턴을 실시간 감지하고 관리자에게 보고한다.	●		
		N2SF-LI-M2	주기적 로그인 정보 무결성 점검	로그인 관련 데이터(세션, 토큰, 사용자 연계 정보 등)에 대해 주기적으로 무결성을 점검하고 이상 여부를 확인한다.	●	●	
분리 및 격리	분리 Segregation (SG)	N2SF-SG-1	하드웨어 기반 분리	서로 다른 영역이 구분되도록 하드웨어를 통해 분리하고, 보안통제를 적용한다.	●	●	
		N2SF-SG-2	운영체제(OS) 기반 분리	하나의 시스템에 다수 OS 가 존재하더라도, 각 운영체제는 서로 독립된 환경으로 분리되도록 구성한다.	●	●	●
		N2SF-SG-2(1)	시스템 파티셔닝	동일 하드웨어 내에서도 OS, 데이터, 애플리케이션 영역을 파티션별로 구분하여 영역 간 영향을 제한한다.	●		
		N2SF-SG-3	소프트웨어 기반 분리	소프트웨어적 논리구조를 활용하여 기능이나 사용자의 실행 영역을 분리하며, 실행 파일 간 충돌이나 간섭을 차단한다.	●	●	

대항목	중항목	N2SF ID	소항목	보안통제설명	N2SF 우선 검토사항		
					 기밀	 민감	 공개
분리 및 격리	분리 Segregation (SG)	N2SF-SG-3(1)	프로세스 기반 분리	다중 사용자 또는 다중 작업 실행 시 프로세스 간 간섭을 방지하기 위해 각각의 실행 공간을 격리한다.	●	●	
		N2SF-SG-4	IP 체계 분리	서로 다른 영역 또는 정보자산(기능 등)별 IP 체계를 분리하고, 보안통제를 적용한다.	●	●	●
		N2SF-SG-5	보안·운영관리 인프라 분리	보안·운영관리 인프라를 물리적으로 분리된 네트워크로 구성하여 이외 정보시스템과 분리한다.	●	●	
		N2SF-SG-5(1)	개발/테스트 환경 분리	운영 시스템과 구분된 개발/테스트 환경을 별도 구성하여 시스템 안정성과 보안을 확보한다.	●	●	●
		N2SF-SG-6	보안 기능과 사용자 기능 분리	인증, 감사 및 데이터 통제와 같은 핵심 보안 기능과 데이터 입력, 애플리케이션 실행 등 사용자 기능을 분리한다.	●	●	
		N2SF-SG-M1	분리 정책 및 절차 수립	자산 간 분리 기준, 설정 방식, 승인 절차 등을 포함한 정책과 문서화된 절차를 수립한다.	●	●	
		N2SF-SG-M2	보안·운영 인프라 접근 책임 및 역할 관리	분리된 인프라에 접근 가능한 대상 및 책임자를 지정하고 권한 기반 접근 통제를 적용한다.	●		
		N2SF-SG-M3	분리된 시스템 정기적 평가 및 감사	분리된 영역의 적절성, 위험, 취약점 등을 정기적으로 점검하고, 감사 결과에 따라 개선 조치를 수행한다.	●	●	
		N2SF-SG-M4	분리환경 접근권한 관리 및 모니터링	분리된 환경에 대한 접근권한을 사용자, 장비, 서비스 단위로 설정하고 이를 모니터링한다.	●	●	
		N2SF-SG-M5	분리 위반사항 대응체계 운영	분리 정책 위반 발생 시 자동 경고, 세션 차단, 감사 로그 저장 등 즉시 대응이 가능하도록 대응 체계를 운영한다.	●		
	격리 Isolation (IS)	N2SF-IS-1	프로세스 격리	실행되는 각 프로세스(작업 또는 프로그램)가 다른 프로세스에 영향을 미치거나 간섭을 차단하기 위해 독립된 공간에서 실행한다.	●		
		N2SF-IS-2	정보시스템 운영·관리 기능 표출 제한	일반 사용자에게 정보시스템 관리와 관련된 기능 및 인터페이스 표출을 제한한다.	●	●	●
		N2SF-IS-3	애플리케이션 논리적 격리	하나의 시스템 내 여러 애플리케이션이 서로 자원을 공유하지 않도록 논리적으로 격리해 민감 데이터 접근을 제한한다.	●	●	
		N2SF-IS-4	네트워크 격리	내부망, 외부망, 보안망 등 네트워크 간에 방화벽, 라우팅 제어 등으로 트래픽을 분리하여 정보 유출 또는 확산을 방지한다.	●	●	●

대항목	중항목	N2SF ID	소항목	보안통제설명	N2SF 우선 검토사항		
					 기밀	 민감	 공개
분리 및 격리	격리 Isolation (IS)	N2SF-IS-5	가상화 환경 격리	가상머신(VM) 또는 컨테이너는 호스트와 다른 가상 환경 간 간섭이 없도록 하이퍼바이저 및 메모리 보호 기술로 격리한다.	●	●	●
		N2SF-IS-6	격리 위반사항 대응체계 운영	시스템 간 경계 침해, 애플리케이션 간 접근 시도 등 격리 위반 탐지 시 경고, 차단, 로그 분석 등 즉각적인 대응체계를 갖춘다.	●	●	●
통제	정보흐름 Information Flow (IF)	N2SF-IF-1	정보흐름의 동적 통제	정보시스템의 비정상 동작, 외부의 공격 등 지정된 조건에 대하여 정보흐름을 동적으로 통제한다.	●	●	
		N2SF-IF-2	암호화된 정보흐름 통제	암호화된 정보의 내용을 확인하기 위하여 정보를 복호화하거나, 확인이 불가능한 암호화된 정보는 흐름을 차단하는 등의 조치를 적용한다.	●	●	
		N2SF-IF-3	임베디드 데이터 삽입 차단	임베디드된 데이터 내부에 인가되지 않은 다른 종류의 데이터가 삽입되는 것을 차단한다.	●	●	●
		N2SF-IF-4	메타데이터 활용 정보흐름 통제	메타데이터(소유자, 생성일시 등 기록), 이미지/영상/오디오용 메타데이터 등을 활용하여 정보흐름을 통제한다.	●		
		N2SF-IF-5	일방향 정보흐름 통제	일방향 전송 장치를 통해 단방향 정보 흐름만 허용하고 반대 방향 흐름을 차단한다.	●		
		N2SF-IF-6	필터링 규칙 정보흐름 통제	보안 및 프라이버시 등에 관한 필터링 규칙을 적용하여 정보흐름을 통제한다.	●	●	●
		N2SF-IF-7	데이터 유형 식별자 통제	서로 다른 영역 간에 정보를 전송하는 경우 데이터 유형 식별자를 확인하여 전송 여부를 통제한다.	●	●	
		N2SF-IF-8	인가되지 않은 정보 전송 통제	인가되지 않은 정보가 포함되었는지 검사하고 보안정책에 따라 해당 정보의 전송을 차단한다.	●	●	
		N2SF-IF-9	출발지점과 도착지점 식별 및 인증	정보 전송 시 개인, 기관, 응용프로그램 혹은 정보시스템 등 하나 이상을 사용하여 출발지점과 도착지점을 식별하고 인증한다.	●	●	●
		N2SF-IF-10	정보 전송 방식 제한	정보 전송 시 특정 매체나 방식만 허용하고 나머지는 차단한다.	●	●	
		N2SF-IF-11	데이터 전송 차단	서로 다른 정보시스템(또는 영역 등)으로의 접근은 허용하되 데이터 전송은 차단한다.	●		
		N2SF-IF-12	정보흐름 통제 기능 유지	독립적인 다수의 정보흐름 통제 체계를 구성하여 하나의 통제 체계가 무력화되더라도 정보흐름 통제 기능을 유지한다.	●	●	

대항목	중항목	N2SF ID	소항목	보안통제설명	N2SF 우선 검토사항		
					 기밀	 민감	 공개
통제	정보흐름 Information Flow (IF)	N2SF-IF-13	시간기반/상황기 반 흐름 제한	특정 시간대 또는 상황(비상, 침해 등)에 따라 정보흐름을 제한하거나 차단한다.	●	●	
		N2SF-IF-14	보안등급 기반 흐름 통제	보안등급에 따라 정보 흐름을 제한하여 상위 등급에서 하위 등급으로의 부적절한 전송을 차단한다.	●	●	
		N2SF-IF-15	전용 통신망 구성	외부로부터 정보흐름을 보호할 수 있는 전용 통신망(전용회선, 가상사설망 등)을 구성한다.	●	●	
		N2SF-IF-M1	정보흐름 통제 정책 수립 및 갱신	정보흐름에 대한 통제 기준 및 예외 절차를 문서화하고 정기적으로 갱신한다.	●	●	●
		N2SF-IF-M2	정보흐름 로그 기록 및 보존	정보흐름 통제 활동(허용/차단 등)을 로깅하고, 법적/감사 목적으로 일정 기간 보관한다.	●	●	●
		N2SF-IF-M3	정보흐름 통제 감사 및 이행 점검	정보흐름 통제의 적용 현황을 정기적으로 점검하여 정책 미준수 사항을 식별 및 개선한다.	●	●	
		N2SF-IF-M4	비인가 흐름 탐지 자동화	정책을 우회하거나 비정상적 흐름을 탐지하기 위한 자동화 도구 또는 시스템을 구축한다.	●	●	
		N2SF-IF-M5	통제 실패·예외 보고 체계	통제가 실패하거나 예외 발생 시 담당자에게 자동 보고하고 이를 기록하는 체계를 마련한다.	●	●	
	외부경계 External Boundary (EB)	N2SF-EB-1	연결 접점 제한	정보시스템의 외부 네트워크 연결 접점 수를 제한한다.	●	●	
		N2SF-EB-2	서비스별 외부 통신 통제	외부와 통신하는 서비스의 경계마다 통신흐름을 통제한다.	●	●	●
		N2SF-EB-3	화이트리스트 기반 통신 허용	기본적으로 모든 통신을 차단한 상태에서 필요한 통신만을 허용하는 화이트리스트 기반 정책을 적용한다.	●	●	
		N2SF-EB-4	분할 터널링(Split Tunneling) 제한	인터넷 서비스와 원격접속을 통한 기관 네트워크를 동시에 이용하는 등 내·외부 통신을 동시 연결하는 분할 터널링 기법을 제한한다.	●	●	●
		N2SF-EB-5	통신 경유(proxy) 강제화	인가된 정보시스템을 경유하여 통신하도록 통신경로를 강제화한다.	●		
		N2SF-EB-6	외부로의 사이버위협 통신 발신 제한	내부에서 외부 네트워크에 사이버위협을 가하는 발신(outbound) 통신을 탐지 및 차단하고, 발신자(사용자 및 정보자산 등)를 식별한다.	●	●	
		N2SF-EB-7	호스트 기반 경계 보호	정보시스템 구성요소에 호스트 기반 경계 보안체계를 적용한다.	●	●	
		N2SF-EB-8	운영관리용 포트의 물리적 연결 차단	운영관리용 포트에 인가되지 않은 장치의 포트 연결을 차단한다.	●	●	●

대항목	중항목	N2SF ID	소항목	보안통제설명	N2SF 우선 검토사항		
					 기밀	 민감	 공개
통제	외부경계 External Boundary (EB)	N2SF-EB-9	전용 장치를 통한 관리자 권한 접속	전용 장치를 통해서만 네트워크를 경유하여 관리자 권한으로 접속한다.	●	●	●
		N2SF-EB-10	정보시스템 구성요소 외부 노출 차단	정보시스템 운영관리 및 서비스를 제공하는 구성요소가 외부 노출되지 않도록 차단한다.	●	●	●
		N2SF-EB-11	외부 경계 보호 기능 유지	외부 경계를 보호하는 정보자산(보안시스템 등) 장애 시에도 보호기능은 유지되도록 구성한다.	●	●	●
		N2SF-EB-12	외부 통신용 정보자산(장치) 설치 금지	외부 네트워크와 통신하는 인가되지 않은 정보자산(장치) 설치를 금지한다.	●	●	●
		N2SF-EB-13	오류정보 발신자 전송 제한	네트워크 규약에 따른 통신 오류 발생 시 발신자에게 피드백이나 경고를 통해 정보시스템 구성이나 취약점이 전송되지 않도록 한다.	●	●	
		N2SF-EB-14	외부 DNS 통신 제한	인가된 DNS 서버 외의 요청을 차단한다.	●		
		N2SF-EB-15	우회 통신 수단 탐지 및 차단	VPN, Tor 등 우회 경로 사용을 탐지하고 차단한다.	●	●	
		N2SF-EB-M1	개인 식별정보 보호	외부와 통신 시 개인을 식별하거나 특정 개인과 관련된 정보를 포함하는 경우 노출되지 않도록 조치한다.	●	●	
		N2SF-EB-M2	외부 경계 정책 수립 및 갱신	외부 통신 및 경계 보안 정책을 수립하고 주기적으로 갱신한다.	●	●	●
		N2SF-EB-M3	외부 통신 로그 기록 및 감사	외부 통신 활동과 설정 변경 사항을 기록하고 감사가 가능하게 한다.	●	●	●
		N2SF-EB-M4	외부 경계 위협 탐지 자동화	이상 행위를 자동으로 탐지하는 시스템을 운영한다.	●		
		N2SF-EB-M5	비상 시 외부 통신 격리	침해 발생 시 외부 통신을 즉시 차단할 수 있는 절차를 마련한다.	●	●	
	크로스도메인 보안 Cross Domain Solution (CD)	N2SF-CD-1	도메인 간 정보 흐름 검증 및 통제	서로 다른 보안 도메인 간 정보 흐름 시 데이터 유형, 등급, 출처를 검증하고 사전에 정의된 정책에 따라 전송을 허용, 차단 또는 보류한다.	●	●	
		N2SF-CD-2	다단계 보안 레이블 적용	전송되는 정보에 대해 다단계 보안 등급(예: 기밀, 민감, 공개)을 태깅하고, 대상 도메인의 수신 허용 기준에 부합하는 경우에만 전달한다.	●		

대항목	중항목	N2SF ID	소항목	보안통제설명	N2SF 우선 검토사항		
					 기밀	 민감	 공개
통제	크로스도메인 보안 Cross Domain Solution (CD)	N2SF-CD-3	일방향 전송 기술 적용 (Data Diode)	정보 유출 방지를 위해 단방향 전송 장치(Data Diode)를 활용하여 물리적 또는 논리적 일방향 정보 흐름을 강제한다. ※ N2SF-IF-5 와 유사하지만, CDS 에서 일방향 보장 장비 사용 시 구체적으로 분리 필요	●	●	
		N2SF-CD-4	검증 기반 릴레이 시스템 적용	수신된 정보는 릴레이 서버를 통해 악성코드 스캔, 포맷 검증, 콘텐츠 정제 후 안전성 판단을 거쳐 송신된다.	●	●	
		N2SF-CD-5	파일 유형 기반 전송 정책	파일 확장자, MIME 타입, 내부 Magic Number 등을 기준으로 허용된 파일 유형만 송수신 허용하고 나머지는 격리 또는 삭제한다.	●	●	
		N2SF-CD-6	콘텐츠 무해화 (CDR) 적용	전송 전 파일 내 삽입된 숨겨진 객체, 매크로, 스크립트 등을 제거하고 안전한 형식으로 변환하여 콘텐츠를 정제한다.	●		
		N2SF-CD-7	메타데이터 기반 통제 정책	파일 메타데이터의 생성일, 작성자, 등급 등 정보에 따라 송수신 정책을 달리 적용하고, 필요 시 메타데이터 제거 후 전송한다.	●	●	
		N2SF-CD-8	승인된 CDS 구성요소만 사용	크로스 도메인 연계를 위한 CDS 는 기관이 검증하고 승인한 하드웨어/소프트웨어 구성요소만을 사용해야 한다.	●	●	●
		N2SF-CD-9	CDS 우회 경로 탐지 및 차단	CDS 를 우회하여 다른 경로(USB, 무선, 별도 링크 등)로 도메인 간 전송을 시도하는 행위를 탐지하고 차단한다.	●	●	
		N2SF-CD-10	전송 실패 보호 및 무결성 보장	전송 중 실패 시 데이터가 존존하거나 일부가 누락되지 않도록 조치하고, 수신자가 정보의 완전성과 무결성을 검증할 수 있도록 한다.	●	●	
		N2SF-CD-11	등급 간 콘텐츠 정책 적용	다양한 등급 간 콘텐츠 전송 시 등급 정책에 따른 필터링, 수정, 전환 작업을 수행할 수 있도록 한다.	●	●	
		N2SF-CD-12	사용자 및 단말 등록 기반 접근 제어	CDS 접근을 허용할 사용자와 단말 정보를 사전에 등록하고, 정책에 기반해 인증을 수행한다.	●	●	●
		N2SF-CD-13	트래픽 흐름 컨텍스트 분석	동일 사용자 단말의 연속적인 전송 흐름을 분석하여 비정상 컨텍스트(다량, 시간외 등)를 차단한다.	●	●	
		N2SF-CD-M1	CDS 운용 정책 수립	CDS 구성, 운용, 접근, 예외 처리 절차 등을 포함한 관리 정책을 수립하고 주기적으로 갱신한다.	●	●	●
		N2SF-CD-M2	CDS 통제 로그 기록 및 감사	CDS 를 통한 정보 흐름의 허용, 차단, 예외처리 등의 모든 활동을 로깅하고 주기적으로 감사한다.	●	●	●

대항목	중항목	N2SF ID	소항목	보안통제설명	N2SF 우선 검토사항		
					 기밀	 민감	 공개
통제	크로스도메인 보안 Cross Domain Solution (CD)	N2SF-CD-M3	도메인 간 정보 교환 승인 프로세스	도메인 간 정보 교환은 사전 승인된 업무 목적 및 사용자에게 한정되며, 자동화된 승인 및 검토 체계를 갖추어야 한다.	●	●	
		N2SF-CD-M4	CDS 구성요소 무결성 검증	CDS 시스템의 구성요소(소프트웨어, 펌웨어 등)에 대한 무결성을 정기적으로 검증하고 변경 시 승인 절차를 거친다.	●	●	●
	원격접속 Remote Access (RA)	N2SF-RA-1	원격접속 모니터링 및 통제	원격접속을 모니터링하고 통제한다.	●	●	●
		N2SF-RA-2	원격접속 세션 암호화	원격접속 세션의 기밀성과 무결성을 보호하기 위해 통신구간 암호화를 적용한다.	●	●	●
		N2SF-RA-3	원격접속위치 통제	보안관리 및 통제가 가능한 물리적 공간(위치) 또는 기술적 대책을 적용하여 원격접속을 허용한다.	●	●	
		N2SF-RA-4	관리자 권한 통제	원격접속을 통한 관리자 권한은 제한된 조건에서만 허용해야 하며, 관리자 권한으로 실행한 명령어 이력 등은 유지한다.	—	●	
		N2SF-RA-5	원격접속 정보 유출 방지	원격접속에 관한 정보를 무단으로 사용하거나 외부로 유출되는 것을 방지한다.	●	●	●
		N2SF-RA-6	원격접속 자동 종료 및 비활성화	일정시간 경과 등 조건에 따라 원격접속을 자동 종료하거나, 원격접속 목적이 달성된 경우 비활성화한다.	●	●	●
		N2SF-RA-7	원격 명령 신뢰성 검증	명령을 수행하기 전에 적절한 인증 체계(암호화된 인증서, 보안 토큰, 또는 사용자 인증)를 적용하여 명령의 무결성과 출처를 검증한다.	●		
		N2SF-RA-M1	원격접속 정책 수립 및 예외 관리	원격접속 허용 대상, 시간, 인증수단 등에 대한 정책을 수립하고 예외 시 승인 절차를 마련한다.	●	●	
		N2SF-RA-M2	원격접속 로그 보존 및 감사	원격접속 활동 기록을 수집하여 정기 감사가 가능하도록 보존한다.	●	●	●
		N2SF-RA-M3	원격접속 보안 점검 주기 운영	원격접속 정책 이행 여부와 취약 구성 점검을 주기적으로 수행한다.	●	●	
	세션 Session (SN)	N2SF-SN-1	로그아웃 세션 처리	로그아웃 또는 비정상 세션 종료 시 연결되었던 모든 세션의 식별자를 즉시 무효화하며, 더 이상 세션이 유효하지 않도록 한다.	●	●	●
		N2SF-SN-2	세션별 고유 식별자	각 사용자 세션마다 고유한 식별자를 활용하고, 고유한 식별자의 재사용을 방지한다.	●	●	●
		N2SF-SN-3	동시 접속 세션 제한	사용자 계정 또는 정보시스템 등을 기준으로 동시 세션 수를 제한한다.	●		
		N2SF-SN-4	세션 종료	세션 종료 요청이 있거나 세션 종료 조건 발생 시 자동으로 세션을 종료한다.	●	●	●

대항목	중항목	N2SF ID	소항목	보안통제설명	N2SF 우선 검토사항		
					 기밀	 민감	 공개
통제	세션 Session (SN)	N2SF-SN-4(1)	사용자 기반 로그아웃	사용자 요청에 따라 로그아웃 할 수 있는 기능을 제공한다.	●	●	●
		N2SF-SN-4(2)	종료 메시지	사용자에게 종료되었다는 메시지를 표시한다.	●	●	●
		N2SF-SN-5	로그인 유효시간 경과 경고 메시지	사용자에게 로그인 유효시간 경고 메시지를 표시한다.	●	●	
		N2SF-SN-6	네트워크 연결 해제	정상 세션 종료 또는 일정 시간 비활성 상태가 유지될 경우 네트워크 연결을 자동 해제한다.	●	●	●
		N2SF-SN-7	세션 중 행위 기반 비정상 탐지	세션 중 사용자 행위가 정상 범위를 벗어나면 자동으로 세션을 종료하거나 별도 인증 절차를 유도한다. (예: 위치 급변, 동시접속 이상 등)	●		
		N2SF-SN-8	세션 중 연속 인증 수행	장시간 세션 또는 민감 작업 수행 시, 주기적 또는 조건 기반으로 인증수단(MFA 등)을 다시 요구한다.	●	●	
		N2SF-SN-M1	세션 관리 정책 수립	세션 유지 시간, 비활성화 조건, 동시 접속 허용 수 등 세션 운용 정책을 수립하고 문서화한다.	●	●	
		N2SF-SN-M2	세션 감사 및 로그 기록	세션 생성, 종료, 중복, 충돌 등 관련 활동을 로깅하고 보안 감사가 가능하도록 구성한다.	●	●	●
	무선망접속 Wireless Network Access (WA)	N2SF-WA-1	업무용 무선망 인증 및 암호화	사용자 인증, 기기(단말 등) 인증 및 무선통신 구간 암호화를 적용한다.	●	●	●
		N2SF-WA-2	업무용 무선망 인증정보 보호	업무용 무선 통신망 서비스 식별 정보(SSID 등)를 경계지역 외부에서 확인할 수 없도록 적용하고, 무선 통신망 인증정보의 무단 사용 및 외부 유출을 방지한다.	●	●	●
		N2SF-WA-3	업무용 무선망 신호 보호	무선 통신환경에 적합한 안테나를 선택하고 송수신 출력을 교신에 필요한 최저 출력으로 유지하여 경계지역 외부로 전파 되는 것을 방지한다.	●		
		N2SF-WA-4	비인가 무선장비 설치 차단	업무용 무선망 서비스에 비인가 무선장비가 설치되거나 가동되는 것을 탐지하고 운용되지 않도록 한다.	●	●	●
		N2SF-WA-5	외부인 전용 무선망 구성	업무용 네트워크 또는 무선망과 분리하여 외부인 전용망을 구성한다.	-	●	●
		N2SF-WA-6	무선망 관리기능 보호	무선망 관리기능은 무선망에 노출되지 않아야 하며, 지정된 관리자만 접속되도록 통제한다.	●	●	●
		N2SF-WA-7	비인가 무선망 접속 차단	인가되지 않은 무선망 접속을 차단한다.	●	●	●
		N2SF-WA-M1	무선망 세션/로그 분석	무선 접속 로그와 세션 데이터를 통해 이상행위를 분석한다.	●	●	

대항목	중항목	N2SF ID	소항목	보안통제설명	N2SF 우선 검토사항		
					 기밀	 민감	 공개
통제	블루투스연결 Bluetooth Connection (BC)	N2SF-BC-1	블루투스 데이터 통신 제한	블루투스 장치 연결 시 키보드, 마우스, 오디오 등을 위한 입출력 기능 외 데이터 통신은 차단한다.	●	●	
데이터	암호 키 관리 Encryption Key Management (EK)	N2SF-EK-1	암호 키 설정	데이터 저장을 위해 암호 키를 생성하는 경우, 유형별 암호 키(대칭 키, 공개 키 등) 및 인증서를 키 관리 시스템(KMS)을 활용할 수 있다. 암호 키를 설정 시 C/S/O 보안등급별 암호화 강도, 암호 알고리즘(국산 암호, 국제표준암호 등), 암호 키 유효기간 및 갱신, 암호 키와 서명용 키 분리, CRL(인증서 폐기 목록) 생성 주기 및 배포 경로 등을 설정한다.	●	●	●
		N2SF-EK-2	암호 키 생성	KCMVP(Korea Cryptographic Module Validation Program) 인증을 받은 난수 발생기 또는 암호 모듈을 사용하며, 데이터의 보안 등급에 따라 소프트웨어 기반 TRNG (True Random Number Generator) 또는 하드웨어 기반 난수발생기를 사용한다.	●	●	
		N2SF-EK-3	암호 키 저장	암호 키는 암호화된 형태로 저장하거나 보안성이 요구되는 경우 보안 토큰 등을 사용하여 분리 보관한다.	●	●	●
		N2SF-EK-4	암호 키 사용	데이터 저장 규모 및 성능에 따라 암호화된 데이터베이스 또는 하드웨어 보안 모듈(HSM: Hardware Security Module)을 활용하여 암호 키를 사용한다. 클라우드 환경에서 암호키를 안전하게 저장, 사용하기 위해 HSM 을 활용할 수 있다.	●	●	
		N2SF-EK-5	암호 키 폐기	암호키는 복구 불가능한 상태로 안전하게 삭제하고 동일 암호 키가 재생성 및 재사용되지 않도록 조치한다. 그리고 CRL(인증서 폐기 목록)을 관리해야 한다.	●	●	●
		N2SF-EK-6	전자서명 검증	데이터의 전송 및 저장 시 데이터 무결성 확인 및 암호화를 통한 데이터 보호를 위해 전자서명 생성 및 검증 키 관리, 표준화된 서명 검증 알고리즘과 서명용 인증서 관리, 전자서명 검증 기술을 적용한다.	●	●	●
		N2SF-EK-M1	암호 키 저장소 관리	암호 키 저장소는 접근권한이 인가된 사용자로 제한되며, 물리적·논리적으로 분리하여 보호해야 한다. 저장소 접근 로그는 감사 목적으로 기록·관리되어야 한다.	●	●	

대항목	중항목	N2SF ID	소항목	보안통제설명	N2SF 우선 검토사항		
					 기밀	 민감	 공개
데이터	암호 키 관리 Encryption Key Management (EK)	N2SF-EK-M2	암호 키 관리 정책 및 절차	암호 키의 생성, 저장, 사용, 폐기 등 키 생명주기 전반에 걸쳐 관리정책 및 절차를 문서화하고, 주기적으로 검토하여 최신화해야 한다.	●	●	
		N2SF-EK-M3	키 접근 권한 및 감사 관리	암호 키에 대한 접근 권한은 최소 권한 원칙에 따라 관리하며, 키 접근 및 사용에 관한 모든 이벤트는 감사 로그로 기록하고 정기적으로 검토해야 한다.	●	●	
	암호 모듈 사용 (EA)	N2SF-EA-1	검증필 암호모듈 사용	국가정보원장이 안전성을 확인한 상용 암호모듈(검증필 암호모듈)을 사용한다.	●	●	●
		N2SF-EA-2	국가용 암호자재 및 장비 사용	국가정보원장이 개발하거나 안전성을 확인한 암호자재 또는 암호장비 등을 사용한다.	●		
		N2SF-EA-3	특수목적용 외국산 암호자재 및 장비 사용	외국기관 또는 외국군 등 특수목적 통신을 위해 외국산 암호자재 및 장비를 사용한다.	●	●	
	데이터전송 Data Transmission (DT)	N2SF-DT-1	전송 권한 확인	데이터가 전송되기 전에 이를 처리하는 개인이나 정보시스템이 적절한 권한을 보유하고 있는지 확인한다.	●	●	
		N2SF-DT-2	정보교환 중단	정보교환 대상 정보시스템 등에 대한 식별 및 통제가 확인되지 않을 경우 정보교환을 중단한다.	●	●	
		N2SF-DT-3	전송간 암호화 적용	물리적 보안수단에 의해 전송 간 보호되지 않는 경우 전송 구간에 대한 암호기술을 적용한다.	●	●	
		N2SF-DT-4	메시지 외부 암호화 보호	메시지 외부정보를 보호하기 위한 암호기술을 적용한다.	●	●	
		N2SF-DT-5	통신 패턴 은폐 또는 무작위화	통신패턴을 숨기거나 무작위화하는 암호기술을 적용한다.	●		
		N2SF-DT-6	데이터 전송 간 위변조 검증	전송 중 데이터에 대한 위변조 여부를 탐지하기 위해 무결성 검증(해시, 디지털 서명 등)을 수행하며, 이상 징후 발생 시 즉시 경고 및 대응할 수 있는 절차를 수립하여 운영한다.	●	●	
	데이터사용 Data Usage (DU)	N2SF-DU-1	오프라인 저장	중요 정보를 안전한 장소에 오프라인으로 보관하여 네트워크를 통한 무단 접근을 방지한다.	●		
		N2SF-DU-2	데이터 암호화 저장	데이터 대상 암호기술을 적용하여 기밀성을 보장한다.	●	●	●
		N2SF-DU-3	사용중 데이터 보호	검색, 연산, 분석 등 데이터 사용 과정에서 정보시스템 내 데이터를 보호하는 기술을 적용한다.	●		

대항목	중항목	N2SF ID	소항목	보안통제설명	N2SF 우선 검토사항		
					 기밀	 민감	 공개
데이터	데이터사용 Data Usage (DU)	N2SF-DU-4	데이터 갱신 및 삭제	필요 시 데이터를 갱신하거나 생성하여 사용하고, 필요 목적이 종료되면 데이터는 삭제한다.	●	●	
		N2SF-DU-M1	데이터 접근 제어	데이터 접근은 사용자 역할과 권한에 따라 최소한으로 제한하고, 접근 권한은 주기적으로 검토·승인해야 한다.	●	●	
		N2SF-DU-M2	데이터 사용 모니터링	주요 데이터에 대한 사용 이력을 감사 로그로 기록하여 모니터링하고, 이상 징후 발생 시 즉각 보고 및 대응한다.	●	●	
		N2SF-DU-M3	데이터 사용 정책 수립	데이터의 사용 목적, 접근 권한, 보존 기간, 폐기 절차 등을 포함하는 데이터 사용 정책을 문서화하고 전사적으로 적용 및 관리한다.	●	●	
		N2SF-DU-M4	데이터 저장 무결성	저장된 데이터에 대한 위변조 여부를 탐지하기 위해 무결성 검증(해시, 디지털 서명 등)을 수행하며, 이상 징후 발생 시 즉시 경고 및 대응할 수 있는 절차를 수립하여 운영한다.	●	●	
정보 자산	모바일단말 Mobile Device (MD)	N2SF-MD-1	모바일 코드 다운로드 및 실행 금지	허용되지 않은 모바일 코드 다운로드 및 실행을 금지한다.	●	●	●
		N2SF-MD-2	자동 실행 금지	응용프로그램에서 모바일 코드의 자동 실행을 방지한다.	●	●	
		N2SF-MD-3	제한된 환경에서의 실행	모바일 코드를 제한된 환경(가상머신 등)에서만 실행하도록 제한한다.	●	●	
		N2SF-MD-4	민감정보 소통 제한	민감정보를 처리·저장·전송하는 경우 보안요건에 따른 기술적 조치가 적용되지 않은 일반적인 모바일 장비 사용을 제한한다.	●	●	
		N2SF-MD-5	모바일 장치 암호화 기술	모바일 장비 저장공간 암호화 또는 컨테이너 기반 저장공간 분리 및 암호화를 적용한다.	●	●	
		N2SF-MD-6	데이터 자동삭제 또는 초기화	특정 상황 또는 조건에 따라 단말 내부에 저장된 데이터를 자동 삭제하거나 초기화한다.	●	●	
		N2SF-MD-7	탈옥·루팅 탐지 및 차단	루팅 또는 탈옥된 모바일 기기의 접근을 탐지하고 차단한다.	●	●	●
		N2SF-MD-8	블루투스·USB 제어 설정	블루투스, USB 등 외부 입출력 통신 기능을 제어하고 정책에 따라 허용한다.	●	●	
		N2SF-MD-9	비인가 앱 탐지 및 차단	관리자가 승인하지 않은 앱이 설치되거나 실행되면 알림 및 차단한다.	●	●	
		N2SF-MD-10	위치 기반 보안 정책	단말의 물리적 위치(GPS)에 따라 특정 앱 실행 또는 네트워크 접근을 제한한다.	●	●	

대항목	중항목	N2SF ID	소항목	보안통제설명	N2SF 우선 검토사항		
					 기밀	 민감	 공개
정보 자산	모바일단말 Mobile Device (MD)	N2SF-MD-11	네트워크 접근 제어	단말이 안전하지 않은 네트워크(예: 공용 Wi-Fi)에 연결될 경우 경고 또는 차단한다.	●		
		N2SF-MD-M1	장비 식별 및 사용자 연동 관리	모바일 장치 고유 ID 와 사용자 계정을 연동하여 통합 식별 및 통제를 수행한다.	●	●	
		N2SF-MD-M2	정책 위반 자동 조치	정책 위반 시 자동으로 앱 차단, 로그아웃, 초기화 등 사전 정의된 조치를 수행한다.	●		
	하드웨어 Device (DV)	N2SF-DV-1	하드웨어 무결성 검증	하드웨어 구성 요소의 무결성을 검증한다.	●	●	
		N2SF-DV-2	하드웨어 기반 펌웨어 보호 (Hardware-Based Protection)	펌웨어 구성요소 대상 하드웨어 기반 쓰기방지 기능을 활용한다.	●		
		N2SF-DV-3	하드웨어 장치(device) 사용 제한	정보자산 배포 또는 설치 전 특정 하드웨어 장치(USB 포트, 무선통신 모듈 등)를 비활성화 또는 제거 등으로 사용을 제한한다.	●	●	
		N2SF-DV-4	포트 및 입출력 장치 제어	정보시스템의 포트나 입출력 장치를 제어하여 악성코드 유입 및 정보 유출을 차단한다.	●	●	
		N2SF-DV-5	외부 정보자산 활용 정보처리 제한	외부 정보자산 등을 통한 정보의 처리, 저장 및 전송 등을 제한한다.	●		
		N2SF-DV-6	통신 기능이 포함된 저장장치 제한	통신기능이 포함된 저장장치를 사용을 제한한다.	●		
		N2SF-DV-7	기관 접속용 장치 제한	외부 정보자산(시스템 등)에서 기관 네트워크 접속이 가능한 장치 사용을 제한한다.	●		
		N2SF-DV-8	장치 자동 잠금	사용자가 일정시간 이상 정보시스템을 사용하지 않거나 방치할 경우 잠금 기능을 활성화하고, 화면에 표시되는 정보는 표출되지 않아야 한다.	●	●	●
		N2SF-DV-9	읽기전용 매체 활용 프로그램 실행	하드웨어 기반의 읽기 전용 매체에서 운영체제(OS) 로드 및 응용프로그램을 실행하여 실행환경의 무결성을 확보한다.	●		
		N2SF-DV-10	저장장치 연결 금지	정보시스템 기동 및 종료 또는 재시작하는 동안 쓰기 가능한 저장장치 연결을 금지한다.	●		
		N2SF-DV-11	읽기전용 매체 무결성 검증	읽기 전용 매체에 정보를 저장하기 이전 무결성을 검증한다.	●		
		N2SF-DV-12	장치 펌웨어 업데이트 검증	펌웨어 업데이트 시 서명 검증 또는 위변조 여부를 검증하여 설치를 제한한다.	●		

대항목	중항목	N2SF ID	소항목	보안통제설명	N2SF 우선 검토사항		
					 기밀	 민감	 공개
정보 자산	하드웨어 Device (DV)	N2SF-DV-M1	하드웨어 장치 식별 및 인벤토리	장치별 고유 ID(MAC, Serial Number 등)를 기반으로 자산 목록을 구성하고 지속적으로 관리한다.	●	●	
		N2SF-DV-M2	반입 장치 검사 절차	외부 장치 반입 시 보안 검사 및 승인 절차를 운영한다.	●	●	
	정보시스템 구성요소 Information System Component (IN)	N2SF-IN-1	구성요소 목록 중앙관리	정보시스템 구성요소 목록을 통합관리하기 위한 중앙화된 저장소를 운용한다.	●	●	
		N2SF-IN-1(1)	정보시스템 구성요소 최신상태 유지	정보시스템 내의 모든 구성요소가 포함되도록 정보시스템 구성 요소 목록을 작성하고 정기적으로 검토 및 최신 상태로 업데이트 한다.	●	●	
		N2SF-IN-1(2)	구성요소 목록 현행화	정보시스템 구성 요소 설치, 제거, 또는 정보시스템 업데이트 시 목록을 갱신한다.	●	●	
		N2SF-IN-1(3)	구성요소 목록 자동관리	자동화된 메커니즘을 통해 정보시스템 구성요소 목록의 최신성, 완전성, 정확성, 가용성을 유지한다.	●		
		N2SF-IN-2	비인가 구성요소 식별	정보시스템 내 비인가 하드웨어, 소프트웨어 및 펌웨어 구성 요소를 검사하여 식별한다.	●	●	
		N2SF-IN-3	물리적 위치 식별	자동화된 메커니즘을 통해 정보시스템 구성요소의 물리적 위치를 식별한다.	●		
		N2SF-IN-4	변경 사항 테스트 및 검증	변경 사항을 최종 적용하기 전에 테스트 및 검증을 통해 안전성을 확보한다.	●	●	
		N2SF-IN-5	비인가 변경 방지	인가되지 않은 정보시스템 구성요소 변경을 방지한다.	●	●	
		N2SF-IN-6	불필요한 구성요소 제거	필요 기능만 제공하도록 구성하고, 사용하지 않는 기능, 포트, 프로토콜, 소프트웨어, 서비스의 사용을 제거하거나 비활성화한다.	●	●	
		N2SF-IN-7	주기적인 구성요소 제거 상태 점검	주기적으로 사용하지 않은 기능, 포트, 프로토콜, 소프트웨어 및 서비스의 활성화 여부를 점검한다.	●	●	
		N2SF-IN-8	비인가 소프트웨어 실행 차단	허가되지 않은 소프트웨어(응용프로그램)가 실행되지 않도록 차단한다.	●	●	
		N2SF-IN-9	소프트웨어 기술지원 유지	개발자, 공급업체 또는 제조업체에서 기술지원이 종료된 구성요소는 교체하거나 지속적 기술지원이 가능하도록 조치한다.	●	●	●
		N2SF-IN-10	소프트웨어 설치 권한 제한	소프트웨어 설치 권한은 필요한 사용자에게만 부여한다.	●	●	

대항목	중항목	N2SF ID	소항목	보안통제설명	N2SF 우선 검토사항		
					 기밀	 민감	 공개
정보 자산	정보시스템 구성요소 Information System Component (IN)	N2SF-IN-11	재기동 서비스 신뢰성 확보	정보시스템 구성요소와 서비스가 재기동(재부팅) 할 때 소프트웨어와 데이터는 신뢰된 곳으로부터 획득한다.	●	●	●
		N2SF-IN-12	신뢰성이 보장된 구성요소 설치	신뢰할 수 있는 외부 기관·제조사 또는 기관이 자체 서명한 구성요소를 설치 및 활용한다.	●	●	●
		N2SF-IN-13	정보의 비지속성	정보시스템이 종료되거나 재부팅될 때 관련 정보(데이터 등)는 자동 삭제하여 유지되지 않도록 한다.	●	●	
		N2SF-IN-14	연결의 비지속성	일시적으로 사용된 연결은 사용이 종료되면 자동으로 연결을 끊어 연결이 유지되지 않도록 한다.	●	●	
		N2SF-IN-15	구성요소 해시/서명 무결성 검증	설치된 구성요소의 해시 또는 디지털 서명을 검증한다.	●	●	
		N2SF-IN-16	악성코드 감염 차단	악성코드 유입 및 실행 등으로 인한 악성코드 감염을 실시간 탐지하고 차단한다.	●	●	●

제1장

권한

1. 최소 권한 (Least Privilege, LP)

정의

최소 권한은 사용자나 프로세스가 특정 업무를 수행하는 데 필요한 최소한의 권한만을 부여하는 보안 원칙으로, 내부 및 외부 위협으로부터 시스템을 보호하고, 내부 정보로의 불필요한 접근을 방지하기 위한 통제항목이다.

보안통제 항목

N2SF ID		보안통제 항목 설명
N2SF-LP-1	C S	정보시스템 접근 권한 정의
		업무정보(데이터)를 식별하고, 업무정보를 저장하고 있는 정보시스템 접근 권한을 정의한다.
N2SF-LP-2	C S O	보안통제 권한 제한
		보안통제 권한은 정보보안담당관(자) 또는 이에 준하는 관리권한을 부여받은 인원에게만 부여한다.
N2SF-LP-3	C S O	보안통제 계정 노출 방지
		보안통제 목적으로 사용되는 계정이 다른 기능에 사용되지 않도록 하고, 불필요한 사용을 제한하여 계정의 노출을 방지한다.
N2SF-LP-4	C S O	관리자 권한 제한
		정보시스템 접근에 필요한 최소한의 관리자 및 운영자 등에게만 관리자 권한을 부여한다.
N2SF-LP-4(1)	- S O	원격접속을 통한 관리자 권한 접속제한
		기관 네트워크 내부에서 관리자 권한 접속이 제한되는 경우 등 불가피한 상황에서만 한시적으로 기관 네트워크 외부에서의 관리자 권한 접속을 허용하며, 목적이 달성된 경우 외부에서의 관리자 권한 접속을 즉시 차단한다.
N2SF-LP-4(2)	C S O	기관 이외 인원의 관리자 권한 제한
		기관 구성원 이외 인원에게 관리자 권한은 부여하지 않으며, 다만 정보보안 감사, 사이버보안 실태평가, 사고 조사 및 진단·점검 등에 필요한 경우 외부 인원에게 관리자 권한을 한시적으로 부여할 수 있다.

N2SF ID		보안통제 항목 설명	
N2SF-LP-4(3)	-	사용자에게 부여된 관리자 권한 관리	
		사용자에게 부여된 관리자 권한을 주기적으로 검토하고, 필요 없는 권한은 즉시 회수한다.	
N2SF-LP-4(4)	C S O	관리자 권한 실행 로깅 및 감사	
		관리자 권한 기능 실행 내역은 로깅하고 주기적인 사용 내역 감사를 실시한다.	
N2SF-LP-5	C S O	코드 실행권한 제한	
		코드는 필요한 권한으로만 실행되도록 제한하고, 사용자 권한으로 실행되는 코드가 관리자 영역으로 접근되지 않도록 차단한다.	
N2SF-LP-M1	C S	특별권한 사용자 지정	
		일반 사용 권한과 별도로 특별권한 사용자 그룹을 지정하고, 이들의 권한 부여와 변경을 통제한다.	
N2SF-LP-M2	C S	주요 사용자 위험 관리	
		주요 사용자의 권한과 활동을 모니터링하고 이상 징후를 탐지하여 위험을 사전에 관리한다.	
N2SF-LP-M3	C S O	접근권한 사전 설정	
		기본적으로 필요 최소한의 권한만을 부여하는 사전 권한 설정 기준을 마련하고 운영한다.	
N2SF-LP-M4	C S O	접근권한과 정보 연계	
		접근권한 부여 시 정보 접근 범위를 명확히 연계하여 통제하며, 불필요한 정보 접근을 차단한다.	

■ 구현 방법 예시

• 역할 기반 접근 통제(RBAC) 적용

- 사용자, 부서, 직책, 업무 유형별로 역할(Role)을 구분하고, 역할별 최소 권한 세트를 정의한다.
- 역할에 따라 시스템 접근 권한을 사전 설정하고, 새로운 사용자 생성 시 자동으로 역할 기반 권한을 부여한다.
- 역할(Role)과 권한(Permission)의 부여·변경·말소 등 설정 이력은 모두 감사(Audit) 로그에 기록하여 추적할 수 있도록 한다.

• 속성 기반 접근 통제 확대 적용(ABAC)

- 사용자 속성(직급, 근무 위치, 고용 형태 등), 리소스 속성(기밀성, 소유자 등), 환경 속성(시간, 장치, 네트워크 위치 등)을 기반으로 접근 여부를 결정하도록 정책 기반 접근 제어를 구성한다.
- PDP(Policy Decision Point)와 PEP(Policy Enforcement Point) 구조를 통해 실시간으로 조건을 평가하고 정책을 강제하도록 한다.

• 권한 자동 관리 체계 도입

- 중앙 관리형 권한 관리 시스템(IAM, Identity and Access Management)을 구축하여, 조직 내 권한 부여·변경·회수 절차를 자동화한다.
- 사용자 변경 이벤트(입사, 퇴사, 조직 변경 등)에 따라 계정 생성, 권한 부여, 비활성화, 삭제가 자동으로 연동되도록 구성한다.
- 승인(Workflow) 기반으로 권한 요청 및 부여가 이루어지며, 최소 2단계 이상의 승인(요청자-검토자-승인자)을 요구한다.

• 시스템 프로세스 권한 세분화

- 시스템 내 실행 프로세스별로 필요한 리소스 접근 권한을 세분화하여 정의한다.
- 운영체제 레벨에서 프로세스별 접근 통제(예: Linux AppArmor, SELinux, Windows Defender Application Control)를 적용하여, 허용된 프로세스만 시스템 자원 접근을 허용한다.
- 불필요한 프로세스 권한은 제거하고, 승인된 프로세스 외의 실행은 차단한다.

• 정기적인 권한 검토 및 감사

- 권한 검토 주기를 명시(예: 3개월, 6개월)하고, 주기별로 모든 사용자 및 관리자 계정의 권한 현황을 점검한다.
- 실제 사용 이력과 권한을 비교하여 불필요하거나 미사용 권한은 회수한다.
- 권한 변경 이력과 이상 행위 감지 결과를 기반으로 추가 감사(Audit Trail)를 수행한다.

• 권한 분리(SOD, Segregation of Duties) 강화

- 업무상 상호 충돌할 수 있는 역할(예: 요청-승인, 개발-운영 등)을 동일 사용자에게 부여하지 않도록 정책화한다.
- 특히, 시스템 운영자, 보안 관리자, 개발자 간 역할과 권한을 명확히 구분하고, 겸직을 금지한다.
- 권한 격리를 위해 다중 계정 사용(업무별 별도 계정) 또는 특별권한 사용자 계정 분리 솔루션(PAM) 도입을 검토한다.

• 특별권한 사용자 계정 및 관리자 권한 관리

- 특별권한 사용자 계정(관리자, root, DBA 등)은 별도로 식별하여 엄격한 접근 통제 정책을 적용한다.
- 특별권한 사용자 계정 접속 시 다중 인증(MFA, Multi-Factor Authentication)을 필수 적용한다.
- 특별권한 사용자 계정은 사전 승인제(Privileged Access Request)와 세션 기록(Session Recording)을 병행하여 통제한다.

• 계정 및 권한 이상 행위 탐지

- 비정상 시간대 접속, 평소와 다른 시스템 접근, 권한 변경 요청 등의 이상 행위를 실시간 모니터링하고 탐지한다.
- 사용자 행동 분석(UEBA, User and Entity Behavior Analytics) 기반 솔루션을 활용하여 이상 권한 활동을 탐지하고 알람을 발생시킨다.

• 최소권한 적용 자동화 도구 사용

- 계정 라이프사이클 관리(LCM: Life Cycle Management) 도구를 이용하여 계정 생성, 권한 부여, 변경, 비활성화, 삭제를 자동화한다.
- 기존 계정과 신규 계정 모두에 대해 최소 권한 적용 규칙을 적용하고, 규칙 위반 시 자동으로 통보 하거나 권한 수정 조치를 시행한다.
- 사용자의 역할에 따라 각기 다른 권한을 부여하고, 최소한의 권한만 설정하여 불필요한 권한 남용을 방지한다.

항목	적용 기술 또는 방식
역할 기반 접근통제(RBAC)	RBAC, 역할-권한 연계, 권한 정의 템플릿, 감사 로그 기록
속성 기반 접근통제(ABAC)	ABAC, 정책 기반 접근 제어, 환경 기반 조건 평가 (위치, 시간 등)
권한 자동 관리 체계	IAM, 권한 요청·승인 워크플로우, 입사/퇴사 연계 권한 자동화
시스템 프로세스 권한 분리	AppArmor, SELinux, 프로세스별 권한 제한, 실행 경로 제어
정기 권한 검토 및 감사	권한 검토 주기 설정, 미사용 권한 회수, 권한-사용 내역 비교, Audit Trail
업무분리(SOD) 정책 강화	역할 충돌 매트릭스, 다중 계정 운영, 업무별 계정 분리, PAM
특별권한 사용자 계정 관리	MFA 적용, 특별권한 사용자 계정 식별·분리
계정 이상 행위 탐지	UEBA, 이상 권한 요청 탐지, 비정상 접속 감지, 실시간 알람 및 정책 위반 탐지
최소 권한 자동화 도구	LCM 도구 도입, 권한 할당 자동화, 최소 권한 프로파일 적용
계정 라이프사이클 관리	계정 생성/변경/비활성화 자동화, AD/LDAP 통합, 권한 연동 정책

2. 신원 검증 (Identity Verification, IV)

정의

신원 증명은 시스템 접근을 위한 자격 증명을 설정할 목적으로 대상 사용자의 신원 정보를 수집, 검증 및 확인하기 위한 통제항목이다.

보안통제 항목

N2SF ID		보안통제 항목 설명	
N2SF-IV-1	C S	관리자 승인	
		정보시스템 사용자 계정(대민서비스 등 서비스 이용자 계정 제외) 부여를 위한 계정 등록 절차에 정보시스템 관리자(정보화담당관 또는 이에 준하는 관리자)의 승인을 포함한다.	
N2SF-IV-2	C S	신원 증거 제출	
		개인은 신원을 증명할 수 있는 증거를 등록 기관에 제출한다.	
N2SF-IV-2(1)	C S	신원 증거 검증	
		제출된 신원 증거를 검증한다.	
N2SF-IV-3	C S O	외부 신원 검증 수용	
		동등한 수준의 보증을 제공하는 외부 기관 또는 업체의 신원 검증 결과를 수용할 수 있다.	
N2SF-IV-M1	C	대면 신원 증거 검증	
		대면을 통한 신원 증거를 검증한다.	

구현 방법 예시

• 신원 확인 절차 도입

- 계정 등록 시 사용자의 신원을 고유하게 식별할 수 있는 절차를 도입한다. 예를 들어, 정부 발급 신분증, 인증서, 생체 인식 등을 검증한다.

• 다단계 신원 검증(Multi-Factor Identity Proofing) 적용

- 중요 시스템 및 민감 정보에 접근하는 사용자에게 대해서는 단일 신원 검증이 아니라, 2단계 이상 신원 검증 절차를 요구한다.
- 위험 기반 접근 제어(Risk-based Access Control)를 연계하여, 접속 환경(시간, 장소, 장치 등) 변화 시 추가 신원 검증을 요구한다.

• 신원 증거 수집 및 보호

- 사용자가 제출하는 신원 증거(정부 발급 신분증, 인증서, 바이오 매트릭스 등)는 안전한 경로(SSL/TLS 암호화 채널)로 수집한다.
- 수집된 신원 증거는 법적 요건을 충족하도록 암호화 저장하고, 접근 통제를 적용한다.
- 신원 증거는 정해진 보존 기간 이후 안전하게 폐기하거나 삭제 절차를 거친다.

• 외부 신원 검증 결과 수용 절차

- 신뢰할 수 있는 제3자(정부, 금융기관, 공인 인증기관 등)로부터 신원 검증 결과를 받아들이는 경우, 기관 간 연동 프로토콜을 안전하게 구축한다.
- 외부 검증 결과 수신 시 데이터 위·변조를 방지하기 위해 전자서명 및 무결성 검증 절차를 추가한다.

• 자동화된 신원 검증 시스템 구축

- 신원 증거 제출 및 검증 과정을 자동화하여 신원 확인 속도를 향상시키고, 사용자 오류 및 담당자 수작업 오류를 최소화한다.
- OCR(Optical Character Recognition) 및 AI 기반 신원 증거 자동 판독 솔루션을 도입하여 신분증, 문서 등을 신속히 검증한다.
- 자동 검증 실패 시 관리자 수동 검토 프로세스를 병행하여 정확성을 확보한다.

• 대면 신원 검증 절차 마련

- 중요도 높은 계정이나 특별권한 사용자 계정 신청 시 대면 검증 절차를 필수화한다.
- 대면 검증은 영상통화 기반 실시간 확인 또는 방문 검증을 통해 수행하며, 확인 결과를 신원 검증 이력에 기록한다.
- 대면 검증 담당자는 사전 지정된 교육 이수자만 수행할 수 있도록 한다.

• 신원 검증 실패 관리

- 신원 검증 실패 시, 즉시 시스템 접근을 차단하고 추가 신원 증명을 요구하는 재검증 절차를 마련한다.
- 다수의 신원 검증 실패가 발생할 경우 자동으로 계정을 잠그고 보안팀에 알림이 전송되도록 구성한다.

• 법적 요구사항 반영

- 국내외 개인정보보호법 및 인증기준에 부합하는 신원 검증 절차를 적용한다.
- 지역 및 서비스 특성에 따라 연령확인, 실명확인 등의 추가 신원 검증 요건을 설정한다.

항목	적용 기술 또는 방식
신원 확인 절차 도입	정부 발급 신분증 검증, 전자 인증서 확인, 생체 인식 등록
다단계 신원 검증 적용	2단계 신원 확인, 접속 환경 변화 감지 시 추가 검증
외부 신원 검증 수용	공공·금융기관 등 연동, 전자서명 검증
자동화된 신원 검증 시스템	OCR, AI 기반 자동 판독, 신분증 문서 자동 검증
대면 신원 확인 절차	영상통화 검증, 방문 검증, 검증자 자격 등록 및 기록 관리
신원 검증 실패 대응	검증 실패 시 계정 잠금, 보안팀 알림, 재검증 요청 절차 적용
법적 요건 및 서비스 특성 대응	개인정보보호법, 인증기준 반영, 연령확인, 실명확인 등 요건 설정

3. 식별자 관리 (Identifier Management, IM)

정의

식별자 관리는 기관의 IT 자산 및 인적 자원을 식별할 수 있는 고유한 식별자를 생성, 관리하여 접근 통제를 강화하고 인증 프로세스를 지원하기 위한 통제항목이다.

보안통제 항목

N2SF ID	보안통제 항목 설명	
N2SF-IM-1	C	공개된 식별자의 계정 사용 금지
		정보시스템 계정 식별자로 개인의 공개된 식별자 사용을 금지한다.
N2SF-IM-2	C S	사용자 상태 식별
		개인과 조직의 구별, 사용자 상태(활성, 비활성, 임시계정 등)를 식별하고 관리한다.
N2SF-IM-3	C S	기관 간 상호 관리
		기관 간 식별자 관리를 위해 인증정보 관리기관, 외부 연동 정보시스템 관리기관 등과 주기적으로 관련 정보를 공유한다.
N2SF-IM-4	C	상호(쌍, Pairwise) 가명 식별자
		사용자의 익명성 보장이 필요한 경우 사용자 간 식별을 위해 식별 정보가 없는 상호(쌍, Pairwise) 가명 식별자를 제공한다.
N2SF-IM-5	C	속성 유지관리 및 보호
		안전하게 보호조치가 된 저장소에서 고유하게 식별된 각 개인, 그룹, 장치 또는 서비스에 대한 속성을 유지하고 보호한다.

■ 구현 방법 예시

• 고유한 식별자 생성 규칙 설정

- 사용자, 장치, 그룹, 서비스 등 각각의 엔티티(Entity)에 대해 고유한 식별자가 생성되도록 규칙을 정의한다.
- 식별자는 중복되지 않도록 시스템 내에서 자동 검증을 수행한다.
- 식별자 포맷을 표준화하여 관리한다.

• 식별자 재사용 방지 및 제한

- 탈퇴한 사용자 또는 사용 중지된 장치에 대한 식별자는 즉시 비활성화하고 일정 기간 동안 재사용을 금지한다.
- 시스템 내 재사용 방지를 위해 비활성화 식별자 목록을 별도 관리하고, 신규 생성 시 참조하여 재발급을 방지한다.

• 식별자 변경 및 로그 기록

- 식별자 생성, 수정, 삭제 이력을 모두 감사 로그에 기록한다.
- 감사 로그는 별도 보안 저장소에 보관하고, 변경 내역에 대한 정기적 검토(분기별 등)를 수행한다.

• 식별자 주기적 검토 및 비활성화

- 사용자, 장치, 서비스가 시스템에서 더 이상 사용되지 않을 경우, 관련 식별자를 주기적으로 검토하고 비활성화한다.
- 일정 기간 이상 로그인, 접속, 호출 이력이 없는 식별자는 비활성화 대상 목록에 자동 추가한다.

• 식별자 통합 관리

- 모든 시스템, 응용 프로그램, 서비스에 걸쳐 식별자가 일관되게 관리되도록 통합 디렉터리 서비스를 활용한다.
- 식별자에 대한 메타정보(생성일자, 생성자, 사용 이력, 그룹 소속 등)는 별도 속성 DB에 보관하며, IAM 또는 MDM 솔루션을 통해 조회 및 변경 내역을 관리한다.

• 상호(Pairwise) 가명 식별자 적용

- 외부 시스템 또는 제3자 연동 시 개인정보 노출을 방지하기 위해 사용자에게 대해 상호(Pairwise) 식별자를 사용한다.
- 상호(Pairwise) 식별자는 요청 시스템별로 고유하게 생성되어 재식별 위험을 최소화한다.

- 개인정보 유출을 방지하기 위해 애플리케이션 간 공유 ID는 난수 기반의 Pairwise Pseudonymous Identifier로 대체하여 각 시스템마다 다른 ID를 노출하도록 구성한다.

• 속성 관리 및 보호

- 식별자에 부여된 부가 속성(예: 직위, 부서, 역할, 권한 정보 등)은 암호화하여 저장하고, 권한을 가진 사용자만 조회 가능하도록 제한한다.
- 속성 변경 이력도 감사 로그에 기록하고, 속성의 정확성 유지를 위해 정기적으로 갱신한다.

항목	적용 기술 또는 방식
고유 식별자 생성 규칙 설정	중복 방지 자동 검증, 표준 포맷 지정, 엔티티별 ID 규칙 정의
식별자 재사용 방지	비활성화 목록 관리, 일정 기간 재사용 금지, 신규 발급 시 참조 검증
식별자 변경 이력 기록	생성/수정/삭제 시 로그 기록, 보안 저장소 보관, 정기 감사
식별자 주기적 검토 및 비활성화	로그인·접속 이력 기반 자동 비활성화 등록, 미사용 엔티티 주기 검토
통합 식별자 관리	통합 디렉터리 서비스, IAM/MDM 기반 메타정보 속성 DB 연계
Pairwise 가명 식별자	난수 기반 고유 식별자, 시스템별 다른 ID 생성, 재식별 방지
속성 정보 보호 및 갱신	속성 암호화 저장, 접근권한 제한, 변경 이력 기록 및 정기 갱신

4. 계정 관리 (Account Management, AC)

정의

계정 관리는 시스템 내에서 사용자와 관련된 계정을 생성, 관리, 모니터링, 비활성화 및 삭제 기능을 수행하여 불필요한 계정 사용을 방지하고, 비 인가된 사용자 접근을 통제하여 보안성을 유지하기 위한 통제항목이다.

보안통제 항목

N2SF ID	보안통제 항목 설명	
N2SF-AC-1	C S	계정 관리 자동화
	정보시스템 계정 관리를 효율화하고, 인적 오류를 최소화하기 위해 자동화된 메커니즘을 사용하여 계정 관리를 수행한다.	
N2SF-AC-1(1)	C S	동적 계정 관리
	사용자 상태(입사, 퇴사, 부서 이동 등)에 따라 계정 정보를 실시간으로 반영하고, 시스템 간 계정 동기화를 통해 계정 수명주기 관리를 자동화한다.	

N2SF ID		보안통제 항목 설명	
N2SF-AC-1(2)	C S	계정 상태 모니터링	계정의 임시 생성, 수정, 활성화, 비활성화 및 삭제 등을 모니터링한다.
N2SF-AC-1(3)	C	계정 자동 비활성화	계정 사용 기간이 종료되거나 일정 기간 미사용된 계정은 자동으로 비활성화한다.
N2SF-AC-1(4)	C S O	계정 자동 로그아웃	비활동 시간이 일정 기간 지속되었을 때 정보시스템에서 자동 로그아웃 되어야 한다.
N2SF-AC-1(5)	C S O	불필요한 관리자 권한 계정 제거	관리자 권한이 필요 없거나 활용이 종료된 계정은 비활성화 또는 삭제 조치한다.
N2SF-AC-2	C	공유 및 그룹 계정 사용 제한	공유 및 그룹 계정 사용은 필요한 경우로 제한하며, 가능하면 개인별 계정 사용을 권장한다.
N2SF-AC-3	C S	의심스러운 계정 모니터링	비정상적이거나 의심스러운 계정 접속 시도 및 활동을 지속적으로 모니터링한다.
N2SF-AC-3(1)	C S O	위험에 노출된 계정 비활성화	정보시스템 위협 탐지 시, 위험에 노출된 계정은 신속히 비활성화하거나 제한 조치를 한다.
N2SF-AC-3(2)	C S	내부 사용자 모니터링	내부 사용자의 계정 사용 및 활동을 지속적으로 모니터링한다.
N2SF-AC-3(3)	C S	외부 사용자 모니터링	외부 사용자의 계정 사용 및 접속 활동을 지속적으로 모니터링한다.
N2SF-AC-M1	C	감사 활동 자동화	계정 사용 및 관련된 감사 활동을 자동화하여 관리한다
N2SF-AC-M2	C S O	감사 기록 생성	계정 활동에 대한 감사 기록을 생성하여 보관하고 분석할 수 있도록 한다.
N2SF-AC-M3	C S	세션 감사	세션 활동을 기록하고 주기적으로 감사하여 비정상적 행위를 탐지한다.

구현 방법 예시

• 계정 생성 및 변경 승인 프로세스 도입

- 계정 생성, 권한 변경, 복구 요청 등은 사전에 정의된 승인 절차를 반드시 거치도록 한다.
- 승인자는 조직 내 역할별로 구분하고(예: 팀장, 시스템 관리자), 승인은 워크플로우 시스템을 통해 기록 및 추적한다.
- 승인 없이 생성된 계정은 시스템적으로 탐지하여 관리자에게 즉시 통보된다.

• 계정 관리 자동화

- 계정 생성, 수정, 비활성화, 삭제를 자동화하기 위해 ID 관리(IAM) 시스템을 구축한다.
- 인사정보 시스템(HR 시스템)과 연계하여 입사, 퇴사, 이동 시 자동으로 계정 라이프사이클을 관리한다.
- 계정별 역할-권한 연계(Role-Permission Mapping) 기준을 사전에 정의하여 신규 사용자 생성 시 자동으로 권한이 부여되도록 구성한다.
- 자동화된 작업에도 예외 및 오류 발생 시 감사 로깅을 수행하고, 관리자 확인 프로세스를 마련한다.

• 동적 계정 관리

- 사용자의 입사, 부서 변경, 직책 변경, 휴직, 퇴직 등의 상태 변화에 따라 계정 속성(소속, 역할, 권한 등)을 실시간으로 반영한다.
- 이벤트 기반(Event-driven)으로 상태 변화가 감지되면 즉시 계정 정보 업데이트를 수행한다.
- 동적 관리 실패 시 시스템 경고를 발생시키고, 수동 검토 절차를 트리거한다.

• 계정 상태 모니터링 및 이상 행위 탐지

- AD(Active Directory), LDAP 등 디렉터리 서비스를 기반으로 계정의 생성, 활성, 비활성, 삭제 이력을 주기적으로 점검한다.
- 비정상 시간대 접속, 예상 외 시스템 접근, 권한 초과 사용 등 이상 징후를 실시간 탐지한다.
- UEBA(User and Entity Behavior Analytics) 기반 솔루션을 통해 비정상적인 사용자 패턴을 탐지하고 알람을 제공한다.
- 이상 행위 탐지 시 자동 알람 및 대응 프로세스(잠금, 추가 인증 요청 등)를 실행한다.
- 위험 기반 인증(Risk-Based Authentication)을 통해 야간 시간대, 해외 IP, 평소와 다른 장치에서 접속 시 계정 보호 조치를 강화한다.

• 정기적인 계정 점검 및 비활성화

- 모든 계정에 대해 3개월 또는 6개월마다 사용 여부를 검토하고, 장기간 미사용 계정은 자동 비활성화한다.
- 사용되지 않는 계정은 일정 보존 기간 이후 삭제하거나 별도 비활성화 영역으로 이동시킨다.
- 점검 결과는 감사 기록에 저장하고, 미사용 계정 수를 보고한다.

• 세션 및 로그인 통제

- 일정 시간 이상 비활동 시 세션을 자동 종료하도록 구성한다.
- 세션 활동 이력을 기록하고 주기적으로 검토하여 이상 접근 시도를 탐지한다.

- 동일 계정으로 다중 접속을 제한하고, 세션 수 초과 시 추가 로그인 차단을 적용한다.
- SSH, RDP, 웹 기반 접속 등에 대해 세션 타임아웃(Idle Timeout) 정책을 설정하여 비활성 사용자를 자동 로그아웃시킨다.
- 세션 기록(Session Recording) 기능을 도입하여 관리자 또는 특별권한 사용자 사용자 세션의 명령어, 화면을 저장하고 감사 시 활용한다.
- 세션 기록은 보존 기간, 암호화 저장, 위변조 방지 해시(SHA256 등) 정책을 적용하여 관리한다.

• 공유 및 그룹 계정 사용 제한

- 가능하면 개인 식별 가능한 계정만 사용하도록 하고, 공유 계정 사용은 업무상 필수적일 때만 별도 승인 절차를 통해 허용한다.
- 공유 계정은 사용 이력(로그인/로그아웃 기록) 및 활동 로그를 반드시 기록하고 주기적으로 감사한다.

• 특별권한 사용자 계정 및 관리자 권한 계정 관리

- 특별권한 사용자 계정은 일반 계정과 별도로 식별하여, 사용 시 사전 승인을 받도록 한다.
- 불필요한 관리자 계정 또는 권한은 PAM(Privileged Access Management) 시스템에서 자동 회수되도록 설정한다.
- 관리자 권한은 최소 권한 원칙에 따라 분리하여 부여하고, 필요시마다 임시 권한 상승 방식(Just-In-Time Access)을 활용한다.

• 감사 기록 생성 및 유지

- 모든 계정 활동(생성, 변경, 삭제, 로그인, 세션 활동)에 대해 상세 감사 로그를 생성한다.
- 감사 기록은 변조 방지를 위해 별도 보안 저장소에 저장하며, 규정에 따른 기간동안 보존한다.
- 이상 징후 또는 사고 발생 시 감사 기록을 통해 원인 분석과 대응이 가능하도록 한다.

항목	적용 기술 또는 방식
계정 생성/변경 승인 절차	승인 워크플로우, 관리자 승인 시스템, 무승인 계정 탐지 및 통보
계정 관리 자동화	IAM 연동, HR 시스템 통합, LCM, 자동 권한 할당
동적 계정 속성 반영	이벤트 기반 계정 동기화, 실시간 역할/조직 변경 반영
계정 상태 모니터링 및 이상 탐지	AD/LDAP 로그 분석, UEBA, Risk-Based Authentication, 실시간 경고/잠금 처리
정기 계정 점검 및 비활성화	미사용 계정 탐지, 자동 비활성화 및 삭제, 감사 이력 기록, 점검 주기 정책 설정

항목	적용 기술 또는 방식
세션 및 로그인 통제	Idle Timeout, 세션 로그 기록, 다중 로그인 차단, SSH/RDP 세션 관리
공유/그룹 계정 사용 제한	개인 식별 계정 우선 사용, 공유 계정 승인 절차, 활동 로그 기록 및 주기 감사
특별권한 사용자 계정 및 관리자 계정 관리	특별권한 사용자 계정 사전 승인, PAM 시스템, JIT(Just-In-Time Access), 자동 권한 회수
감사 로그 생성 및 보존	계정 활동 로깅, 보안 저장소 보관, 변조 방지 해시

제2장

인증

1. 다중요소 인증 (Multi-Factor Authentication, MA)

정의

다중요소 인증은 기관 내부 사용자의 정보시스템 등에 접근 시 사용자 인증을 위해 두 개 이상의 인증 요소를 사용하여 보안성을 강화하기 위한 통제항목이다.

보안통제 항목

N2SF ID	보안통제 항목 설명
N2SF-MA-1	C S O 관리자 계정 다중요소 인증(MFA, Multi-factor Authentication)
	관리자 권한 인증 수행 시 다중요소 인증을 적용한다. * 다음의 인증요소 중 2가지 이상을 조합하여 활용 (1) 지식기반 요소 : 사용자가 설정한 정보(비밀번호, PIN, 패턴, 보안질문 등) (2) 소유기반 요소 : 사용자에게 발급한 장치(OTP, 기관 지급 인증장치 등) 또는 계정 사용자가 소유하고 있으며 기관이 승인한 장치 이용(SMS, 모바일 공무원증, 모바일 OTP 등) (3) 생체기반 요소 : 사용자 고유 생체정보(지문, 홍채, 얼굴, 정맥 등)
N2SF-MA-2	C S 사용자 계정 다중요소 인증(MFA, Multi-factor Authentication) 지정되지 않은 접속 경로 또는 사전 승인되지 않은 단말을 통한 사용자 계정에 대해 다중요소 인증을 적용한다.
N2SF-MA-3	C S O 다중요소 인증 장치 분리 다중요소 인증시에는 인증을 요청한 장치와 물리적으로 분리된 별도의 장치(수단 등)를 활용하여 인증을 수행한다.
N2SF-MA-4	C S O 다중요소 인증(MFA, Multi-factor Authentication) 경로 분리 다중요소 인증시에는 인증을 요청한 장치의 통신 경로와 분리된 별도의 통신 경로를 통해 인증을 수행한다.
N2SF-MA-5	C S 특정상황에서의 다중요소 인증 특정 상황 또는 조건에서는 다중요소 인증을 적용하여 사용자를 인증한다.
N2SF-MA-M1	C S O 다중인증요소 설정 및 관리 보안 정책 또는 조건에 따라 다중요소 인증(MFA)의 적용 대상, 방식, 조합 기준을 정의하고 주기적으로 검토 및 관리하며, MFA 설정 변경은 승인 절차를 거쳐 수행된다.

■ 구현 방법 예시

• MFA 시스템 도입 및 연계

- 조직 내 계정 및 권한 관리 시스템과 연계되는 MFA 솔루션을 도입한다.
- 인증 요소 조합은 사용자 유형(일반, 관리자), 접속 위치(내부/외부), 단말 종류(사내/비인가)에 따라 다르게 설정될 수 있도록 한다.
- MFA 인증 로그는 보안 로그 관리 시스템과 연동하여 이상행위를 감지할 수 있도록 한다.

• 인증 요소 조합 설정

- 사용자 인증 시 다음 중 2개 이상 요소 조합을 요구한다:
- 지식 기반 요소: 비밀번호, PIN, 보안 질문 등
- 소유 기반 요소: OTP, 인증 앱, USB 토큰, 모바일 기기, 모바일 공무원증, 기관 지급 인증 장치 등
- 생체 기반 요소: 지문, 얼굴 인식, 홍채, 정맥 등

• 고위험 접근에 대한 MFA 강제 적용

- 외부 네트워크, 원격 접속, 관리자 접근, 민감정보 처리 시스템 접속 시에는 MFA를 무조건 적용하도록 한다.
- 접속 경로, 위치, 시간대, 장치 특성을 기반으로 위험을 판단하는 리스크 기반 MFA를 적용한다.
- 지정되지 않은 IP, 단말, 네트워크 위치에서의 접속은 사전 등록 또는 승인 없이 불가하도록 구성하고, 예외 발생 시 무조건 MFA 인증을 요구하도록 한다.

• 장치 및 인증 경로 분리

- 인증 요청을 처리하는 장치(OTP 생성기, 인증앱)와 본 단말(PC, 모바일)을 물리적으로 분리하거나, 인증 통신 경로를 논리적으로 분리하여 보안성을 강화한다.
- 인증 요청 시, 일반 인증 경로(ID/Password) 외에 추가 인증 경로(모바일 앱, 인증 링크 등)를 병행한다.
- FIDO2 기반 하드웨어 키(보안 토큰), 또는 MFA Proxy 서버를 통해 인증 경로를 분리·중계한다.

• 인증 실패 대응 및 제한

- 지정 횟수 이상 인증 실패 시 계정을 자동 잠금하며, 관리자는 수동 해제를 통해 검증한다.
- 실패 원인을 기록하여 MFA 우회 시도를 탐지한다.
- MFA 인증 실패가 연속되거나, 로그인 실패와 함께 발생하는 경우 자동 계정 잠금, 관리자 경고, CAPTCHA 적용 등으로 방어한다.

• 인증 요소 보안 강화

- OTP 기반 인증은 TOTP(Time-based One Time Password) 또는 HOTP를 사용하며, 암호화된 저장 및 서버-클라이언트 동기화 기능을 갖춘 MFA 서버에서 관리한다.
- 생체 정보 기반 인증은 FIDO U2F/FIDO2 기반 생체 인증 모듈을 사용하고, 인증 정보는 서버에 저장하지 않고 로컬 장치에서 인증 처리되도록 한다.

• MFA 정책의 중앙 관리

- MFA 설정, 적용 대상, 인증수단 등록 및 해지 등의 정책은 중앙 통제 시스템에서 관리하며 변경 이력은 모두 감사에 기록한다.
- MFA 설정 변경 이력(예: 인증 요소 추가/제거, 적용 대상 변경 등)을 모두 감사 로그에 남기고, 주기적으로 검토할 수 있도록 한다.
- 관리자 계정은 사전 승인된 MFA 등록 장치만 허용되며, 등록/삭제는 이중 승인 절차(승인자-검토자)를 거쳐야 한다.

• 예외 처리 절차 마련

- 장비 고장, 생체 인식 오류, 휴대기기 미소지 등의 상황에서 비상 인증 절차(1회용 임시코드 발급 등)를 마련한다.
- 모든 예외는 사유 기록 및 일시적 권한 제한 상태에서만 처리되도록 한다.

항목	적용 기술 또는 방식
인증 요소 구성	지식(PIN), 소유(OTP, Token), 생체(지문, 얼굴)
인증 분리	인증 경로 분리, 인증 장치 물리 분리, MFA Proxy
MFA 정책 관리	중앙 정책 서버, MFA 정책 변경 이력 관리
위험 기반 대응	Risk-Based Authentication, UEBA 연계
인증 장치	OTP Generator, 보안 USB 키(FIDO2), 생체 인증 장치
보안 강화	TOTP/HOTP 기반 OTP, FIDO2, 암호화 저장
통합 관리	IAM, SSO+MFA 통합 솔루션, 감사 로깅 시스템

2. 외부인증수단 (External Identity, EI)

정의

외부 인증수단은 외부 기관 사용자에게 대한 접근 시스템을 식별하고 시스템에 대한 접근 권한 부여하기 위한 통제항목이다.

보안통제 항목

N2SF ID	보안통제 항목 설명	
N2SF-EI-1	C S	외부 자격증명 수단 활용
	안전성 및 신뢰성을 검증받은 외부 기관(또는 업체 등)에서 발급한 자격증명 수단을 활용한다.	
N2SF-EI-2	C S	외부 인증수단 활용
	안전성 및 신뢰성을 검증받은 외부의 인증수단을 활용한다.	
N2SF-EI-M1	C	외부 인증수단 관리
	외부 인증수단의 등록, 변경, 폐지 등 전체 수명 주기를 체계적으로 관리하며, 외부 기관과의 연계된 인증 프로파일의 보안 검증을 주기적으로 수행한다.	

구현 방법 예시

• 외부 자격증명 기반 인증 도입

- 모바일 공무원증 등 기관에서 신뢰할 수 있으며 기관 외 사용자 식별 및 자격증명이 가능한 수단을 인증 방법으로 사용한다.
- 인증된 외부 사용자는 계정 없이 임시 세션 기반 접근 권한을 부여받는다.

• 외부 인증수단 연동

- 외부 사용자가 보유한 인증수단(예: 타기관 OTP, 인증서, FIDO 인증 등)을 등록하고, 인증서의 유효성 및 폐지 상태를 검증한 후 인증에 활용한다.
- 기관 외 사용자에게 대한 인증 수행 시 기관이 사전 승인한 외부 인증 시스템과 인증 프로파일을 활용한 연계를 통해 인증을 수행한다. (예: 이동통신사 인증 등)

• 외부 인증수단 관리 및 감사

- 외부 인증수단의 등록, 변경, 만료, 폐지 이력을 자동 기록하고, 감사 로그로 저장한다.

- 외부 인증수단 연동 시 정기적 보안 검토 및 신뢰성 평가를 실시하며, 보안 기준에 미달한 수단은 자동 차단하거나 격리 조치한다.
- 인증 실패 또는 연속된 오류 발생 시 외부 인증수단을 일시 정지하고 관리자 승인 후 재사용 가능 하도록 설정한다.

• 외부 사용자 최소 권한 접근 및 정보 보호

- 외부 사용자에게 허용된 정보시스템에만 접속할 수 있도록 외부 사용자 단말의 네트워크 경로를 별도 설정한다.
- 외부 사용자 세션은 시간제한, IP 제약, 단말 인증 병행 적용을 통해 보안을 강화한다.
- 외부 사용자의 개인정보 및 인증 정보는 조직 내 데이터베이스와 논리적으로 분리하여 저장하며, 익명화 또는 마스킹을 적용한다.

• 외부 인증 실패 대응 및 통제

- 외부 인증 요청이 실패하거나 인증서 유효성 검증에 실패한 경우, 즉시 접근 차단 및 관리자 알림이 발생한다.

항목	적용 기술 또는 방식
외부 자격증명 기반 인증	모바일 공공 인증 등 외부 기관에서 발급한 자격증명, 일회성 세션 기반 접근 권한
외부 인증수단 연동	OTP, 인증서, FIDO 인증 모듈, 인증 프로파일 기반 검증
외부 인증수단 관리 및 감사	외부 인증수단 등록/변경/폐지 시 주기적 보안 검토 및 관리 로그 기록
외부 사용자 최소 권한 및 정보 보호	네트워크 경로 분리, 최소 권한 접근, 개인정보 마스킹·익명화
외부 인증 실패 대응 및 통제	인증 실패 시 즉시 접근 차단, 관리자 알림, 재사용 승인 절차

3. 단말인증 (Device Authentication, DA)

정의

단말인증은 사용자 또는 관리자 단말의 접근을 허용하기에 앞서, 해당 단말의 식별, 무결성 검증, 보안 상태 평가를 수행하여 신뢰된 단말만 시스템 자원에 접근할 수 있도록 하는 통제항목이다.

■ 보안통제 항목

N2SF ID		보안통제 항목 설명
N2SF-DA-1	C S	단말 무결성 검증
		단말 내 신뢰 가능한 모듈(TPM 등)을 통한 구성 정보(BIOS 설정 정보, Disk 설치 정보 등) 등을 확인한다.
N2SF-DA-2	C	정보서비스 식별 및 제한
		인증 절차를 통해 사전 승인한 정보서비스만을 활용하도록 제한한다.
N2SF-DA-3	C S	단말 식별 및 인증
		단말의 고유 식별자(MAC, TPM, 인증서 등)를 통해 단말을 식별하고, 등록된 단말만 인증을 통해 시스템에 접근할 수 있도록 한다.
N2SF-DA-3(1)	C S	인가 단말 인증
		조직 내 등록되어 인가된 단말에 한해 인증수단(디지털 인증서, 장치 지문 등)을 통해 접근을 허용한다.
	C	비인가 단말 인증
N2SF-DA-3(2)		등록되지 않았거나 보안 기준을 충족하지 못한 단말은 인증 요청을 차단하거나 별도 네트워크 구역으로 격리한다.
	C	인증된 단말의 접속 관리
N2SF-DA-4		인증된 단말이라 하더라도 접속 시간, 위치, 사용자에게 따라 세부 접근 권한을 제어하고, 접근 이력을 기록하여 감사 가능하도록 한다.
	C S O	외부 단말 접속 제어
N2SF-DA-5		외부에서 접근하는 단말은 보안 VPN, MFA, 장치검증 등 추가 보안 절차를 거쳐서만 제한된 자원에 접근하도록 구성한다.

■ 구현 방법 예시

• 접속 단말 정보 수집 및 신뢰 점검

- 단말 등록 시 TPM, BIOS UUID, MAC 주소, 디지털 인증서 등의 정보를 수집하여 단말 고유 식별자를 생성한다.
- 수집된 정보는 중앙 단말 등록 시스템에 저장되며, 접근 시 해당 정보와 일치하는 경우에만 접근 허용된다.
- 단말의 무결성(펌웨어 변경, 보안 설정 위반 등)을 검사하여 무결성 검증을 통과한 경우에만 네트워크 접근을 허용한다.

• 인가된 단말 인증 적용

- 등록된 단말에는 디지털 인증서 또는 장치 기반 OTP 인증수단을 연동하고, 사용자는 해당 장치로만 인증 가능하도록 제한한다.
- 각 단말에 고유 식별자(MAC 주소, TPM 키, 디지털 인증서 등)를 부여하고, 등록된 단말만 접근을 허용하는 화이트리스트 기반 접근통제를 구성한다.
- X.509 기반 클라이언트 인증서를 발급받아 사용자 계정과 단말을 연계하고, 인증서 기반 인증을 수행한다.
- 단말 인증 실패 시 사용자 인증과 무관하게 접근을 차단하며, 이력은 별도 감사 로그로 저장된다.

• 비인가 단말 대응

- 등록되지 않은 단말의 접근 시도는 자동 차단되며, 관리자는 등록 요청 여부를 검토할 수 있도록 한다.
- 등록되지 않았거나 관리되지 않은 단말의 접근 시도는 NAC 또는 802.1X 기반 인증 시스템을 통해 차단한다.

• 인증된 단말의 접속 범위 통제 및 감사

- IAM, NAC, DLP 시스템과 연계하여 인증된 단말이라 하더라도 업무 시스템별, 시간대별, 사용자 역할별 접근 정책을 차등 적용한다.
- 접속 기록, 사용 시간, 위치, 사용자 정보 등을 로그 서버 또는 SIEM에 기록하고, 비인가 접속/비정상 사용 감지 시 알림 또는 차단 조치를 수행한다.

• 외부 단말에 대한 보안 통제 강화

- 외부 단말이 접근할 경우 SSL VPN, TLS 기반 보안 채널, Virtual Desktop Infrastructure(VDI) 등을 통해서만 내부 자원에 접근 가능하도록 한다.
- 이때 반드시 다중요소 인증(MFA)를 적용하고, 접속 환경에 따라 추가 인증 요소를 요구하거나 세션을 제한한다.
- USB, 프린터, 클립보드 등 로컬 장치 리디렉션 제한 기능을 적용하여 민감 정보 유출을 방지한다.
- 외부 단말 세션은 최대 지속시간, 활동 기반 자동 로그아웃 등의 조건을 적용한다.

항목	적용 기술 또는 방식
단말 무결성 검증	TPM 기반 무결성 검증, EDR, SIEM 연동
단말 식별	MAC, TPM, X.509 인증서 기반 식별
비인가 단말 차단	NAC, 802.1X
사용자-단말 연계 인증	인증서 + OTP, 사용자-장치 정책 연계
인증된 단말의 범위 제한	IAM, NAC 등을 통한 접속 범위 제한
외부 단말 통제	SSL VPN, VDI, TLS 터널, MFA 연동
세션 보호	로컬 장치 제한, 세션 로깅, 위험 세션 감지

4. 인증보호 (Authentication Protection, AU)

정의

인증보호는 계정 인증 보안 강화 및 불법적인 계정 로그인 시도 방지, 생체인증 공격 방지, 대체 보안 수단 강구 등 인증 과정에서의 보안성 강화 및 다양한 위협에 대응하기 위한 통제항목이다.

보안통제 항목

N2SF ID	보안통제 항목 설명	
N2SF-AU-1	C S O	계정 인증 재전송 공격 방지
	불법적인 계정 인증을 시도하는 재전송 공격 방지 대책을 적용한다.	
N2SF-AU-2	C S	통합인증(SSO, Single Sign-on) 보호
	통합인증 기능 적용 시 불법적인 계정 로그인 시도에 대한 기술적 대책을 적용한다.	
N2SF-AU-3	C S	권한 위임 토큰(OAuth) 보호
	권한 위임 토큰(OAuth) 인증 토큰이 탈취되거나 위조되지 않도록 제한 조건과 보호 조치를 설정한다.	
N2SF-AU-4	C S O	생체인증 공격 방지
	생체 데이터를 암호화하여 저장 및 전송하며, 변조 여부를 탐지할 수 있는 메커니즘을 사용한다.	
N2SF-AU-5	C S	인증시스템 구성 및 관리
	인증시스템의 구성 요소를 안전하게 설정하고 변경 시 보안에 영향이 없도록 관리한다.	

N2SF ID		보안통제 항목 설명	
N2SF-AU-5(1)	C	비밀번호 보안 수준 점검	
		자동화된 도구를 이용하여 비밀번호 정책에 적합하게 설정·유지되고 있는지 점검한다.	
N2SF-AU-5(2)	C	대체 보안 수단 강구	
		보안 기능을 구현 또는 제공하는 주요 수단을 사용할 수 없거나 손상되었을 상황을 대비한 대체 보안 수단을 강구한다.	
N2SF-AU-6	C S O	공개키 기반 구조(PKI) 인증서 관리	
		신뢰할 수 있는 공개키 인프라(PKI)를 통해 발급된 인증서 사용을 인증서 유효기간 동안 관리하고 보호한다.	
N2SF-AU-M1	C S O	인증정보 접근 권한 통제 및 관리	
		인증정보는 최소한의 인원만 접근할 수 있도록 제한하고 기록을 남긴다.	
N2SF-AU-M2	C S O	인증 위협 및 취약점 관리	
		인증 관련 취약점을 점검하고 위협 대응 방안을 마련해 운영한다.	

■ 구현 방법 예시

• 재전송 공격 방지 대책 적용

- 재전송 공격(Replay Attack) 방지를 위해 인증 요청 시 Nonce, Timestamp, Challenge-Response 방식 등을 적용한다.
- 인증 세션마다 세션 토큰에 만료 시간과 고유 식별 값을 포함하고, 중복된 인증 요청은 차단한다.
- 로그인 시도 횟수 제한, 계정 잠금, CAPTCHA 기반 방어도 함께 구성한다.

• 통합 인증 및 OAuth 보호

- SSO(Single Sign-On) 사용 시 SAML, OAuth 2.0, OpenID Connect 기반 프로토콜을 적용하고, 인가 토큰은 짧은 주기로 발급한다.
- OAuth 보호를 위해 토큰에 대한 scope 제한, 사용 단말/위치/IP 기반 제어 정책을 설정하고, 토큰 탈취 방지용 refresh token rotation 기능을 도입한다.

• 생체인증 및 인증수단 보호

- 생체인증(Fingerprint, FaceID 등) 정보를 저장하지 않고, FIDO2/WebAuthn 기반 장치 로컬 저장 구조를 활용해 중앙 집중 노출을 차단한다.
- 생체인증 데이터는 해시 및 암호화 후 저장/전송하며, 인증 실패 시 fallback(비밀번호, OTP)으로 전환한다.

• 계정 정보 보호 대책

- MFA 또는 FIDO 인증을 병행하여, 계정 인증 과정에서 탈취 또는 중간자 공격을 방지한다.
- 세션이 비정상 종료되었을 때 즉시 세션을 무효화하고, 토큰 또는 쿠키 정보를 폐기한다.

• 대체 보안 메커니즘 구현

- 기본 인증수단이 사용 불가 시 자동 전환되는 OTP, 인증 앱 등 대체 인증수단을 미리 등록하고 사용자에게 사전 안내한다.
- 시스템의 핵심 보안 기능이 손상될 가능성에 대비하여 보안 메커니즘을 정의하고 이를 구현한다.
- 대체 보안 메커니즘을 정기적으로 점검하고 최신 보안 위협에 대응할 수 있도록 업데이트한다.

• 인증서 기반 인증(PKI) 보호 및 자동화

- 인증서(Cert, Key)는 HSM 또는 클라우드 기반 키 관리 시스템(KMS)에 저장하여 키 탈취를 방지한다.
- 인증서 수명은 자동 갱신 정책을 적용하고, 만료 전 알림 및 갱신 요청이 자동 처리되도록 구성한다.
- 인증서는 사용자 또는 단말과 연계되며, 접근 시 클라이언트 인증서(Certificate-based Auth) 방식이 사용된다.

• 인증시스템 구성 강화

- 인증 서버는 이중화 구성으로 장애 대응력을 갖추고, 구성 변경 시 보안 영향도 평가를 병행한다.

• 인증 위협 탐지 및 대응

- 인증 관련 접근 권한은 RBAC 또는 ABAC 기반으로 최소화하며, 접근 로그는 SIEM에 저장하여 이상 행위 분석에 활용한다.
- 인증시스템의 취약점을 정기적으로 점검하기 위해 취약점 스캐너 또는 API 보안 테스트 도구를 활용한다.
- 인증시스템 설정 변경, 실패 이력, 의심 행위 발생 시 알림 및 차단 정책을 구성한다.

항목	적용 기술 또는 방식
재전송 공격 방지	Nonce, Timestamp, Challenge-Response
통합 인증	SAML, OAuth 2.0, OpenID Connect
OAuth 보호	토큰 Scope 제한, Refresh Token Rotation
생체인증 보호	FIDO2, WebAuthn

항목	적용 기술 또는 방식
비밀번호 보호	Password Policy, Salt + Hash 저장
대체 인증수단	OTP, ARS, 이메일 인증, FIDO Key
인증서 관리	HSM, KMS, 인증서 수명 자동 갱신
권한 및 취약점 관리	IAM, SIEM, 취약점 스캐너, WAF

5. 인증정책 (Authentication Policy, AP)

정의

인증정책은 기관 사용자 증명, 인증 프로파일, 그룹계정 사용자 인증 등 기관 내 사용자의 신원을 지속적으로 확인하고 보호하기 위한 통제항목이다.

보안통제 항목

N2SF ID	보안통제 항목 설명	
N2SF-AP-1	C S	기관 발급 증명수단 인증 활용
		기관에서 발급한 자격 증명수단(모바일 공무원증 등)을 활용하여 사용자를 인증한다.
N2SF-AP-2	C S	인증 프로파일 활용
		사용자의 직무나 역할에 따라 인증 기준을 정하고, 그에 맞게 관리한다.
N2SF-AP-3	C S	그룹 계정 사용자 인증
		그룹 계정 인증 시 해당 그룹 계정에 포함된 사용자를 식별할 수 있는 인증수단을 적용하여 사용자 인증을 추가로 수행한다.
N2SF-AP-4	C	재인증
		주기적 또는 특정 상황·조건에서는 사용자에게 재인증을 요구한다.
N2SF-AP-5	C	동시 중복인증 차단
		정보서비스 특성을 반영하여 동시 중복인증을 차단한다.
N2SF-AP-M1	C S	인증 정책 수립 및 절차 관리
		인증 방식이나 기준을 정하고, 절차를 따라 관리한다.
N2SF-AP-M2	C S	인증 관리자의 역할 및 책임 관리
		인증을 담당하는 관리자에게 역할과 책임을 분명히 정해 운영한다.
N2SF-AP-M3	C S O	인증 관련 보안사고 대응체계
		인증 관련 문제가 생겼을 때 대한 대응 절차를 마련해 둔다.

■ 구현 방법 예시

• 기관 발급 인증수단 수단 연계

- 행정전자서명, 공무원증, 기관 OTP 등 공식 수단과 인증시스템을 연동하여 사용자의 신원을 검증한다.
- 발급 기관과의 신뢰 체계를 사전에 등록하고, 인증서 유효성 검증 절차를 구현한다.
- 인증서 상태는 OCSP, CRL 방식으로 검증되며, 로그인 시 자동 선택 또는 사용자 지정이 가능하도록 설정한다.

• 역할 기반 인증 프로파일 구성

- 사용자의 부서, 직무, 업무 유형을 기준으로 인증 수준을 구분하고, 각 수준에 따라 MFA 적용, 인증 주기, 인증수단을 조합한 프로파일을 사전 정의한다.
- 인증 프로파일은 계정 생성 시 자동으로 할당되며, IAM 또는 AD와 연계하여 중앙 관리되도록 구성한다.

• 그룹 계정 사용자 식별 절차 도입

- 공용 계정 사용 시 사용자 개별 식별을 위해 2차 인증(OTP, 생체인증, PIN 등)을 요구하고, 사용자 ID 또는 장치 식별 정보를 로그에 남긴다.
- 그룹 계정 사용 이력은 개인 사용자별로 분리 저장되며, 책임 추적성을 확보할 수 있도록 구성한다.

• 재인증 조건 설정 및 적용

- 계정 복구, 비밀번호 변경, 권한 상승 등 특정 이벤트 발생 시 재인증이 요구되도록 시스템 정책을 구성한다.
- 재인증은 OTP, 푸시 인증, 생체인증 등으로 수행되며, 세션 유지 조건, 접속 위치 변경 등의 위험 기반 조건도 함께 고려한다.

• 동시 로그인 및 세션 중복 방지

- 하나의 계정으로 다중 세션이 생성되지 않도록 세션 중복 제한 정책을 적용한다.
- 다른 IP, 장치, 브라우저에서 동일 계정이 접속 시 기존 세션을 종료하거나 사용자 확인을 거치도록 구성하며, 세션 정보는 로그로 기록된다.

• 인증정책 수립 및 변경 이력 관리

- 인증수단, 인증 주기, 예외 허용 조건 등은 정책 문서로 정의하고, IAM 또는 인증 관리 포털을 통해 시스템에 적용한다.

- 정책 변경 시 승인 절차와 이력 기록 기능을 통해 변경 내용을 감사 로그로 남기고, 변경 이력은 주기적으로 검토할 수 있도록 구성한다.

• 인증 관리자 역할 구분 및 권한 통제

- 인증 정책을 설정·변경할 수 있는 관리자 계정은 별도 Role로 정의하고, 승인자·적용자 역할을 분리한다.
- 인증 관리자 변경, 정책 승인 이력은 자동으로 기록되며, 변경사항은 주기적으로 검토할 수 있도록 한다.

• 인증 관련 보안 사고 대응 체계 구축

- 인증 실패 반복, 인증수단 탈취, 계정 도용 등의 상황에 대응할 수 있도록 자동 차단, 세션 종료, 관리자 알림 등의 보안 조치를 시스템에 반영한다.
- SIEM, UEBA, SOAR 등과 연계하여 보안 이벤트 발생 시 실시간 대응이 가능하도록 구성한다.

항목	적용 기술 또는 방식
인증 연계	SAML, OAuth, X.509, OpenID Connect
역할 기반 인증	RBAC 기반 인증 프로파일
그룹 계정 식별	사용자 재확인, 2차 인증, 로그 분리
재인증	조건 기반 MFA 트리거
세션 제어	동시 접속 제한, 세션 핑거프린트
정책 적용	IAM 시스템, 정책 문서, 통합 포털 연동
관리자 권한 관리	Role-Based Access Control, 로그 감사
사고 대응	SIEM, SOAR, UEBA 연동, 자동 차단

6. 인증수단 (Authentication Method, AM)

정의

인증수단은 시스템 접근에 사용되는 인증의 생성, 변경, 보호, 갱신 등을 관리하기 위한 통제 항목이다.

■ 보안통제 항목

N2SF ID	보안통제 항목 설명	
N2SF-AM-1	C S O	암호모듈 기반 인증
	관련 법규, 정책 및 규정 등을 준수한 암호모듈 인증체계를 적용한다.	
N2SF-AM-2	C S O	비밀번호 기반 인증
	숫자·문자·특수문자 등을 혼합하고 주기적으로 변경하는 비밀번호 인증체계를 적용한다.	
N2SF-AM-3	C S O	공개키 기반 인증
	신뢰할 수 있는 인증 기관(CA)을 통해 발급된 인증서의 유효성을 검증하고, 인증서의 발급, 갱신, 폐지 등을 관리한다.	
N2SF-AM-4	C S O	초기 인증수단 변경
	시스템 설치 후 초기 설정된 비밀번호나 인증서는 반드시 사용자 지정 값으로 변경하도록 하여 기본값 노출을 방지한다.	
N2SF-AM-5	C S	인증수단 보호
	정보시스템의 보안 수준에 준하여 인증수단을 보호한다.	
N2SF-AM-6	C S O	암호화되지 않은 인증수단 내장 금지
	암호화되지 않은 인증수단이 응용프로그램 또는 스크립트 등에 내장되거나 기능키 등에 삽입되지 않아야 한다.	
N2SF-AM-7	C S O	캐시된 인증수단 재사용 차단
	캐시된 인증수단이 세션 유효 시간이 만료된 이후에 재사용되는 것을 차단한다.	
N2SF-AM-8	C S	공개키 기반 저장소 관리
	네트워크, 운영체제, 브라우저, 응용프로그램을 포함하여 모든 정보시스템에 설치된 PKI 저장소에 대해 관리방안을 수립한다.	
N2SF-AM-9	C S O	소유기반 인증
	생체인증, 모바일 인증 및 하드웨어 토큰 등을 활용한 인증체계를 적용한다.	
N2SF-AM-M1	C S	인증시스템 운영 감사
	인증 서버와 구성 요소가 안전하게 운영되고 있는지 주기적으로 점검하고, 이상 행위는 감사 대상에 포함한다.	
N2SF-AM-M2	C S	인증수단 정기적 보안 평가
	사용 중인 인증 방식과 시스템에 대해 정기적으로 취약점 분석과 보안성 평가를 수행하여 보완한다.	

■ 구현 방법 예시

• 인증수단 생성, 보호 및 변경 관리

- 비밀번호 기반 인증은 복잡성 규칙(Complexity Rule), 만료 정책(Expiration Policy), 재사용 제한>Password History) 을 적용하며, 초기 비밀번호 또는 기본 인증정보는 최초 로그인 시 즉시 변경되도록 설정한다.

- 비밀번호는 안전한 해시 알고리즘을 이용하여 해시하고, 저장 시에는 암호화 파일 시스템(EFS) 또는 HSM(Hardware Security Module) 을 통해 안전하게 보호한다.
- 비밀번호 외의 인증정보는 대체 수단(OTP, Push 인증, FIDO 키 등) 을 함께 적용하여 다중요소 인증(MFA) 체계로 보완한다.

• 비밀번호 정책 적용

- 최소 길이, 대문자/숫자/특수문자 포함, 일정 주기 변경 등의 비밀번호 정책을 시스템에 적용한다.
- 동일 비밀번호 재사용 방지를 위해 비밀번호 이력을 최소 3개 이상 보관한다.

• 암호화된 인증수단 저장

- 인증시스템 전반에는 공인된 암호모듈을 기반으로 구성된 암호화 인증 모듈을 적용하며, 이는 인증서 저장, 인증 토큰 보호, 세션 암호화 등에 활용된다.
- 인증정보 저장소(DB, 파일 등)는 AES, RSA등의 알고리즘으로 암호화하고, 암호모듈 인증 상태 및 버전 관리를 수행하여 무결성을 유지한다.
- 인증 토큰(OAuth Access Token, Refresh Token 등) 이 탈취되거나 변조되지 않도록, 토큰 암호화와 JWT 서명 검증(HMAC 또는 RSA) 을 포함한 보호 조치를 설정한다.

• 인증수단 손상 대응

- 인증서 유출, 비밀번호 노출 등 인증 정보가 손상되었을 경우, 즉시 폐기하고 새로운 수단으로 대체 되도록 자동화한다.
- 손상 감지 시 관리자에게 경고를 보내고 접근 권한을 일시 정지한다.
- 스크립트 내 인증정보 하드코딩 방지를 위해 정적 분석 도구(SAST)를 활용하여 인증서, 비밀번호 등의 노출 여부를 검사한다.

• 인증정보 삭제

- 인증이 완료된 후, 메모리나 세션에 남아 있는 인증정보는 자동으로 삭제되도록 구성한다.
- 인증 쿠키나 토큰은 세션 종료 시 만료되도록 설정한다.

• 인증 저장소 보호 및 접근 제어

- 시스템 인증에는 공개키 기반 구조(PKI) 를 적용하고, 사용자에게 발급된 인증서는 유효성 검증을 통해 관리한다.
- PKI 기반 인증서 저장소는 브라우저, OS, 응용프로그램별로 존재하므로, 통합 관리 도구를 통해 중복된 저장소를 통제하고, 신뢰 루트 관리 기능을 구성한다.

- 인증서의 발급, 갱신, 폐기는 중앙 CA 및 RA 서버를 통해 자동으로 처리되며, 각 인증 행위는 Audit Trail에 기록되도록 한다.

• 인증시스템 보안 점검 및 운영 감사

- 인증 구성 요소(인증 서버, DB, API, 인증포털 등)는 분리 배치하며, 변경은 반드시 CI/CD 보안 승인 절차를 통해 반영한다.
- 시스템은 주기적으로 취약점 진단 도구를 통해 점검하며, 발견된 위험은 변경관리 프로세스에 따라 수정한다.
- 인증 로그 및 실패 이력, 변경 이력은 SIEM, IAM 로그 분석, 세션 로그와 연계되어 비정상 행위 탐지에 활용된다.

항목	적용 기술 또는 방식
비밀번호 정책 적용	Complexity Rule, Password Expiry, Password History, First Login Change
OTP 및 다중요소 인증 적용	TOTP, FIDO2, ARS 인증, SMS/Email Token
인증서 기반 인증	PKI, X.509, CA/RA 서버 관리
생체정보 인증	지문/얼굴 인증 (FIDO2, WebAuthn)
인증정보 보호 및 저장	해시, HSM
인증 캐시 제거	세션 만료 후 자동 삭제, 브라우저 정책 설정
통합 인증 프로토콜	OAuth 2.0, SAML, OpenID Connect
위험 기반 인증	Risk-Based Policy
인증 로그 감사 및 정책 변경	SIEM 연계, 인증 실패/변경 이력 저장, MFA 설정 감사

7. 로그인 (Login, LI)

■ 정의

로그인은 인증 피드백 보호, 로그인 시도 제한, 시스템 사용 알림, 인증 결과 처리 등 사용자 계정 인증 과정에서의 보안 위협 방지를 위한 통제항목이다.

■ 보안통제 항목

N2SF ID	보안통제 항목 설명	
N2SF-LI-1	C S O	유효한 인증정보 노출 방지
		인증 과정에서 유효한 인증정보가 노출되지 않도록 한다.
N2SF-LI-2	C S	로그인 실패에 따른 접속 제한
		정의한 횟수 이상 연속적으로 로그인을 실패한 경우 일정 시간 계정을 차단(또는 잠금)하거나 접속을 제한한다.
N2SF-LI-3	C S	로그인 실패에 따른 인증 요소 추가
		정의한 횟수 이상 연속적으로 로그인을 실패한 경우 추가 인증수단(생체인증, OTP, ARS 등)을 적용한다.
N2SF-LI-4	C S	계정 잠금 해제 인증 요소 추가
		계정 잠금 상태에서 해제 요청 시 기본 인증 요소 외 인증 요소를 추가 사용한다.
N2SF-LI-5	C	정보시스템 사용 알림
		로그인(사용자 인증 성공) 후 사용자 화면에 정보시스템(서비스 등)에 관한 정보를 알림으로 표시하고, 사용자가 명확하게 인지한 상황에서 표시를 종료하도록 적용한다.
N2SF-LI-6	C S	직전 로그인 정보 알림
		로그인(사용자 인증 성공) 후 사용자 화면에 사용자의 직전 로그인 정보를 사용자가 확인할 수 있도록 표시한다.
N2SF-LI-7	C	실패 로그인 정보 알림
		로그인(사용자 인증 성공) 후 사용자 화면에 사용자의 로그인 실패 정보를 사용자가 확인할 수 있도록 알림을 표시한다.
N2SF-LI-8	C S	로그인 이력 정보 제공
		로그인(사용자 인증 성공) 후 사용자 화면에 로그인 성공 이력 정보를 제공한다.
N2SF-LI-9	C	계정 정보 변경 알림
		로그인(사용자 인증 성공) 후 사용자 계정 관련 정보 변경 이력이 존재하는 경우, 일정 기간동안 사용자에게 해당 내용 알림을 표시한다.
N2SF-LI-10	C	로그인 부가 정보 제공
		로그인(사용자 인증 성공) 후 이전에 성공한 로그인과 관련된 부가 정보(접속 위치, 단말 종류 등)를 제공한다.
N2SF-LI-M1	C	로그인 실패 모니터링 및 보고
		반복 실패, 의심 로그인 시도 등의 실패 패턴을 실시간 감지하고 관리자에게 보고한다.
N2SF-LI-M2	C S	주기적 로그인 정보 무결성 점검
		로그인 관련 데이터(세션, 토큰, 사용자 연계 정보 등)에 대해 주기적으로 무결성을 점검하고 이상 여부를 확인한다.

■ 구현 방법 예시

• 로그인 시도 제한 보호조치

- 기관이 지정한 인증 시도 횟수를 초과하여 사용자 인증 실패 시 해당 계정의 상태를 잠금 상태로 변경하여 일정 시간 또는 영구히 접속을 차단한다.
- 기관이 지정한 인증 시도 횟수를 초과하여 사용자 인증 실패 시 해당 계정에 대한 기본 인증수단 외 추가 요소 인증을 요구한다. (예: 기본 비밀번호 외 OTP, 생체인증, ARS, SMS, 보안 질문, 모바일 공무원증, 기관 지급 인증 장치 등 추가 인증수단 사용)

• 로그인 정보 노출 방지

- 로그인 화면과 통신 채널은 TLS 1.2 이상 암호화를 적용하고, 입력값 마스킹 및 화면 캡처 방지 기능을 활성화한다.
- 유효한 인증정보가 탈취되지 않도록 세션 타임아웃, 브라우저 캐시 차단, 자동 로그아웃 등을 적용한다.

• 시스템 알림 설정

- 사용자가 기관 정보시스템 등 시스템 로그인 전 또는 로그인 후 해당 사용에 대한 필요 내용을 인지할 수 있도록 알림 기능을 수행한다.
- 시스템 사용에 대한 필요 내용은 시스템 사용 조건, 권한, 정책 등 기관이 지정한 내용을 출력한다.

• 이전 로그인 정보 알림

- 사용자 로그인 후 접속 시간, 접속 위치(IP 주소) 등 기관이 지정한 직전 로그인 정보를 사용자 화면에 출력한다.
- 로그인 이력은 정해진 횟수 이상을 보관하며, UI에서 사용자가 직접 확인할 수 있도록 구성한다.

• 로그인 실패 정보 알림

- 사용자 로그인 후 이전 로그아웃 시점부터 현재 로그인 시점 사이의 로그인 실패 정보를 사용자가 확인할 수 있도록 알림을 수행한다.

• 로그인 정보 제공

- 사용자 로그인 후 사용자 화면에서 사용자가 이전 로그인 관련 정보를 확인할 수 있도록 기능을 제공한다.

• 계정 정보 변경 알림

- 계정 잠금/해제, 비밀번호 변경, MFA 방식 변경, 복구 옵션 변경 등 주요 인증 상태 변화 시 사용자에게 알림톡, 이메일, 팝업 등으로 실시간 알림을 제공한다.
- 계정 정책 변경은 사용자 계정과 연동되어 자동으로 반영되며, 일정 기간 동안 변경 이력을 사용자에게 노출한다.

• 로그인 실패 모니터링 설정

- 동일 계정 또는 동일 IP에서 다수의 로그인 실패가 발생할 경우 자동으로 로그를 생성하고 관리자에게 알림을 전송한다.
- 로그인 실패 이벤트는 SIEM 또는 로그 분석 시스템과 연동되어 이상 행위로 탐지되며, 필요시 계정을 자동 잠금 처리한다.

항목	적용 기술 또는 방식
로그인 시도 제한	계정 잠금, 로그인 실패 횟수 제한, IP 차단 목록 설정
인증 실패 시 추가 인증 요구	다중인증(MFA) 적용, OTP, 생체인증, ARS 인증 연동
로그인 이력 확인 및 알림	사용자별 로그인 이력 로그 기록(DB/파일), UI 출력 템플릿 구성, 웹 푸시/이메일/알림톡 연동
계정 상태 변화 알림	사용자 프로파일 변경 감지, 정책 기반 알림 트리거 설정, SIEM 또는 IAM 연계 알림 전송
로그인 이상 행위 탐지	UEBA 솔루션, SIEM 연계 이상 징후 분석, Risk-based 접속 정책, 비정상 행위 탐지 룰 기반 탐지
부가 정보 제공 및 감사	로그인 시 단말 정보/위치 정보 제공, 감사 로그 생성 및 장기 저장

제3장

분리 및 격리

1. 분리 (Segregation, SG)

정의

정보서비스 및 업무정보가 보안 등급에 따라 서로 다른 보안 도메인으로 구분되도록 하드웨어, 소프트웨어, 운영체제 분리 또는 인프라, 사용자 기능 분리를 통해 각 영역에 대한 보안을 강화하기 위한 통제항목이다.

보안통제 항목

N2SF ID		보안통제 항목 설명	
N2SF-SG-1		C S	하드웨어 기반 분리
		서로 다른 영역이 구분되도록 하드웨어를 통해 분리하고, 보안통제를 적용한다.	
N2SF-SG-2		C S O	운영체제(OS) 기반 분리
		하나의 시스템에 다수 OS가 존재하더라도, 각 운영체제는 서로 독립된 환경으로 분리되도록 구성한다.	
	N2SF-SG-2(1)	C	시스템 파티셔닝
		동일 하드웨어 내에서도 OS, 데이터, 애플리케이션 영역을 파티션별로 구분하여 영역 간 영향을 제한한다.	
N2SF-SG-3		C S	소프트웨어 기반 분리
		소프트웨어적 논리구조를 활용하여 기능이나 사용자의 실행 영역을 분리하며, 실행 파일 간 충돌이나 간섭을 차단한다.	
	N2SF-SG-3(1)	C S	프로세스 기반 분리
		다중 사용자 또는 다중 작업 실행 시 프로세스 간 간섭을 방지하기 위해 각각의 실행 공간을 격리한다.	
N2SF-SG-4		C S O	IP체계 분리
		서로 다른 영역 또는 정보자산(기능 등)별 IP체계를 분리하고, 보안통제를 적용한다.	

N2SF ID		보안통제 항목 설명
N2SF-SG-5	C S	보안·운영관리 인프라 분리
		보안·운영관리 인프라를 물리적으로 분리된 네트워크로 구성하여 이외 정보시스템과 분리한다.
N2SF-SG-5(1)	C S O	개발/테스트 환경 분리
		운영 시스템과 구분된 개발/테스트 환경을 별도 구성하여 시스템 안정성과 보안을 확보한다.
N2SF-SG-6	C S	보안 기능과 사용자 기능 분리
		인증, 감사 및 데이터 통제와 같은 핵심 보안 기능과 데이터 입력, 애플리케이션 실행 등 사용자 기능을 분리한다.
N2SF-SG-M1	C S	분리 정책 및 절차 수립
		자산 간 분리 기준, 설정 방식, 승인 절차 등을 포함한 정책과 문서화된 절차를 수립한다.
N2SF-SG-M2	C	보안·운영 인프라 접근 책임 및 역할 관리
		분리된 인프라에 접근 가능한 대상 및 책임자를 지정하고 권한 기반 접근 통제를 적용한다.
N2SF-SG-M3	C S	분리된 시스템 정기적 평가 및 감사
		분리된 영역의 적절성, 위협, 취약점 등을 정기적으로 점검하고, 감사 결과에 따라 개선 조치를 수행한다.
N2SF-SG-M4	C S	분리 환경 접근 권한 관리 및 모니터링
		분리된 환경에 대한 접근 권한을 사용자, 장비, 서비스 단위로 설정하고 이를 모니터링한다.
N2SF-SG-M5	C	분리 위반사항 대응체계 운영
		분리 정책 위반 발생 시 자동 경고, 세션 차단, 감사 로그 저장 등 즉시 대응이 가능하도록 대응 체계를 운영한다.

■ 구현 방법 예시

• 하드웨어 기반 물리적 분리 구성

- 시스템 자산의 보안 등급에 따라 물리적으로 서로 다른 장비에 배치하여, 동일 장비 내 자산 간 불필요한 데이터 경로와 하드웨어 공유를 방지한다.
- 사용자 업무망과 관리자 제어망을 각각 분리된 장비에 구성하고, 이더넷 포트 또는 NIC 인터페이스도 분리하여 관리한다.

• 운영체제 및 애플리케이션 계층 논리 분리

- 단일 OS 내 다중 사용자 환경에서는 사용자별 홈 디렉토리, 실행 경로, 파일 접근 권한을 ACL과 RBAC 기반으로 제한한다.
- 프로세스 간 권한을 격리하기 위해 Linux AppArmor, SELinux, Windows Application Locker를 적용하고, 사용자별 실행 권한을 제한한다.

- 서버 응용 프로그램(웹, DB, API 등)은 운영 포트, 서비스 계정, 설정 파일 경로를 별도로 설정하여 격리한다.

• 가상화 및 하이퍼바이저 기반 분리 정책 적용

- 가상 머신 간 보안 도메인을 분리하기 위해 각 VM은 고유 보안 정책을 갖도록 설정하고, 하이퍼바이저에서 리소스 분배와 메모리 격리(Memory Isolation)를 적용한다.
- 업무 도메인별로 별도 가상 머신(VM)을 생성하고, 하이퍼바이저에서 메모리 보호, 스토리지 I/O 분리, CPU 스케줄링 제어 등 자원 격리를 설정한다.
- 하이퍼바이저 보안 로그는 Syslog 서버 및 SIEM과 연동하여 통합 분석한다.

• 컨테이너 환경의 분리 정책 강화

- 각 컨테이너는 Namespace, cgroup, Read-Only Root Filesystem을 활용하여 독립된 실행 환경으로 구성한다.
- 컨테이너 이미지 보안 검증을 위해 이미지 스캐너, 서명 검증, 취약점 점검을 실시한다.
- 컨테이너 간 통신은 네트워크 정책을 통해 통제하며, IPC, shared memory 사용은 제한한다.

• 네트워크 기반 보안 도메인 분리

- 보안 등급 또는 기능별로 네트워크를 VLAN, Subnet, DMZ로 분리하고, 각 영역 간에는 방화벽, ACL 등을 배치하여 흐름을 통제한다.
- 사용자망, 운영망, 개발망, 외부 연계망은 독립된 서브넷으로 구성하며, 라우팅 정책 및 포트 접근 제어를 명시적으로 설정한다.
- 네트워크 흐름은 NTA(Network Traffic Analysis) 도구를 통해 이상 패턴을 분석하고, 비인가 접속은 자동 차단한다.

• 개발·운영 환경 및 테스트 환경 분리

- 개발, 테스트, 운영 서버는 네트워크 및 자산으로 구분하여 별도 영역으로 운영한다.
- CI/CD 도구는 운영망과 연결되지 않도록 구성하며, 코드 배포는 사전 승인 기반으로 제한한다.
- 개발용 데이터는 마스킹(Data Masking), 샘플링을 통해 운영 데이터와 구분한다.

• 분리 환경에 대한 지속적 감사 및 정책 적용

- 분리 영역에 대해 SIEM, 로그 수집기를 통해 변경 상태를 주기적으로 감시한다.
- 분리 정책 위반 시 자동 알림, 세션 차단, 계정 정지, 로그 백업 등의 정책을 자동화하여 대응한다.

- 위반 로그는 중앙 감사 로그 서버로 전송되며, 이상 징후는 탐지 시스템(UEBA, NDR 등)을 통해 탐지된다.

• 보안 기능과 사용자 기능의 서비스 분리

- 사용자가 접근하는 애플리케이션과 백엔드의 인증, 감사, 로깅 기능은 별도 서비스 또는 모듈로 구성하여 접근 경로와 책임을 분리한다.

항목	적용 기술 또는 방식
물리적 장비 분리	물리 서버 분리, KVM 접근 제어, 이중 NIC 구성
OS/애플리케이션 분리	SELinux, AppArmor, RBAC, ACL, 서비스 계정 분리
가상화 기반 분리	하이퍼바이저 리소스 격리, VM 간 방화벽, 보안 그룹
컨테이너 분리	Namespace, Read-Only FS
네트워크 도메인 분리	VLAN, Subnet, DMZ, 방화벽, ACL, 라우팅 정책
개발·운영 환경 분리	CI/CD 경로 분리, 개발망 분리, 마스킹
보안 기능 분리	인증/감사 서버 분리, API Gateway
상태 감시 및 대응	SIEM, 로그 서버, 자동 알림, 정책 위반 탐지 (UEBA, NDR)

2. 격리 (Isolation, IS)

정의

정보시스템은 각 프로세스를 독립된 공간에서 실행하여 상호 간섭을 차단하고, 일반 사용자에게 관리 기능 및 인터페이스의 노출을 제한하며, 애플리케이션 접근을 통제하여 데이터의 무단 접근을 방지하기 위한 통제항목이다.

보안통제 항목

N2SF ID	보안통제 항목 설명	
N2SF-IS-1		프로세스 격리
	실행되는 각 프로세스(작업 또는 프로그램)가 다른 프로세스에 영향을 미치거나 간섭을 차단하기 위해 독립된 공간에서 실행한다.	
N2SF-IS-2	  	정보시스템 운영·관리 기능 표출 제한
	일반 사용자에게 정보시스템 관리와 관련된 기능 및 인터페이스 표출을 제한한다.	

N2SF ID	보안통제 항목 설명	
N2SF-IS-3	C S	애플리케이션 논리적 격리
	하나의 시스템 내 여러 애플리케이션이 서로 자원을 공유하지 않도록 논리적으로 격리해 민감 데이터 접근을 제한한다.	
N2SF-IS-4	C S O	네트워크 격리
	내부망, 외부망, 보안망 등 네트워크 간에 방화벽, 라우팅 제어 등으로 트래픽을 분리하여 정보 유출 또는 확산을 방지한다.	
N2SF-IS-5	C S O	가상화 환경 격리
	가상머신(VM) 또는 컨테이너는 호스트와 다른 가상환경 간 간섭이 없도록 하이퍼바이저 및 메모리 보호 기술로 격리한다.	
N2SF-IS-6	C S O	격리 위반사항 대응체계 운영
	시스템 간 경계 침해, 애플리케이션 간 접근 시도 등 격리 위반 탐지 시 경고, 차단, 로그 분석 등 즉각적인 대응체계를 갖춘다.	

■ 구현 방법 예시

• 프로세스 격리를 위한 격리 기술

- 각 프로세스를 독립적인 가상 머신(VM) 또는 컨테이너(Container)에서 실행하여, 프로세스 간 간섭을 원천적으로 차단한다.
- 하드웨어 기반 메모리 보호(Memory Isolation) 기술(Intel VT-x나 AMD-V 기술 등)을 활용하여 프로세스가 다른 프로세스의 메모리에 접근하지 못하도록 설정한다.

• 시스템 관리 기능 및 인터페이스 제한 기술

- 시스템 운영 기능과 관리 인터페이스는 일반 사용자에게 노출되지 않도록 별도의 관리 경로로 분리하며, 역할 기반 접근 제어(RBAC)를 적용하여 기능별 접근 권한을 제한한다.
- 관리자는 별도의 URL 또는 인증수단을 통해서만 접근하도록 설정한다.
- 사용자 계정에게 시스템 제어 패널, 네트워크 설정, 서비스 시작/중지 등의 관리 기능 접근을 UI 또는 CLI에서 숨김 처리한다.
- API 기반 시스템에서는 Swagger 또는 관리자 콘솔 인터페이스 접근 권한을 RBAC로 통제한다.

• 애플리케이션 접근 통제 기술

- 동일 시스템 내 애플리케이션 간 자원 공유는 최소화하고, 논리적으로 분리된 저장 공간이나 네트워크 인터페이스를 사용하여 민감한 데이터에 대한 비인가 접근을 차단한다.
- 이를 위해 Web Application Firewall(WAF)을 설치하고, 세션 간 데이터 유출 및 입력값 변조 등을 탐지하여 대응한다.

- 민감 정보가 존재하는 애플리케이션은 네트워크 정책 및 인바운드 포트를 엄격히 통제하여 접근을 제한한다.

• 네트워크 분리 적용

- DMZ, 외부망, 내부망, 보안망 간에는 라우팅 경로와 NAT 경계를 명확히 분리하고, 중간에 L3/L7 방화벽과 IDPS를 배치한다.
- 서브넷별 트래픽 흐름은 ACL, Security Group, Firewall Rule로 정책 설정하고, 비인가 포트 접근은 기본 차단한다.
- 네트워크 경로에 대한 실시간 흐름은 NTA(Network Traffic Analysis) 솔루션으로 감시한다.

• 가상화 격리 구성

- 하이퍼바이저 수준에서 VM 및 컨테이너의 리소스는 CPU Pinning, Memory Allocation Control, Storage QoS로 격리한다.
- VM 간 트래픽은 가상 네트워크 방화벽을 통해 통제하며, 하이퍼바이저의 취약점은 정기 패치 및 FIPS 모드로 보호한다.
- 컨테이너 실행 환경은 Namespace, AppArmor, seccomp를 조합하여 IPC, file, socket 접근을 제한한다.

• 위반 탐지 및 대응

- 프로세스 간 의심스러운 접근 시도 또는 비정상 IPC 호출을 EDR로 탐지한다.
- 서비스 간 데이터 전송이 정책을 위반할 경우, SIEM과 연동하여 자동 경고 및 세션 종료 정책을 적용한다.
- 격리 위반 시 로그는 중앙 저장소로 전송되며, 탐지된 이벤트는 관리자 알림 또는 플레이북 기반 대응으로 처리한다.

항목	적용 기술 또는 방식
프로세스 실행 격리	AppArmor, SELinux, WDAC, 실행 경로 제한, 프로세스별 사용자 분리
관리 기능 통제	제어판 숨김, sudo 제한, RBAC 기반 관리 콘솔 제어
애플리케이션 논리 분리	WAF, 비정상 IPC 금지
네트워크 격리	DMZ/내부망 분리, L3 방화벽, IDPS
가상환경 격리	Hypervisor Memory/CPU 분리, Namespace설정, seccomp, 가상 방화벽
위반 탐지 및 자동 대응	EDR, SIEM

제4장

통제

1. 정보흐름 (Information Flow, IF)

정의

정보시스템 간에 정보가 이동할 수 있는 경로에 대한 관리 제어를 통해 비정상 동작, 외부 공격, 암호화된 정보의 흐름, 일방향 데이터 전송 및 차단, 메타데이터 활용, 정보 전송 방식 제한, 보안 및 프라이버시 규칙 등을 통제하여 민감한 정보의 유출을 방지하고 안전한 정보흐름을 보장하기 위한 통제항목이다.

보안통제 항목

N2SF ID	보안통제 항목 설명	
N2SF-IF-1	C S	정보흐름의 동적 통제
	정보시스템의 비정상 동작, 외부의 공격 등 지정한 조건에 대하여 정보흐름을 동적으로 통제한다.	
N2SF-IF-2	C S	암호화된 정보흐름 통제
	암호화된 정보의 내용을 확인하기 위하여 정보를 복호화하거나, 확인이 불가능한 암호화된 정보는 흐름을 차단하는 등의 조치를 적용한다.	
N2SF-IF-3	C S O	임베디드 데이터 삽입 차단
	임베디드된 데이터 내부에 인가되지 않은 다른 종류의 데이터가 삽입되는 것을 차단한다.	
N2SF-IF-4	C	메타데이터 활용 정보흐름 통제
	메타데이터(소유자, 생성일시 등 기록), 이미지/영상/오디오용 메타데이터 등을 활용하여 정보흐름을 통제한다.	
N2SF-IF-5	C	일방향 정보흐름 통제
	일방향 전송 장치를 통해 단방향 정보흐름만 허용하고 반대 방향 흐름을 차단한다.	
N2SF-IF-6	C S O	필터링 규칙 정보흐름 통제
	보안 및 프라이버시 등에 관한 필터링 규칙을 적용하여 정보흐름을 통제한다.	

N2SF ID	보안통제 항목 설명	
N2SF-IF-7	C S	데이터 유형 식별자 통제
	서로 다른 영역 간에 정보를 전송하는 경우 데이터 유형 식별자를 확인하여 전송 여부를 통제한다.	
N2SF-IF-8	C S	인가되지 않은 정보 전송 통제
	인가되지 않은 정보가 포함되었는지 검사하고 보안정책에 따라 해당 정보의 전송을 차단한다.	
N2SF-IF-9	C S O	출발지점과 도착지점 식별 및 인증
	정보 전송 시 개인, 기관, 응용프로그램 혹은 정보시스템 등 하나 이상을 사용하여 출발지점과 도착지점을 식별하고 인증한다.	
N2SF-IF-10	C S	정보 전송 방식 제한
	정보 전송 시 특정 매체나 방식만 허용하고 나머지는 차단한다.	
N2SF-IF-11	C	데이터 전송 차단
	서로 다른 정보시스템(또는 영역 등)으로의 접근은 허용하되 데이터 전송은 차단한다.	
N2SF-IF-12	C S	정보흐름 통제 기능 유지
	독립적인 다수의 정보흐름 통제 체계를 구성하여 하나의 통제 체계가 무력화되더라도 정보흐름 통제 기능을 유지한다.	
N2SF-IF-13	C S	시간 기반/상황 기반 흐름 제한
	특정 시간대 또는 상황(비상, 침해 등)에 따라 정보흐름을 제한하거나 차단한다.	
N2SF-IF-14	C S	보안등급기반 흐름 통제
	보안등급에 따라 정보 흐름을 제한하여 상위 등급에서 하위 등급으로의 부적절한 전송을 차단한다.	
N2SF-IF-15	C S	전용 통신망 구성
	외부로부터 정보흐름을 보호할 수 있는 전용 통신망(전용회선, 가상사설망 등)을 구성한다.	
N2SF-IF-M1	C S O	정보흐름 통제 정책 수립 및 갱신
	정보 흐름에 대한 통제 기준 및 예외 절차를 문서화하고 정기적으로 갱신한다.	
N2SF-IF-M2	C S O	정보흐름 로그 기록 및 보존
	정보 흐름 통제 활동(허용/차단 등)을 로깅하고, 법적/감사 목적으로 일정 기간 보관한다.	
N2SF-IF-M3	C S	정보흐름 통제 감사 및 이행 점검
	정보 흐름 통제의 적용 현황을 정기적으로 점검하여 정책 미준수 사항을 식별 및 개선한다.	
N2SF-IF-M4	C S	비인가 흐름 탐지 자동화
	정책을 우회하거나 비정상적 흐름을 탐지하기 위한 자동화 도구 또는 시스템을 구축한다.	
N2SF-IF-M5	C S	통제 실패·예외 보고 체계
	통제가 실패하거나 예외 발생 시 담당자에게 자동 보고하고 이를 기록하는 체계를 마련한다.	

■ 구현 방법 예시

• 정보흐름의 탐지 및 동적 통제 기술

- 실시간 시스템 로그 및 네트워크 트래픽을 모니터링하여 비정상 행위를 탐지하여 정보흐름을 차단한다.
- 민감 정보의 전송 경로에 대해 DLP, 프록시 기반 트래픽 제어 정책을 적용하여 사전 정의된 조건 외의 전송을 차단한다.
- 데이터 유형 식별 기능을 포함해 텍스트, 이미지, 음성 등 다양한 포맷에 대한 흐름을 제어할 수 있도록 구성한다.

• 일방향 정보흐름 통제 기술

- 물리적/논리적 망 연계 솔루션을 통해 일방향 데이터 흐름만 허용하고 데이터 유형 식별자를 검사하여 인터넷망으로 내부 정보 유출을 방지한다.
- 중요 시스템과 외부 간 정보흐름을 단방향으로만 허용하는 데이터 다이오드(Data Diode) 또는 단방향 NIC 기반 송신 장치를 도입한다.
- 일반 네트워크 구간과는 논리적으로 차단된 통신 채널로 구성하여 무단 반송을 방지한다.

• 암호화된 정보흐름 통제 기술

- KCMVP 인증을 받은 암호화 검증 기술을 사용하여 전송 중인 암호화 데이터를 복호화하여 보안 정책에 맞는지 검사한다.
- 암호화된 트래픽의 내용을 보안 정책에 따라 검증하기 위해 SSL/TLS 복호화 프록시, Inline SSL Visibility 장비를 중간에 배치한다.
- 복호화된 내용은 정책 엔진을 통해 검토 후 다시 암호화하여 목적지로 전달되도록 구성한다.

• 고유 출발지점 및 도착지점 인증 기술

- 정보 전송 시 출발지·목적지 주소(IP, 포트, 인증 ID 등)를 기반으로 접근 허용 여부를 판단하고, 비인가 시스템은 사전 차단한다.
- Application Layer Gateway, IP 허용 목록 기반 ACL 정책을 적용한다.

• 전송 무결성 및 방식 제한 기술 적용

- 전송되는 데이터는 해시, Checksum 등 무결성 검증 기술을 적용하여 위·변조 여부를 확인한다.
- 전송 방식은 HTTPS, SFTP, VPN 등 승인된 채널만 허용되도록 방화벽 또는 NAC에서 정책을 수립한다.

항목	적용 기술 또는 방식
정책 기반 전송 통제	DLP, 콘텐츠 정책 필터링, 사용자/위치 기반 제어
암호화된 트래픽 가시성 확보	SSL Proxy, TLS 복호화 어플라이언스, Inline SSL Visibility
일방향 전송 기술	Data Diode, 단방향 NIC, Secure Gateway, CDS
출발자·목적지 검증	IP/MAC 기반 ACL
정보 흐름 통합 관리	SIEM 연계 오케스트레이션, 흐름 시각화, 다중 정책 조율

2. 외부경계 (External Boundary, EB)

정의

정보시스템 경계에서는 외부 네트워크와의 연결 접점을 제한하고, 승인된 통신만 허용할 수 있도록 경계 보호 장치를 활용하여 트래픽을 필터링하며, 이를 통해 외부로부터의 무단 접근을 차단하고 내부 정보시스템 구성 요소 및 데이터 유출 방지, 개인 식별 정보에 대한 보호조치를 위한 통제항목이다.

보안통제 항목

N2SF ID	보안통제 항목 설명	
N2SF-EB-1	C S	연결 접점 제한
	정보시스템의 외부 네트워크 연결 접점 수를 제한한다.	
N2SF-EB-2	C S O	서비스별 외부 통신 통제
	외부와 통신하는 서비스의 경계마다 통신 흐름을 통제한다.	
N2SF-EB-3	C S	화이트리스트 기반 통신 허용
	기본적으로 모든 통신을 차단한 상태에서 필요한 통신만을 허용하는 화이트리스트 기반 정책을 적용한다.	
N2SF-EB-4	C S O	분할 터널링(Split Tunneling) 제한
	인터넷 서비스와 원격 접속을 통한 기관 네트워크를 동시에 이용하는 등 내·외부 통신을 동시 연결하는 분할 터널링 기법을 제한한다.	
N2SF-EB-5	C	통신 경유(proxy) 강제화
	인가된 정보시스템을 경유하여 통신하도록 통신 경로를 강제화한다.	
N2SF-EB-6	C S	외부로의 사이버 위협 통신 발신 제한
	내부에서 외부 네트워크에 사이버 위협을 가하는 발신(outbound) 통신을 탐지 및 차단하고, 발신자(사용자 및 정보자산 등)를 식별한다.	

N2SF ID	보안통제 항목 설명	
N2SF-EB-7	C S	호스트 기반 경계 보호
	정보시스템 구성 요소에 호스트 기반 경계 보안체계를 적용한다.	
N2SF-EB-8	C S O	운영관리용 포트의 물리적 연결 차단
	운영관리용 포트에 인가되지 않은 장치의 포트 연결을 차단한다.	
N2SF-EB-9	C S O	전용 장치를 통한 관리자 권한 접속
	전용 장치를 통해서만 네트워크를 경유하여 관리자 권한으로 접속한다.	
N2SF-EB-10	C S O	정보시스템 구성 요소 외부 노출 차단
	정보시스템 운영관리 및 서비스를 제공하는 구성 요소가 외부 노출되지 않도록 차단한다.	
N2SF-EB-11	C S O	외부 경계 보호 기능 유지
	외부 경계를 보호하는 정보자산(보안시스템 등) 장애 시에도 보호기능은 유지되도록 구성한다.	
N2SF-EB-12	C S O	외부 통신용 정보자산(장치) 설치 금지
	외부 네트워크와 통신하는 인가되지 않은 정보자산(장치) 설치를 금지한다.	
N2SF-EB-13	C S	오류정보 발신자 전송 제한
	네트워크 규약에 따른 통신 오류 발생 시 발신자에게 피드백이나 경고를 통해 정보시스템 구성이나 취약점이 전송되지 않도록 한다.	
N2SF-EB-14	C	외부 DNS 통신 제한
	인가된 DNS 서버 외의 요청을 차단한다.	
N2SF-EB-15	C S	우회 통신 수단 탐지 및 차단
	VPN, Tor 등 우회 경로 사용을 탐지하고 차단한다.	
N2SF-EB-M1	C S	개인 식별 정보 보호
	외부와 통신 시 개인을 식별하거나 특정 개인과 관련된 정보를 포함하는 경우 노출되지 않도록 조치한다.	
N2SF-EB-M2	C S O	외부 경계 정책 수립 및 갱신
	외부 통신 및 경계 보안 정책을 수립하고 주기적으로 갱신한다.	
N2SF-EB-M3	C S O	외부 통신 로그 기록 및 감사
	외부 통신 활동과 설정 변경 사항을 기록하여 감사 가능하도록 한다.	
N2SF-EB-M4	C	외부 경계 위협 탐지 자동화
	이상 행위를 자동으로 탐지하는 시스템을 운영한다	
N2SF-EB-M5	C S	비상 시 외부 통신 격리
	침해 발생 시 외부 통신을 즉시 차단할 수 있는 절차를 마련한다.	

■ 구현 방법 예시

• 통신 모니터링 및 제어 기술

- 시스템 내·외부 경계에서 이루어지는 통신 흐름을 모니터링하고, 보안정책에 따라 차단 또는 허용한다. 승인되지 않은 통신이나 의심스러운 트래픽이 내부 네트워크에 영향을 주지 않도록 보장한다.
- 외부망과 내부망, 업무망과 제어망 등 네트워크 도메인 간 물리적 또는 논리적 경로를 분리하고, 중간에 방화벽과 ACL을 배치하여 접근을 제한한다.
- 각 접점별로 서브넷 또는 VLAN을 구분하고, 네트워크 흐름은 보안 정책에 따라 명시적으로 지정된 목적지에만 허용되도록 구성한다.
- 방화벽을 통해 네트워크 트래픽을 실시간으로 모니터링하며, 비인가 된 접근이나 악성 코드 전송 차단, 침입 탐지 솔루션을 (IDS/IPS)로 이상 트래픽을 탐지 및 차단한다.

• 서브 네트워크(DMZ) 구현 기술

- 외부에서 접근 가능한 시스템(예: 웹 서버, 이메일 서버 등)을 내부 네트워크와 물리적 또는 논리적으로 분리된 DMZ 서브 네트워크에 배치하여 외부 공격이 내부 네트워크로 확산되는 것을 방지한다.
- DMZ에 웹 서버와 일방향 전송장치(Data Diode)를 함께 배치하여 외부로부터 들어오는 요청은 허용하되 내부 네트워크로의 불필요한 트래픽은 완전히 차단한다.

• 서비스 단위 외부 통신 통제

- 시스템 외부와 통신하는 각 서비스 단위(웹 서버, API 등)는 고유 포트 및 인터페이스를 기준으로 식별하며, 경계 방화벽에서 서비스 단위별 트래픽만 허용한다.
- 불필요한 포트는 차단하고, 보안 그룹(SG) 또는 L7 WAF를 적용하여 서비스별 외부 접근을 제어한다.

• 화이트리스트 기반 통신 정책

- 기본적으로 모든 외부와의 통신을 차단하고, 사전에 정의된 허용된 목적지 IP/도메인에 대해서만 예외적으로 통신을 허용하는 화이트리스트 기반 정책을 적용한다.
- DMZ, 운영망, 클라우드 환경 간 통신 경로는 명확한 승인 절차를 거친 후 허용되도록 한다.

• 터널링 및 비인가 경로 방지

- 원격 접근 시 VPN 또는 터널링(Split Tunneling)이 허용되지 않도록 클라이언트 정책을 구성하고, VPN 사용 시 내부망 외 다른 경로와 동시 연결을 차단한다.
- 프록시 사용 여부를 탐지하고, 비 허가된 프록시 경로로의 통신은 차단한다.

• 외부 정보흐름 제어를 위한 경계 보호 기술

- 외부에서 내부 시스템으로 접근 가능한 포트를 최소화하고, 방화벽(Firewall) 또는 L3/L7 Gateway를 통해 특정 포트만 허용되도록 구성한다.
- 승인된 IP 또는 서브넷만 접근할 수 있도록 ACL, Security Group을 적용하며, 나머지 접근은 기본 차단한다.

• 외부 네트워크 연결 통제 기술

- 외부경계에서 네트워크 연결 접점을 제한하여, 외부로부터 무단 접근 위험을 최소화한다.
- 외부로의 모든 트래픽은 방화벽을 통해 관리되며, CDS를 통해 다중 네트워크 간 연결을 관리하여 승인된 데이터만 전송한다.

• 호스트 및 포트 수준의 접속 제한

- 정보시스템 호스트 단위로 보안 정책을 적용하여 불필요한 외부 포트 접근을 제한하며, 인가된 포트 외의 모든 포트는 기본적으로 차단한다.
- NAC 또는 EDR을 통해 비인가 장비나 포트 연결 시도는 즉시 차단하고 관리자에게 알림을 제공한다.

• 외부 연결 장치 및 노출 방지

- 서버 또는 시스템 운영에 사용되지 않는 구성 요소(백업, DB 복제 등)는 외부에 노출되지 않도록 별도 방화벽 정책으로 보호하고, 공용 DNS 등록 여부를 점검한다.
- 외부 통신용 장치 또는 서비스와는 논리적 인터페이스를 분리하고, 물리 포트는 차단하거나 네트워크 분리 도메인에 위치시킨다.

• 이상 통신 대응 및 보호 자동화

- SIEM과 연동하여 비정상 외부 통신 시도나 과다 통신, 터널링 탐지를 기반으로 자동 경고 및 세션 종료 정책을 적용한다.
- 외부 경계 보호 장비는 이중화 구성되며, 장애 발생 시에도 보안 통제가 유지되도록 구성한다.

항목	적용 기술 또는 방식
외부 접속 제한	방화벽, L3/L7 Gateway, ACL, Security Group, 최소 포트 허용 정책
서비스 통신 경계 구성	CDS, Proxy/Reverse Proxy, API Gateway, 고유 포트 분리, IP 기반 접근 제어
화이트리스트 기반 허용 정책	IP/도메인 기반 화이트리스트, DNS/TLS 기반 허용 필터링
분할 터널링 방지	VPN 전체 터널링 강제, NAC 기반 클라이언트 제어, VPN 터널 우회 방지 설정
사이버 위협 식별 및 분석	DLP, NDR, DNS 분석, 출발지/도착지 탐지, 비인가 대상 통신 차단
포트 및 장비 식별 제어	운영 포트 분리, MAC/IP 등록제, NAC 장비 인증, 인증되지 않은 장비 자동 차단

3. CDS (Cross Domain Solution, CD)

정의

크로스 도메인 솔루션(CDS)은 상이한 보안 등급 또는 네트워크 도메인 간의 정보 교환 시, 인가된 통신만을 허용하고 미인가 접근·정보 유출을 방지하기 위해 설계된 보안 장치이자 체계이다. 정보가 고신뢰 영역에서 저신뢰 영역으로 이동할 경우 강력한 검증, 필터링, 무해화 등을 수행하며, 릴레이 시스템, 콘텐츠 무해화(CDR) 등의 기술이 적용된다.

보안통제 항목

N2SF ID	보안통제 항목 설명	
N2SF-CD-1	C S	도메인 간 정보 흐름 검증 및 통제
		서로 다른 보안 도메인 간 정보 흐름 시 데이터 유형, 등급, 출처를 검증하고 사전에 정의된 정책에 따라 전송을 허용, 차단 또는 보류한다.
N2SF-CD-2	C	다단계 보안 레이블 적용
		전송되는 정보에 대해 다단계 보안 등급(예: 기밀, 민감, 공개)을 태깅하고, 대상 도메인의 수신 허용 기준에 부합하는 경우에만 전달한다.
N2SF-CD-3	C S	일방향 전송 기술 적용 (Data Diode)
		정보 유출 방지를 위해 단방향 전송 장치(Data Diode)를 활용하여 물리적 또는 논리적 단방향 정보 흐름을 강제한다. ※ N2SF-IF-5와 유사하지만, CDS에서 단방향 보장 장비 사용 시 구체적으로 분리 필요
N2SF-CD-4	C S	검증 기반 릴레이 시스템 적용
		수신된 정보는 릴레이 서버를 통해 악성코드 스캔, 포맷 검증, 콘텐츠 정제 후 안전성 판단을 거쳐 송신된다.
N2SF-CD-5	C S	파일 유형 기반 전송 정책
		파일 확장자, MIME 타입, 내부 Magic Number 등을 기준으로 허용된 파일 유형만 송수신 허용하고 나머지는 격리 또는 삭제한다.
N2SF-CD-6	C	콘텐츠 무해화 (CDR) 적용
		전송 전 파일 내 삽입된 숨겨진 객체, 매크로, 스크립트 등을 제거하고 안전한 형식으로 변환하여 콘텐츠를 정제한다.
N2SF-CD-7	C S	메타데이터 기반 통제 정책
		파일 메타데이터의 생성일, 작성자, 등급 등 정보에 따라 송수신 정책을 달리 적용하고, 필요 시 메타데이터 제거 후 전송한다.

N2SF ID	보안통제 항목 설명	
N2SF-CD-8	C S O	승인된 CDS 구성 요소만 사용
		크로스 도메인 연계를 위한 CDS는 기관이 검증하고 승인한 하드웨어/소프트웨어 구성 요소만을 사용해야 한다.
N2SF-CD-9	C S	CDS 우회 경로 탐지 및 차단
		CDS를 우회하여 다른 경로(USB, 무선, 별도 링크 등)로 도메인 간 전송을 시도하는 행위를 탐지하고 차단한다.
N2SF-CD-10	C S	전송 실패 보호 및 무결성 보장
		전송 중 실패 시 데이터가 잔존하거나 일부가 누락되지 않도록 조치하고, 수신자가 정보의 완전성과 무결성을 검증할 수 있도록 한다.
N2SF-CD-11	C S	등급 간 콘텐츠 정책 적용
		다양한 등급 간 콘텐츠 전송 시 등급 정책에 따른 필터링, 수정, 전환 작업을 수행할 수 있도록 한다.
N2SF-CD-12	C S O	사용자 및 단말 등록 기반 접근 제어
		CDS 접근을 허용할 사용자와 단말 정보를 사전에 등록하고, 정책에 기반해 인증을 수행한다.
N2SF-CD-13	C S	트래픽 흐름 컨텍스트 분석
		동일 사용자·단말의 연속적인 전송 흐름을 분석하여 비정상 컨텍스트(다량, 시간외 등)를 차단한다.
N2SF-CD-M1	C S O	CDS 운용 정책 수립
		CDS 구성, 운용, 접근, 예외 처리 절차 등을 포함한 관리 정책을 수립하고 주기적으로 갱신한다.
N2SF-CD-M2	C S O	CDS 통제 로그 기록 및 감사
		CDS를 통한 정보 흐름의 허용, 차단, 예외처리 등의 모든 활동을 로깅하고 주기적으로 감사한다.
N2SF-CD-M3	C S	도메인 간 정보 교환 승인 프로세스
		도메인 간 정보 교환은 사전 승인된 업무 목적 및 사용자에게 한정되며, 자동화된 승인 및 검토 체계를 갖추어야 한다.
N2SF-CD-M4	C S O	CDS 구성요소 무결성 검증
		CDS 시스템의 구성요소(소프트웨어, 펌웨어 등)에 대한 무결성을 정기적으로 검증하고 변경 시 승인 절차를 거친다.

구현 방법 예시

• 통신 모니터링 및 제어 기술

- 시스템 내·외부 경계에서 이루어지는 통신 흐름을 모니터링하고, 보안정책에 따라 차단 또는 허용한다. 승인되지 않은 통신이나 의심스러운 트래픽이 내부 네트워크에 영향을 주지 않도록 보장한다.
- 외부망과 내부망, 업무망과 제어망 등 네트워크 도메인 간 물리적 또는 논리적 분리를 적용하여 상호 직접적인 연결을 차단하고, 오직 CDS를 통한 승인된 경로에서만 통신이 가능하도록 한다.

• 전송 흐름 통제 및 단방향성 보장

- CDS는 정보가 저신뢰 영역에서 고신뢰 영역으로 흐르는 것을 차단하며, 고신뢰에서 저신뢰 영역으로의 전송만 허용하는 단방향 전송 장치를 적용한다.
- 모든 정보는 릴레이 서버를 통해 전송되며, 이 서버는 AV 검사, 포맷 유효성 검증, 정책 기반 승인 절차를 거쳐야만 다음 단계로 전송이 가능하다.

• 콘텐츠 검증 및 무해화 처리(CDR)

- 송수신되는 모든 파일은 콘텐츠 내 스크립트, 매크로, 숨겨진 객체 등을 제거하고, 정형화된 포맷으로 재조합하여 전송한다.
- 이 과정에서는 MIME Type, Magic Number 등을 기반으로 한 파일 유형 검증과 함께, 허용된 포맷 외의 파일은 차단되거나 격리된다.

• 메타데이터 분석 및 정책 기반 전송 제한

- 전송 대상 문서의 생성일, 작성자, 보안등급 등 메타정보를 식별하고, 조직의 정책에 따라 송수신 여부를 결정한다.
- 필요 시 보안등급을 하향 조정하거나, 메타데이터를 삭제 후 전송하는 정책도 적용 가능하다.

• 우회 경로 탐지 및 전송 차단

- CDS를 우회한 USB, 무선통신, 외부 링크 연결 등의 시도를 탐지하며, 이러한 우회 행위가 발생할 경우 즉시 관리자에게 경고하고 해당 경로를 자동으로 차단한다.
- EDR 및 NAC 연동을 통해 비인가 장비나 네트워크 연결을 통제한다.

• 전송 실패 대응 및 무결성 보장

- 정보 전송 중 실패가 발생할 경우 잔존 데이터가 남지 않도록 자동 삭제되며, 부분 전송 누락 여부를 확인하고, 필요시 자동 재전송이 수행된다.
- 이때 체크섬, 해시값 검증을 통해 수신된 정보의 무결성을 보장한다.

• 정책 수립 및 감사 로그 기록

- CDS 구성과 운영을 위한 정책은 조직 내 보안 수준 및 업무 흐름에 따라 정의되며, 예외 전송 요청이나 허용된 흐름은 모두 로그로 기록된다.
- 로그는 정기적으로 감사되며, 이상 징후 발생 시 즉시 대응이 가능해야 한다.

• 다등급 정보처리를 위한 세분화된 접근 제어 적용

- 일부 환경에서는 동일 단말 내에서 다등급 정보 접근이 요구되므로, MLS 보안 원칙을 적용한 논리적 격리 환경(예: VDI, 컨테이너, MAC 기반 OS)을 활용한다.
- 이를 통해 동일한 사용자가 서로 다른 등급의 데이터를 동시에 다루더라도 정보가 교차되지 않도록 보호한다.

• Access CDS, Transfer CDS, MLS CDS 활용

- Access CDS를 통하여 고등급 도메인의 데이터베이스 또는 웹 서비스에 대해 단방향 요청/응답 구조로 구성하며, 단말 접근은 터미널 서비스 방식 또는 프록시 서버를 통해 제한적으로 허용한다.
- 또한, 데이터 유출 방지를 위해 출력 제한(프린트/다운로드 차단) 및 화면 캡처 방지 기술 적용한다.
- Transfer CDS를 구성 시, 송수신 파일은 파일 검사 서버(Relay Server)를 거쳐야 하며, 전송 가능한 파일 포맷, 크기, 내용 등을 정책 기반으로 정의한 후, 악성코드 검사, CDR, 메타데이터 정제, 포맷 검사 후 데이터를 전송한다.
- MLS CDS를 이용하여, 동일 시스템 상에서 보안 등급을 구분해 정보 접근 제어를 수행하며, 사용자나 프로세스에 보안 레이블을 부여하고, 데이터 저장 시 등급 정보 태깅, 접근 시 적절한 보안 수준 여부를 검증한다.

항목	적용 기술 또는 방식
도메인 간 흐름 통제	릴레이 서버, 전송 흐름 정책, 다단계 보안 레이블
단방향 전송 기술 적용	Data Diode(단방향 전송 장비), 송신→수신 방향 제한
콘텐츠 검증 및 정제	CDR, 파일 정적 분석, 포맷 유효성 검사
파일 유형 및 메타데이터 검증	MIME Type 검사, Magic Number 검사, 메타정보 정책 분석 및 삭제
우회 경로 탐지 및 격리	USB/Wi-Fi/외부 링크 감시, 비인가 전송 차단, NAC/EDR 기반 자동 격리
전송 실패 대응 및 무결성 보장	전송 실패 감지, 자동 재전송, 체크섬 검증, 해시 기반 무결성 검증
CDS 정책 수립 및 감사	중앙 정책관리 서버, 전송 정책 정의, 자동화된 로그 수집 및 감사 체계
승인 프로세스 자동화	업무 목적 기반 전송 요청 시스템, 사용자별 정책 연계, 자동/반자동 승인 절차
무결성 검증 및 구성요소 보호	구성요소 무결성 검증, 펌웨어 변경 시 승인 프로세스 적용, 서명 확인

4. 원격접속 (Remote Access, RA)

정의

원격접속 환경에서의 기밀성과 무결성 강화를 위한 접속 통제 및 통신구간 암호화, 관리자·사용자의 접속 위치 및 권한 사용에 제한, 무단 정보 유출 방지 및 일정 시간 이후 세션 자동 종료와 같은 안전한 원격접속을 위한 통제항목이다.

보안통제 항목

N2SF ID	보안통제 항목 설명	
N2SF-RA-1	C S O	원격접속 모니터링 및 통제
		원격접속을 모니터링하고 통제한다.
N2SF-RA-2	C S O	원격접속 세션 암호화
		원격접속 세션의 기밀성과 무결성을 보호하기 위해 통신구간 암호화를 적용한다.
N2SF-RA-3	C S	원격접속위치통제
		보안관리 및 통제가 가능한 물리적 공간(위치) 또는 기술적 대책을 적용하여 원격접속을 허용한다.
N2SF-RA-4	— S	관리자 권한 통제
		원격접속을 통한 관리자 권한은 제한된 조건에서만 허용해야 하며, 관리자 권한으로 실행한 명령어 이력 등은 유지한다.
N2SF-RA-5	C S O	원격접속 정보 유출 방지
		원격접속에 관한 정보를 무단으로 사용하거나 외부로 유출되는 것을 방지한다.
N2SF-RA-6	C S O	원격접속 자동 종료 및 비활성화
		일정시간 경과 등 조건에 따라 원격접속을 자동 종료하거나, 원격접속 목적이 달성된 경우 비활성화한다.
N2SF-RA-7	C	원격 명령 신뢰성 검증
		명령을 수행하기 전에 적절한 인증 체계(암호화된 인증서, 보안 토큰, 또는 사용자 인증)를 적용하여 명령의 무결성과 출처를 검증한다.
N2SF-RA-M1	C S	원격접속 정책 수립 및 예외 관리
		원격접속 허용 대상, 시간, 인증수단 등에 대한 정책을 수립하고 예외 시 승인 절차를 마련한다.
N2SF-RA-M2	C S O	원격접속 로그 보존 및 감사
		원격접속 활동 기록을 수집하여 정기 감사가 가능하도록 보존한다.
N2SF-RA-M3	C S	원격접속 보안 점검 주기 운영
		원격접속 정책 이행 여부와 취약 구성 점검을 주기적으로 수행한다.

■ 구현 방법 예시

• 원격접속 모니터링 및 통제

- 원격 연결 세션은 SIEM을 통해 모든 접속 로그와 활동 이력을 실시간으로 수집하고 분석한다.
- 사용자 단말, 접속 위치(IP, GeoIP), 접속 시간, 명령어 로그 등을 저장하고 이상 징후 시 관리자에게 즉시 알람을 전송한다.

• 통신 구간 암호화 및 무결성 보장

- 원격접속은 TLS 1.2 이상 암호화 프로토콜을 적용한 SSH, HTTPS, VPN 등으로 구성하며, 강제 암호화 정책을 시스템 레벨에서 설정한다.
- 인증서 기반 양방향 인증 또는 VPN 내 세션 키 교환 방식을 통해 세션 무결성을 확보한다.

• 위치 기반 통제 및 제한

- 원격접속은 지정된 사내 IP, VPN IP 또는 특정 국가의 GeoIP로 한정하여 허용하고, 그 외 위치에서는 접속을 차단한다.
- Geo-fencing 기능이 있는 NAC 솔루션 또는 방화벽을 연계하여 허용 지역을 정책화한다.

• 권한 분리 및 계정 최소화

- 원격접속 계정은 일반 사용자와 관리자 계정으로 구분되며, 관리자 권한은 사전 승인된 명령어만 수행 가능하도록 제한한다.
- 명령 실행은 터미널 명령 제어와 sudo 제한을 병행하고, 관리자 세션은 PAM 솔루션을 통해 제어한다.

• 정보 유출 및 파일 전송 차단

- 세션 내 클립보드, 파일 업로드/다운로드 기능은 서버 측에서 비활성화하고, FTP/SCP 접속은 파일 무결성 검증 후에만 허용한다.
- DLP 솔루션과 연계하여 민감 정보 탐지 시 전송을 자동 차단하거나 관리자 승인을 요구하도록 구성한다.

• 세션 자동 종료 및 비활성화

- 장시간 비활성 상태의 세션은 시간 기반 로그아웃 정책을 적용하고, 세션 종료 후 재접속 시 다중 인증 절차를 요구한다.
- 일정 시간 이상 미사용 시 계정도 자동 비활성화하고, 특정 이벤트 발생 시 세션을 즉시 종료하는 대응 절차를 구성한다.

• 명령 무결성 및 실행 검증

- 명령 실행 시, 사전 등록된 명령어만 허용되는 명령어 필터링 시스템을 적용한다.
- 명령 실행 전 MFA, OTP, 또는 관리자 승인을 요구하여 명령의 정당성과 무결성을 보장한다.

항목	적용 기술 또는 방식
접속 모니터링 및 감사	SIEM, 접속 로그 수집, 사용자 위치/시간/행위 기반 탐지
통신 구간 암호화	TLS, SSH, HTTPS, VPN
위치 기반 통제	GeolP 기반 접근 제한, NAC 위치 정책
권한 제어 및 명령 제한	sudo 제한, 명령 화이트리스트, PAM, 관리자 계정 통제
정보 유출 방지	DLP, 클립보드 제한, 파일 전송 제어, FTP/SCP 무결성 검증
세션 자동 종료 및 비활성화	타임아웃 정책, MFA 재인증, 세션 자동 종료, 계정 자동 비활성화
명령 신뢰성 검증	명령 실행 전 MFA, OTP, 사전 등록 명령어 검증 시스템 적용

5. 세션 (Session, SN)

정의

세션 관리 및 보안은 각 세션의 고유 식별자를 할당하여 비정상 종료나 비활성 상태 시 즉시 종료하고 사용자의 요청 또는 조건에 따라 동시 세션 수 제한, 자동 세션 종료, 알람 메시지 제공 등 세션의 보안통제를 통해 비인가 사용자 무단 접근과 정보 유출을 방지하기 위한 통제항목이다.

보안통제 항목

N2SF ID	보안통제 설명
N2SF-SN-1	C S O 로그아웃 세션 처리
	로그아웃 또는 비정상 세션 종료 시 연결되었던 모든 세션의 식별자를 즉시 무효화하며, 더 이상 세션이 유효하지 않도록 한다.
N2SF-SN-2	C S O 세션별 고유 식별자
	각 사용자 세션마다 고유한 식별자를 활용하고, 고유한 식별자의 재사용을 방지한다.
N2SF-SN-3	C 동시 접속 세션 제한
	사용자 계정 또는 정보시스템 등을 기준으로 동시 세션 수를 제한한다.
N2SF-SN-4	C S O 세션 종료
	세션 종료 요청이 있거나 세션 종료 조건 발생 시 자동으로 세션을 종료한다.

N2SF ID	보안통제 설명	
N2SF-SN-4(1)	C S O	사용자 기반 로그아웃
		사용자 요청에 따라 로그아웃 할 수 있는 기능을 제공한다.
N2SF-SN-4(2)	C S O	종료 메시지
		사용자에게 종료되었다는 메시지를 표시한다.
N2SF-SN-5	C S	로그인 유효시간 경과 경고 메시지
		사용자에게 로그인 유효시간 경고 메시지를 표시한다.
N2SF-SN-6	C S O	네트워크 연결 해제
		정상 세션 종료 또는 일정 시간 비활성 상태가 유지될 경우 네트워크 연결을 자동 해제한다.
N2SF-SN-7	C	세션 중 행위 기반 비정상 탐지
		세션 중 사용자 행위가 정상 범위를 벗어나면 자동으로 세션을 종료하거나 별도 인증 절차를 유도한다. (예: 위치 급변, 동시접속 이상 등)
N2SF-SN-8	C S	세션 중 연속 인증 수행
		장시간 세션 또는 민감 작업 수행 시, 주기적 또는 조건 기반으로 인증수단(MFA 등)을 다시 요구한다.
N2SF-SN-M1	C S	세션 관리 정책 수립
		세션 유지 시간, 비활성화 조건, 동시 접속 허용 수 등 세션 운용 정책을 수립하고 문서화한다
N2SF-SN-M2	C S O	세션 감사 및 로그 기록
		세션 생성, 종료, 중복, 충돌 등 관련 활동을 로깅하고 보안 감사가 가능하도록 구성한다.

구현 방법 예시

• 로그아웃 및 세션 무효화 처리

- 사용자 로그아웃 시 관련 세션 식별자(Session ID, Token 등)를 서버 측에서 즉시 무효화하고 재사용을 차단한다.
- JWT 기반 인증의 경우, 서버에서 토큰 블랙리스트를 관리하거나 access/refresh 토큰 주기를 분리하여 대응한다.
- 예기치 않은 접속 종료 시에는 세션 타임아웃 설정을 통해 남은 세션을 자동 종료한다.

• 사용자 세션 고유 식별자 활용 기술

- 각 세션은 고유한 식별자(UUID, Secure Random Token 등)를 통해 구분하며, 세션 시작 시 생성하여 중복되지 않도록 한다.
- 동일 식별자의 반복 사용을 방지하기 위해 서버에서 재사용 감지 로직을 추가한다.

• 동시 세션 수 제한 기술

- 사용자 계정 기준으로 동시 접속 세션 수를 제한하고, 초과 시 기존 세션 종료 또는 추가 접속 차단 정책을 설정한다.
- 관리자 또는 고위험 권한 계정은 단일 세션만 허용하도록 구성하며, 세션 충돌 발생 시 알림을 제공한다.

• 세션 종료 및 알림 메시지 표시

- 사용자가 수동으로 세션을 종료할 수 있는 로그아웃 버튼을 제공하며, 일정 시간 이상 비활성 시 자동으로 세션을 종료한다.
- HTTP Keep-Alive와 관계없이 세션은 독립적으로 타임아웃되도록 설계하며, 정책 기반으로 종료 시점을 관리한다.
- 네트워크 접속이 유지되더라도 세션 유지 조건이 충족되지 않으면 세션을 종료하고 접속을 해제한다.

• 로그아웃 기능

- 사용자에게 세션 종료 또는 유효시간 임박에 대한 경고 메시지를 사전에 출력하여 예기치 않은 종료를 방지한다.
- GUI, CLI 환경 모두에서 메시지를 제공하고, 재연장 또는 저장 기능을 제공하지 않는 보안 모드를 적용한다.

항목	적용 기술 또는 방식
세션 무효화 처리	로그아웃 시 서버 세션 삭제, 토큰 블랙리스트, 타임아웃 설정, refresh-token 분리
고유 식별자 관리	UUID, Secure Token
동시 접속 제한	계정별 동시 세션 제한, 관리자 단일 세션 정책, 세션 충돌 탐지
세션 종료 제어	사용자 로그아웃 버튼 제공, 자동 타임아웃, HTTP Keep-Alive 무관 세션 제어
세션 종료 알림	종료 메시지, 유효시간 경고, 사전 안내 팝업, 보안 모드 메시지 출력
네트워크 연결 해제	비활성 상태 시 세션 종료와 함께 네트워크 연결 해제, 보안망 전환 시 세션 리셋

6. 무선망 접속 (Wireless Network Access, WA)

정의

무선 통신망 보안은 사용자 및 기기 인증, 통신 구간 암호화, 송수신 출력 제어, 승인되지 않은 무선망 차단, 그리고 외부인 전용 무선망 분리 및 무선망 관리 기능 보호를 통해 무선망의 기밀성과 무결성을 유지하는 통제항목이다.

보안통제 항목

N2SF ID	보안통제 설명	
N2SF-WA-1	C S O	업무용 무선망 인증 및 암호화
	사용자 인증, 기기(단말 등) 인증 및 무선통신 구간 암호화를 적용한다.	
N2SF-WA-2	C S O	업무용 무선망 인증정보 보호
	업무용 무선 통신망 서비스 식별 정보(SSID 등)를 경계지역 외부에서 확인할 수 없도록 적용하고, 무선 통신망 인증정보의 무단 사용 및 외부 유출을 방지한다.	
N2SF-WA-3	C	업무용 무선망 신호 보호
	무선 통신환경에 적합한 안테나를 선택하고 송수신 출력을 교신에 필요한 최저 출력으로 유지하여 경계지역 외부로 전파되는 것을 방지한다.	
N2SF-WA-4	C S O	비인가 무선장비 설치 차단
	업무용 무선망 서비스에 비인가 무선장비가 설치되거나 가동되는 것을 탐지하고 운용되지 않도록 한다.	
N2SF-WA-5	— S O	외부인 전용 무선망 구성
	업무용 네트워크 또는 무선망과 분리하여 외부인 전용망을 구성한다.	
N2SF-WA-6	C S O	무선망 관리기능 보호
	무선망 관리기능은 무선망에 노출되지 않아야 하며, 지정된 관리자만 접속되도록 통제한다.	
N2SF-WA-7	C S O	비인가 무선망 접속 차단
	인가되지 않은 무선망 접속을 차단한다.	
N2SF-WA-M1	C S	무선망 세션/로그 분석
	무선 접속 로그와 세션 데이터를 통해 이상행위를 분석한다.	

■ 구현 방법 예시

• 무선망 인증 및 암호화 적용

- 무선랜 접속 시 IEEE 802.1X 기반 인증 방식을 도입하고, 인증 서버(RADIUS 또는 EAP-TLS)를 연동하여 사용자 및 단말 인증을 수행한다.
- WPA3 또는 WPA2-Enterprise 수준의 무선 보안 프로토콜을 적용하고, 통신 구간은 AES 기반 암호화로 보호한다.
- 무선 접속에 실패한 단말은 게스트 망으로 격리하거나 접속 자체를 차단한다.

• SSID 및 인증정보 보호

- SSID는 숨김 모드로 운영하고, 인증정보(사전 공유 키, 접속 토큰 등)는 별도 보안 채널을 통해 배포한다.
- 무선 인증정보가 단말에 저장되는 경우에는 TPM 기반 암호화를 적용하고, 사용자 로그아웃 시 자동 삭제 기능을 활성화한다.
- SSID 브로드캐스팅은 업무망과 구분된 VLAN에서만 제한적으로 허용한다.

• 무선 신호 보호 및 출력 제어

- 무선 AP 장비는 물리적 경계 내 설치하며, 신호 출력 범위를 조정해 외부 유출을 최소화한다.
- 신호 감쇄 필름, 안테나 패턴 조절, 저출력 모드 등의 기술을 활용해 건물 외부로의 신호 확산을 통제한다.
- RF 탐지 솔루션을 사용하여 의도하지 않은 신호 확산 또는 무단 AP를 감지한다.

• 비인가 무선장비 탐지 및 차단

- 무선 침입 차단 시스템(WIPS)을 도입하여 Rogue AP, Soft AP, 모바일 핫스팟 등 비인가 장비의 접속 시도를 차단한다.
- 주기적으로 무선 주파수 대역을 스캔하고, 탐지된 장비는 네트워크 접근 차단 및 관리자에게 알림을 제공한다.
- 특정 장비 MAC 또는 제조사 식별자 기반으로 허용/차단 리스트를 구성한다.

• 업무망과 외부망의 분리 운영

- 업무용 무선망과 외부 방문자용 무선망은 별도 SSID 및 VLAN으로 구분하여 구성하며, 방화벽과 ACL로 흐름을 통제한다.
- 외부망에서 내부 시스템으로의 접근은 VPN 또는 게이트웨이 기반 인증 절차를 통과해야만 허용한다.

- NAT와 DHCP 범위도 분리하여, IP 충돌 및 혼용을 방지한다.

• 무선망 관리기능의 보안 보호

- 무선 컨트롤러나 AP의 관리 인터페이스는 내부망 또는 전용 관리망에서만 접근 가능하도록 구성한다.
- 관리자 인증은 다중요소 인증(MFA)로 구성하고, 접속 시 관리자 행위는 모두 감사 로그로 기록한다.
- 무선망 설정 변경 시 승인 프로세스를 도입하여 비인가 변경을 방지한다.

항목	적용 기술 또는 방식
무선 인증 및 암호화	WPA3, WPA2-Enterprise, IEEE 802.1X, RADIUS, EAP-TLS, AES 통신 암호화
SSID 및 인증정보 보호	SSID 숨김, 사전 공유 키 보호, TPM 기반 인증정보 저장, 자동 삭제
신호 출력 통제	AP 저출력 설정, RF 감쇄 필름, 패턴 안테나, 신호 확산 제한
비인가 장비 차단	WIPS, Rogue AP 탐지, MAC 기반 허용/차단 리스트
무선망 분리 및 경계 보호	SSID/VLAN 분리, ACL 설정, NAT/DHCP 영역 분리, 내부망/VPN 이중 절차 적용
무선망 관리기능 보호	관리망 분리, 변경 승인 프로세스, 감사 로그 기록

7. 블루투스 연결 (Bluetooth Connection, BC)

정의

정보시스템에서 블루투스 사용 시 키보드, 마우스와 같이 사용자 입력을 위한 HID(Human Interface Device) 프로파일과 데이터 전송을 위한 FTP(File Transfer Profile) 기반으로 동작하는 통신을 구분하여 정보유출 위험이 발생할 수 있는 데이터 통신을 제한하는 통제항목이다.

보안통제 항목

N2SF ID	보안통제 설명	
N2SF-BC-1	 	블루투스 데이터 통신 제한
		블루투스 장치 연결 시 키보드, 마우스, 오디오 등을 위한 입출력 기능 외 데이터 통신은 차단한다.

■ 구현 방법 예시

• 블루투스 장치 연결 통제 정책 적용

- 운영체제의 그룹 정책 또는 모바일 디바이스 관리 시스템을 활용하여 블루투스 기능 자체를 비활성화하거나 연결 가능한 장치 종류를 제한한다.
- 허용된 블루투스 장치 목록을 사전 정의하고, 해당 목록 외 장치에 대해 자동 차단 또는 사용자 경고 메시지를 출력한다.
- Windows에서는 GPO(로컬 그룹 정책), macOS는 Jamf 같은 솔루션에서 Bluetooth PAN, HID 프로파일만 허용 설정이 가능하다.

• 블루투스 기능별 사용 권한 분리

- 오디오, 입력장치(HID)와 같이 업무상 허용 가능한 블루투스 기능만 사용할 수 있도록 제한하고, 파일 송수신, 테더링(PAN), 위치 공유 등은 차단한다.
- Linux 기반 시스템에서는 bluetoothctl과 rfkill 명령어를 활용해 전송 프로파일을 수동 또는 자동 제어한다.
- 블루투스 관련 드라이버 로딩을 제어하여 불필요한 커널 모듈의 활성화를 방지한다.

• 블루투스 통신 흐름 제어 및 로깅

- 엔드포인트 보안 솔루션 또는 EDR을 통해 블루투스 장치 연결 및 통신 기록을 수집하고, 관리자에게 알림 또는 통계를 제공한다.
- 의심 장치가 연결되었거나 예상 외의 파일 송수신이 탐지되면 자동으로 차단하거나 연결을 해제하도록 구성한다.
- 블루투스 MAC 주소 기반 화이트리스트/블랙리스트 기능을 적용하여 장치 수준의 제어를 강화한다.

항목	적용 기술 또는 방식
기능 사용 제한	MDM, 블루투스 기능 비활성화, 연결 가능 장치 제한 설정
기능별 권한 분리	프로파일(HID, A2DP 등) 제어, rfkill, bluetoothctl
통신 흐름 제어 및 로깅	EDR, 장치 연결 기록 수집, MAC 화이트리스트/블랙리스트, 의심 연결 차단 자동화

제5장

데이터

1. 암호 키 관리 (Encryption Key Management, EK)

정의

암호 키 관리는 암호 키의 생성, 배포, 저장, 사용 및 폐기 등 키의 전체 수명 주기를 안전하게 관리하기 위한 프로세스로 키의 무단 접근과 오용을 방지하고, 데이터 기밀성과 무결성을 유지하기 위한 통제항목이다.

보안통제 항목

N2SF ID	보안통제 설명	
N2SF-EK-1	C S O	암호 키 설정
	데이터 저장을 위해 암호 키를 생성하는 경우, 유형별 암호 키(대칭 키, 공개 키 등) 및 인증서를 키 관리 시스템(KMS)을 활용할 수 있다. 암호 키를 설정 시 C/S/O 보안등급별 암호화 강도, 암호 알고리즘(국산 암호, 국제표준암호 등), 암호 키 유효기간 및 갱신, 암호 키와 서명용 키 분리, CRL(인증서 폐기 목록) 생성 주기 및 배포 경로 등을 설정 한다.	
N2SF-EK-2	C S	암호 키 생성
	KCMVP(Korea Cryptographic Module Validation Program) 인증을 받은 난수 발생기 또는 암호 모듈을 사용하며, 데이터의 보안 등급에 따라 소프트웨어 기반 TRNG(True Random Number Generator) 또는 하드웨어 기반 난수발생기를 사용한다.	
N2SF-EK-3	C S O	암호 키 저장
	암호 키는 암호화된 형태로 저장하거나 보안성이 요구되는 경우 보안 토큰 등을 사용하여 분리 보관한다.	
N2SF-EK-4	C S	암호 키 사용
	데이터 저장 규모 및 성능에 따라 암호화된 데이터베이스 또는 하드웨어 보안 모듈(HSM: Hardware Security Module)을 활용하여 암호 키를 사용한다. 클라우드 환경에서 암호키를 안전하게 저장, 사용하기 위해 HSM을 활용할 수 있다.	

N2SF ID	보안통제 설명	
N2SF-EK-5	C S O	암호 키 폐기
	암호키는 복구 불가능한 상태로 안전하게 삭제하고 동일 암호 키가 재생성 및 재사용되지 않도록 조치한다. 그리고 CRL(인증서 폐기 목록)을 관리해야 한다.	
N2SF-EK-6	C S O	전자서명 검증
	데이터의 전송 및 저장 시 데이터 무결성 확인 및 암호화를 통한 데이터 보호를 위해 전자서명 생성 및 검증 키 관리, 표준화된 서명 검증 알고리즘과 서명용 인증서 관리, 전자서명 검증 기술을 적용한다.	
N2SF-EK-M1	C S	암호 키 저장소 관리
	암호 키 저장소는 접근권한이 인가된 사용자로 제한되며, 물리적·논리적으로 분리하여 보호해야 한다. 저장소 접근 로그는 감사 목적으로 기록·관리되어야 한다.	
N2SF-EK-M2	C S	암호 키 관리 정책 및 절차
	암호 키의 생성, 저장, 사용, 폐기 등 키 생명주기 전반에 걸쳐 관리정책 및 절차를 문서화하고, 주기적으로 검토하여 최신화해야 한다.	
N2SF-EK-M3	C S	키 접근 권한 및 감사 관리
	암호 키에 대한 접근 권한은 최소 권한 원칙에 따라 관리하며, 키 접근 및 사용에 관한 모든 이벤트는 감사 로그로 기록하고 정기적으로 검토해야 한다.	

■ 구현 방법 예시

• 암호 키 관리 기술

- 암호 키는 키 관리 시스템(KMS)을 통해 안전하게 생성, 저장, 배포할 수 있다. 암호키와 서명용 키는 분리하여 관리해야 한다.
- 인증서 기반 시스템 또는 키 관리 시스템(KMS)을 통해 대칭·비대칭 키를 생성하고, 키 용도, 길이, 알고리즘(AES, RSA 등), 키 수명 등을 명시한다.
- 암호 키에 대한 생성 시점, 생성자, 키 유형, 사용 정책을 메타데이터와 함께 등록하고 주기적 검토를 수행한다.
- 난수 기반 키 생성은 KCMVP 인증 난수 생성기 또는 TRNG/DRBG를 사용하여 보안성을 확보한다.
- 국산 인증 알고리즘 또는 국제표준 암호 알고리즘(AES 등)을 사용한다.
- 암호 키를 HSM에 저장하거나, 보안 토큰(USB) 등을 사용해 분리 보관하여 관리한다.

• 암호 키 저장 및 보호 체계 적용

- 암호 키는 파일 시스템에 평문 저장하지 않고, HSM, 보안 토큰 또는 암호화 저장소에 저장한다.
- 저장소 접근은 IP 제한, 인증, 접근 통제 정책을 설정하고, 저장소 접근 로그는 SIEM 연계로 중앙 관리한다.

- 암호 키 저장 시 AES-GCM, RSA-OAEP 등의 안전한 포맷으로 암호화하며, 키 백업은 별도 보안 절차로 관리한다.
- TPM(Trusted Platform Module)에 암호 키를 저장하여 물리적 보안을 수행한다.

• 키 접근 제어 및 감사 체계

- 키 사용은 최소 권한 원칙에 따라 역할 기반(RBAC)으로 통제하며, 접근 요청은 승인 워크플로우를 통해 처리한다.
- 모든 키 접근 및 사용 내역은 로그로 기록되며, 주기적으로 감사하여 이상 징후를 탐지한다.
- 암호화 키를 여러 부분으로 분할하여 각 부분을 다른 물리적 위치에 저장하여 한 곳에서 키가 탈취 되더라도 전체 키를 얻지 못하게 한다.
- 키 수명 만료, 폐기 요청 시 복구 불가능한 방식으로 제거하며, CRL(Certificate Revocation List)을 유지 관리한다.

• 전자서명 및 검증 기능 구성

- 데이터 무결성 확인을 위해 전자서명 알고리즘을 적용하고, 표준 인증서 형식을 사용한다.
- 전자서명 검증 시 서명 키와 검증 키의 유효성, 만료 여부, 서명자 정보 등을 포함하여 검증한다.
- 서명된 메시지 또는 문서는 원본 변경 방지를 위한 검증 API를 통해 처리한다.

항목	적용 기술 또는 방식
암호 키 생성 및 속성 관리	KMS, RSA, AES, ECC, 키 정책 메타데이터 설정, KCMVP 난수 생성기
암호 키 저장 방식	HSM, 보안 토큰, 파일 암호화 저장소, AES-GCM, RSA-OAEP
키 접근 제어 및 감사	RBAC, 승인 기반 접근제어, 접근 로그 수집, SIEM 연계 감사
암호 키 폐기 관리	Secure Erase, CRL 관리, 키 수명 정책 적용
전자서명 생성 및 검증	SHA with RSA, ECDSA, 인증서 유효성 검증, 전자서명 API

2. 암호 모듈 사용 (Encryption Technology Application, EA)

■ 정의

암호기술을 사용할 경우 보안등급과 용도에 따라 국가정보원장이 인증한 검증필 암호모듈 및 국가용 암호자재·장비를 사용하거나 특수목적용 암호자재·장비의 선택적 사용에 대한 통제항목이다.

■ 보안통제 항목

N2SF ID	보안통제 설명	
N2SF-EA-1	C S O	검증필 암호모듈 사용
	국가정보원장이 안전성을 확인한 상용 암호모듈(검증필 암호모듈)을 사용한다.	
N2SF-EA-2	C	국가용 암호자재 및 장비 사용
	국가정보원장이 개발하거나 안전성을 확인한 암호자재 또는 암호장비 등을 사용한다.	
N2SF-EA-3	C S	특수목적용 외국산 암호자재 및 장비 사용
	외국기관 또는 외국군 등 특수목적 통신을 위해 외국산 암호자재 및 장비를 사용한다.	

■ 구현 방법 예시

• 검증필 암호모듈 적용

- 암호 알고리즘은 KCMVP 인증을 받은 검증필 암호모듈을 사용하여 안전성을 확보한다.
- 주요 사용 알고리즘은 ARIA, SEED 등 국내 표준 암호 및 AES-256 등 사용 가능한 알고리즘으로 구성한다.
- 암호모듈은 라이브러리(API) 형태로 서비스에 내장하거나, 인증서 기반 연계 시스템과 통합 구축한다.

• 국가용 암호자재 및 장비 사용

- 국정원에서 안전성을 인정한 암호장비(예: 국산 VPN, 전자서명장비, 인증 서버 등)를 적용한다.
- 내부망, 업무망 등에서 암호화 통신 구간 설정 시 국산 암호 프로토콜(KTLS, 국산 IPsec 등)을 통해 데이터 전송을 보호한다.
- 국가용 암호자재는 HSM 또는 키 관리 서버와 연계하여 물리적 보안성과 인증성을 보장한다.

• 특수목적 외국산 암호기술 제한적 사용

- 외국과의 통신이 불가피한 경우, TLS, IPsec, S/MIME 등의 국제 표준 암호기술은 통제된 환경에서만 사용한다.
- 해당 장비와 알고리즘의 인증 상태를 확인한 후 허용 여부를 결정한다.
- 외국산 암호 기술은 전용 네트워크 또는 게이트웨이 내부에서만 적용되도록 설계하며, 주요 키와 데이터를 별도 격리 저장한다.

항목	적용 기술 또는 방식
검증필 암호모듈 사용	KCMVP 인증 모듈, ARIA, SEED 등 검증필 라이브러리 연계
국가용 암호자재 및 장비 적용	국산 VPN, 국산 인증서 시스템, 국산 IPsec/KTLS, 국산 전자서명장비, 키 서버 연동
외국산 암호기술 제한 사용	TLS, S/MIME, 게이트웨이 격리, 접근 통제 기반 환경 설정

3. 데이터 전송 (Data Transmission, DT)

정의

데이터 전송은 시스템 간 데이터 및 정보를 안전하게 전송하기 위한 보안 요구사항을 명확히 하고, 이를 관리하는 절차를 포함한다. 이를 통해 전송 중인 정보가 허가되지 않은 사람이나 시스템에 의해 읽히거나 변경, 손상되지 않도록 전송 기밀성과 전송 무결성을 보호하기 위한 통제항목이다.

보안통제 항목

N2SF ID	보안통제 설명	
N2SF-DT-1	C S	전송 권한 확인
	데이터가 전송되기 전에 이를 처리하는 개인이나 정보시스템이 적절한 권한을 보유하고 있는지 확인한다.	
N2SF-DT-2	C S	정보교환 중단
	정보교환 대상 정보시스템 등에 대한 식별 및 통제가 확인되지 않을 경우 정보교환을 중단한다.	
N2SF-DT-3	C S	전송간 암호화 적용
	물리적 보안수단에 의해 전송 간 보호되지 않는 경우 전송 구간에 대한 암호기술을 적용한다.	
N2SF-DT-4	C S	메시지 외부 암호화 보호
	메시지 외부정보를 보호하기 위한 암호기술을 적용한다.	
N2SF-DT-5	C	통신 패턴 은폐 또는 무작위화
	통신패턴을 숨기거나 무작위화하는 암호기술을 적용한다.	
N2SF-DT-6	C S	데이터 전송 간 위변조 검증
	전송 중 데이터에 대한 위변조 여부를 탐지하기 위해 무결성 검증(해시, 디지털 서명 등)을 수행하며, 이상 징후 발생 시 즉시 경고 및 대응할 수 있는 절차를 수립하여 운영한다.	

■ 구현 방법 예시

• 전송 권한 검증 및 사용자 식별

- 데이터 전송 요청 시 해당 사용자의 인증 상태 및 권한을 검증하고, 시스템 또는 API 호출 권한이 부여된 대상에 한해 전송을 허용한다.
- API Gateway나 프록시 서버에서 인증 토큰(JWT, OAuth2) 기반의 접근 제어 정책을 연동하여 전송 자격을 검증한다.
- 비인가 사용자 또는 시스템에 대한 요청은 자동 차단하며, 로그를 통해 감사 기록을 유지한다.

• 전송 대상에 대한 정보교환 중단 정책

- 수신 대상 시스템 또는 외부 연계 서버의 식별자 및 무결성 검증 실패 시 전송을 중단한다.
- TLS 핸드셰이크 오류, 인증서 유효성 검증 실패, 목적지 IP 또는 FQDN 변경 등이 발생하면 즉시 전송 세션을 종료한다.
- 중요 정보 전송 시 대상 시스템의 디지털 인증서 또는 인증 해시값을 매칭하여 상대 신뢰성을 확보한다.

• 전송 구간 암호화 적용

- 물리적으로 보호되지 않은 구간(인터넷, 무선망 등)에서는 TLS, IPsec, HTTPS, VPN 기반 암호 채널을 적용한다.
- 민감 데이터에 대해서는 애플리케이션 수준의 end-to-end 암호화(예: AES, GCM 모드)를 병행하여 이중 암호화를 구성한다.
- 사용자가 데이터를 전송하기 전 암호화 여부를 자동 확인하도록 전송 트리거에 검증 로직을 삽입한다.

• 메시지 외부 암호화 및 콘텐츠 보호

- JSON, XML, 파일 형태의 메시지는 전송 전에 암호화한 후, 전체 메시지를 전송 채널(TLS 등)로 감싼다.
- 외부 공개 메시지에는 데이터 마스킹, 익명화(토큰화), 서명 검증을 적용하여 노출 위험을 최소화한다.
- 이메일, SMS 전송 시에도 암호화 표준(PGP, S/MIME 등)을 도입해 메시지 본문을 보호한다.

• 통신 패턴 은폐 및 무작위화

- 트래픽 분석을 우회하기 위해 고정된 메시지 크기와 전송 주기를 무작위화한다.
- Dummy 트래픽, Padding, 시간 지연(Random Delay) 등을 삽입하여 분석 회피를 수행한다.

• 전송 중 위변조 탐지 및 무결성 검증

- 데이터 전송 시 디지털 서명, HMAC, 체크섬 등을 통해 무결성을 검증한다.
- IDS/IPS, TLS 프록시, DPI(Deep Packet Inspection) 장비를 통해 위변조 탐지 기능을 추가한다.
- 이상 징후 발견 시, 자동으로 경고 알림을 생성하고 차단/세션 종료를 수행하는 대응 정책을 자동화한다.

항목	적용 기술 또는 방식
전송 권한 확인	API 인증 토큰, JWT/OAuth2.0, 접근 제어 프록시, 전송 자격 검증
정보교환 중단 기준 설정	인증서 검증 실패 차단, TLS 오류 감지, 신뢰 검증 해시 비교
전송 구간 암호화	TLS, IPsec, HTTPS, VPN
메시지 외부 보호	메시지 본문 암호화, 마스킹, 토큰화, 전송 채널 이중 보호
통신 은폐 및 무작위화	Dummy 트래픽, Padding, 랜덤 지연, 시간 분산 전송
위변조 탐지 및 무결성 검증	디지털 서명, HMAC, DPI, TLS 프록시

4. 데이터 사용 (Data Usage, DU)

정의

데이터 사용은 검색, 연산 또는 기타 데이터 처리 활동과 같이 데이터가 정보시스템 내부에서 사용되는 동안에도 데이터에 대한 보호조치를 구현하는 통제항목이다.

보안통제 항목

N2SF ID	보안통제 설명	
N2SF-DU-1		오프라인 저장
	중요 정보를 안전한 장소에 오프라인으로 보관하여 네트워크를 통한 무단 접근을 방지한다.	
N2SF-DU-2	  	데이터 암호화 저장
	데이터 대상 암호기술을 적용하여 기밀성을 보장한다.	
N2SF-DU-3		사용중 데이터 보호
	검색, 연산, 분석 등 데이터 사용 과정에서 정보시스템 내 데이터를 보호하는 기술을 적용한다.	
N2SF-DU-4	 	데이터 갱신 및 삭제
	필요 시 데이터를 갱신하거나 생성하여 사용하고, 필요 목적이 종료되면 데이터는 삭제한다.	

N2SF ID	보안통제 설명	
N2SF-DU-M1	C S	데이터 접근 제어
	데이터 접근은 사용자 역할과 권한에 따라 최소한으로 제한하고, 접근 권한은 주기적으로 검토·승인해야 한다.	
N2SF-DU-M2	C S	데이터 사용 모니터링
	주요 데이터에 대한 사용 이력을 감사 로그로 기록하여 모니터링하고, 이상 징후 발생 시 즉각 보고 및 대응한다.	
N2SF-DU-M3	C S	데이터 사용 정책 수립
	데이터의 사용 목적, 접근 권한, 보존 기간, 폐기 절차 등을 포함하는 데이터 사용 정책을 문서화하고 전사적으로 적용 및 관리한다.	
N2SF-DU-M4	C S	데이터 저장 무결성
	저장된 데이터에 대한 위변조 여부를 탐지하기 위해 무결성 검증(해시, 디지털 서명 등)을 수행하며, 이상 징후 발생 시 즉시 경고 및 대응할 수 있는 절차를 수립하여 운영한다.	

구현 방법 예시

• 오프라인 저장 기반 중요 데이터 보호

- 민감 정보 또는 핵심 데이터는 외부 연결이 불가능한 오프라인 저장소, 암호화된 외장 장치 등에 저장한다.
- 저장 장치는 물리적 보안이 적용된 공간에 위치시키고, 접근 권한은 지정된 관리자에 한해 제한한다.
- 자동 백업은 오프라인 스토리지에 저장되며, 저장 후 접근 로그를 남긴다.

• 저장 데이터 암호화

- 모든 저장 데이터는 암호화하여 보관하며, AES-256, ARIA 등 검증된 알고리즘을 사용한다.
- 파일 단위 암호화는 DRM 또는 파일 시스템 암호화를 적용하며, DB는 TDE를 구성한다.
- 키 관리는 중앙 KMS를 통해 분리하며, 키 접근 권한은 독립된 인증 절차를 거친 사용자만 허용한다.

• 사용자 활동 기반 데이터 보호

- 검색, 조회, 출력, 분석 등 데이터 활용 시 정보의 노출을 방지하기 위해 DLP를 적용한다.
- 민감정보 조회 시 워터마크 삽입, 화면 캡처 방지, 출력 제한 등 사용 통제를 적용한다.
- 분석 시스템에서는 개인정보 비식별화 또는 마스킹 처리 후 활용하도록 정책화한다.

• 데이터 생성 및 삭제 정책

- 파일 또는 레코드 생성 시 메타정보(생성자, 생성일, 목적 등)를 기록하고, 정책에 따라 수명 주기

관리를 수행한다.

- 불필요한 데이터는 자동 삭제 스케줄러 또는 만료 정책에 따라 주기적으로 삭제되며, 삭제 시는 완전 삭제(Wipe 기술)를 적용한다.

• 데이터 접근 제어

- RBAC, ABAC 기반으로 사용자 역할 및 속성에 따른 접근 권한을 설정하고, 모든 접근은 로그로 남긴다.
- 접근 권한은 정기적으로 검토되며, 퇴직자나 역할 변경자는 자동으로 권한 회수된다.
- 중요 데이터는 MFA를 통한 접근 인증 절차를 추가 적용한다.

• 데이터 사용 모니터링 및 이상 행위 탐지

- 데이터 접근 및 사용 패턴은 UEBA를 통해 분석하고, 이상 행위는 실시간 탐지된다.
- 로그는 중앙 SIEM에서 분석되며, 설정된 임계값 초과 시 관리자에게 경고 및 자동 대응이 이뤄진다.
- 출력, 다운로드, 복사, 이동 등 사용 행위는 상세 감사 로그로 저장된다.

• 데이터 사용 정책 수립 및 적용

- 데이터 목적, 범위, 접근권한, 보존기한, 활용부서 등을 포함한 데이터 사용 정책은 DUA(Data Usage Agreement)로 수립·시행된다.
- 정책은 사용자 단위로 전자서명 수령 후 적용되며, 변경 시 이력 및 버전관리를 통해 추적 가능하다.

• 저장 데이터 무결성 검증

- 저장된 파일, DB, 로그 등 주요 데이터는 해시, 디지털 서명, MAC 등을 통해 무결성을 주기적으로 점검한다.
- 이상 탐지 시 백업으로 복구하거나 해당 데이터 사용을 일시 중단하고 관리자 승인 후에만 재활성화한다.
- 감사 시점과 점검 시점은 스케줄링되어 있으며, 탐지 결과는 보고서로 생성되어 보관된다.

• 사용 중 데이터 마스킹 적용

- 민감 정보가 포함된 데이터는 검색, 조회, 출력 시 실시간으로 마스킹 처리되도록 한다.
- 마스킹 방식은 고정 마스킹(Fixed), 부분 마스킹(Partial), 셔플링(Shuffling), 랜덤값 치환(Randomization) 등으로 설정하며, 데이터 유형별로 다르게 적용한다.
- 사용자 권한에 따라 마스킹 해제 여부를 통제하고, 마스킹 해제 이력은 로그로 남긴다.

• 신뢰 실행 환경(TEE) 기반 데이터 보호

- 암호화된 상태에서 연산이 필요한 데이터는 TEE(예: Intel SGX, ARM TrustZone 등)를 활용해 메모리 내에서 보호된 상태로 처리한다.
- 클라우드 환경에서는 Confidential VM, Confidential Container를 활용해 실행 중 데이터 보호가 가능하도록 한다.

항목	적용 기술 또는 방식
오프라인 저장	오프라인 저장소, 외장 암호화 저장장치, 물리적 접근 제한
저장 데이터 암호화	파일 암호화, DRM, KMS 기반 키 관리
사용자 활동 보호	DLP, 워터마크, 화면 캡처 방지, 비식별화 처리, 출력 통제
생성·삭제 및 수명 관리	메타정보 기록, 수명 주기 정책, 완전 삭제(Wipe) 적용
접근 통제 정책	RBAC/ABAC, MFA, 권한 회수 자동화, 로그 기록
이상 행위 탐지	UEBA, SIEM, 임계치 기반 탐지, 감사 로그
정책 수립 및 추적	DUA, 정책 전자서명, 버전관리, 사용자별 정책 이력
저장 무결성 검증	해시, 디지털 서명, MAC
데이터 마스킹 처리	고정/부분 마스킹, 셔플링, 마스킹 API, 권한별 마스킹 해제 제한
신뢰 실행 환경 보호	Intel SGX, ARM TrustZone, Confidential VM/Container, 보호된 메모리 연산

제6장

정보자산

1. 모바일 단말 (Mobile Device, MD)

정의

모바일 단말은 시스템에서 허용 및 금지할 모바일 코드와 모바일 코드 기술을 정의하고 허용할 모바일 코드와 모바일 코드 기술의 사용 제한 사항과 구현 가이드를 수립하여 내부 혹은 외부에서 모바일 단말의 사용 인가, 모니터링을 위한 통제항목이다.

보안통제 항목

N2SF ID	보안통제 설명	
N2SF-MD-1	C S O	모바일 코드 다운로드 및 실행 금지
		허용되지 않은 모바일 코드 다운로드 및 실행을 금지한다.
N2SF-MD-2	C S	자동 실행 금지
		응용프로그램에서 모바일 코드의 자동 실행을 방지한다.
N2SF-MD-3	C S	제한된 환경에서의 실행
		모바일 코드를 제한된 환경(가상머신 등)에서만 실행하도록 제한한다.
N2SF-MD-4	C S	민감정보 소통 제한
		민감정보를 처리·저장·전송하는 경우 보안요건에 따른 기술적 조치가 적용되지 않은 일반적인 모바일 장비 사용을 제한한다.
N2SF-MD-5	C S	모바일 장치 암호화 기술
		모바일 장비 저장공간 암호화 또는 컨테이너 기반 저장공간 분리 및 암호화를 적용한다.
N2SF-MD-6	C S	데이터 자동삭제 또는 초기화
		특정 상황 또는 조건에 따라 단말 내부에 저장된 데이터를 자동 삭제하거나 초기화한다.
N2SF-MD-7	C S O	탈옥·루팅 탐지 및 차단
		특정 상황 또는 조건에 따라 단말 내부에 저장된 데이터를 자동 삭제하거나 초기화한다.

N2SF ID	보안통제 설명	
N2SF-MD-8	C S	블루투스·USB 제어 설정 모바일 장치 암호화 기술
		블루투스, USB 등 외부 입출력 통신 기능을 제어하고 정책에 따라 허용한다.
N2SF-MD-9	C S	비인가 앱 탐지 및 차단
		관리자가 승인하지 않은 앱이 설치되거나 실행되면 알림 및 차단한다.
N2SF-MD-10	C S	위치 기반 보안 정책
		단말의 물리적 위치(GPS)에 따라 특정 앱 실행 또는 네트워크 접근을 제한한다.
N2SF-MD-11	C	네트워크 접근 제어
		단말이 안전하지 않은 네트워크(예: 공용 Wi-Fi)에 연결될 경우 경고 또는 차단한다.
N2SF-MD-M1	C S	장비 식별 및 사용자 연동 관리
		모바일 장치 고유 ID와 사용자 계정을 연동하여 통합 식별 및 통제를 수행한다.
N2SF-MD-M2	C	정책 위반 자동 조치
		정책 위반 시 자동으로 앱 차단, 로그아웃, 초기화 등 사전 정의된 조치를 수행한다.

■ 구현 방법 예시

• 모바일 코드 실행 제한 및 무결성 보호

- 허용되지 않은 앱 또는 코드가 실행되지 않도록, 앱스토어 외 설치(Sideload)를 차단하고, App Allowlist 기반 접근을 적용한다.
- iOS에서는 MDM을 통해 앱 설치 권한을 제한하고, Android에서는 Google Play Protect 또는 기업용 앱 허브를 활용한다.
- 코드 자동 실행 차단을 위해 앱 실행 시 관리자 승인 절차 또는 디지털 서명 검증을 수행한다.

• 모바일 실행 환경 격리

- 민감 데이터를 처리하는 앱은 가상 실행 환경(Work Profile, Knox, Android for Work 등)을 통해 사용자 앱과 분리된 공간에서 동작시킨다.
- 컨테이너 기반 앱 구동 방식이나 OS-level 가상화(VM 기반 모바일 OS) 환경을 활용해 코드 실행을 격리한다.
- 위험 탐지 시 Work Profile 전체를 초기화하거나 폐쇄 조치가 가능하도록 구성한다.

• 데이터 보안 및 암호화

- 모바일 저장소는 FDE(Full Disk Encryption), File-based Encryption를 통해 항상 암호화된 상태로 유지한다.

- 민감 데이터는 앱 단위 컨테이너에 저장하고, 키 관리는 OS 보안 모듈(Secure Enclave, Keystore, Keychain 등)과 연동한다.
- 보안이 요구되는 앱은 DLP 기능(화면 캡처 방지, 복사 방지, 클립보드 차단)을 통합 적용한다.

• 탈옥/루팅 탐지 및 대응

- Android/iOS 루팅 탐지 API, 서드파티 SDK 또는 MDM 보안 설정을 활용해 탈옥·루팅 여부를 검사한다.
- 탐지 시 앱 실행을 중지하거나 자동 로그아웃, 데이터 초기화, 관리자 알림 등 즉각적인 조치를 수행한다.

• 외부 인터페이스 통제 (USB/블루투스)

- USB Debugging, OTG 기능, 블루투스 PAN 연결 등을 정책적으로 제한하거나 비활성화한다.
- 업무용 프로파일에서는 외부 저장장치 인식 차단, 블루투스 키보드·마우스만 허용 등으로 제한한다.

• 사용자 연동 및 식별 관리

- 모바일 디바이스의 고유 식별자(UDID, Android ID, IMEI 등)와 사용자 계정을 연동해 기기별 통제를 수행한다.
- 사용자 인증 정보(MDM 연동 계정, AD 기반 Single Sign-On을 통해 사용자-단말 간 연동을 자동화하고, 사용자 변경 시 기기 초기화를 수행한다.
- 통합 디바이스 관리 시스템과 IAM 시스템을 연계하여 단말 상태 기반 인증과 접근 통제를 구성한다.

항목	적용 기술 또는 방식
코드 실행 제한	Sideload 차단, MDM 정책, App Allowlist, 코드 서명 검증
실행 환경 분리	Knox, VM 기반 앱 격리, Container 앱 구동
저장 데이터 암호화	FDE, File-based Encryption, Secure Enclave, Keystore
탈옥/루팅 탐지 및 대응	루팅 탐지 SDK, 앱 실행 차단
외부 인터페이스 제어	USB Debugging 차단, OTG 비활성화, Bluetooth 프로파일 제한
사용자 연동 관리	단말 고유 ID, AD 연동 SSO, 사용자-기기 연동, IAM 연계

2. 하드웨어 (Device, DV)

정의

하드웨어 보안 항목은 정보시스템과 하드웨어의 무결성을 유지하기 위해, 펌웨어 및 하드웨어 구성 요소 검증, 그리고 실행 환경의 무결성 보장을 위한 통제항목이다.

보안통제 항목

N2SF ID	보안통제 설명	
N2SF-DV-1	C S	하드웨어 무결성 검증
		하드웨어 구성 요소의 무결성을 검증한다.
N2SF-DV-2	C	하드웨어 기반 펌웨어 보호(Hardware-Based Protection)
		펌웨어 구성요소 대상 하드웨어 기반 쓰기방지 기능을 활용한다.
N2SF-DV-3	C S	하드웨어 장치(Device) 사용 제한
		정보자산 배포 또는 설치 전 특정 하드웨어 장치(USB포트, 무선통신 모듈 등)를 비활성화 또는 제거 등으로 사용을 제한한다.
N2SF-DV-4	C S	포트 및 입출력 장치 제어
		정보시스템의 포트나 입출력 장치를 제어하여 악성코드 유입 및 정보 유출을 차단한다.
N2SF-DV-5	C	외부 정보자산 활용 정보처리 제한
		외부 정보자산 등을 통한 정보의 처리, 저장 및 전송 등을 제한한다.
N2SF-DV-6	C	통신 기능이 포함된 저장장치 제한
		통신기능이 포함된 저장장치를 사용을 제한한다.
N2SF-DV-7	C	기관 접속용 장치 제한
		외부 정보자산(시스템 등)에서 기관 네트워크 접속이 가능한 장치 사용을 제한한다.
N2SF-DV-8	C S O	장치 자동 잠금
		사용자가 일정시간 이상 정보시스템을 사용하지 않거나 방치할 경우 잠금 기능을 활성화하고, 화면에 표시되는 정보는 표출되지 않아야 한다.
N2SF-DV-9	C	읽기 전용 매체 활용 프로그램 실행
		하드웨어 기반의 읽기 전용 매체에서 운영체제(OS) 로드 및 응용프로그램을 실행하여 실행환경의 무결성을 확보한다.
N2SF-DV-10	C	저장장치 연결 금지
		정보시스템 기동 및 종료 또는 재시작하는 동안 쓰기 가능한 저장장치 연결을 금지한다.
N2SF-DV-11	C	읽기 전용 매체 무결성 검증
		읽기 전용 매체에 정보를 저장하기 이전 무결성을 검증한다.

N2SF ID	보안통제 설명	
N2SF-DV-12	C	장치 펌웨어 업데이트 검증
	펌웨어 업데이트 시 서명 검증 또는 위변조 여부를 검증하여 설치를 제한한다.	
N2SF-DV-M1	C S	하드웨어 장치 식별 및 인벤토리
	장치별 고유 ID(MAC, Serial 등)를 기반으로 자산 목록을 구성하고 지속적으로 관리한다.	
N2SF-DV-M2	C S	반입 장치 검사 절차
	외부 장치 반입 시 보안 검사 및 승인 절차를 운영한다.	

■ 구현 방법 예시

• 하드웨어 무결성 검증

- BIOS, UEFI 및 TPM을 활용하여 하드웨어 구성 요소의 무결성을 부팅 시 검증한다.
- 펌웨어와 드라이버에 대한 Secure Boot를 구성하고, 변경 탐지를 위한 Hash 기반 비교 기능을 활성화한다.
- 특정 하드웨어 구성 요소에 쓰기 보호 칩을 적용하여, 펌웨어를 수정하지 못하도록 한다. 이 칩은 하드웨어적으로 쓰기 명령을 막아, 펌웨어가 원치 않게 변경되는 것을 방지한다.

• 펌웨어 보호 및 업데이트 검증

- 하드웨어 기반의 쓰기방지 기능(WP) 또는 보안 부팅 옵션으로 펌웨어의 무단 변경을 방지한다.
- 펌웨어 업데이트 시에는 디지털 서명 검증 및 무결성 체크를 수행하며, 공인된 펌웨어만 허용되도록 한다.

• 장치 식별 및 인벤토리 관리

- 장치 MAC 주소, Serial 번호 등 고유 식별자를 수집하여 자산 등록 및 인벤토리를 구성하고 주기적으로 비교한다.
- 자산 등록 이외의 장치가 네트워크에 연결되는 경우 자동 알림 또는 차단 정책을 적용한다.
- 개발자가 제공한 검증 가능한 일련번호를 사용하여 각 하드웨어 구성 요소의 진위 여부를 확인하고, 복제된 하드웨어가 사용되지 않도록 방지한다.

• 장치 단말 제어 및 제한

- USB, SD 카드, 블루투스 등 외부 입출력 장치는 정책 기반으로 허용 여부를 제어하며, 읽기전용 설정을 적용한다.
- 이동식 저장장치는 보안 정책에 따라 허용된 사용자 또는 작업에서만 사용할 수 있도록 DLP 솔루션과 연동한다.

• 하드웨어 장치 자동 잠금 및 비사용 제어

- 일정 시간 이상 사용하지 않는 시스템은 자동 잠금되도록 구성하며, 장치 화면 보호기와 연동한 로그인 재인증을 설정한다.
- 업무 외 시간에는 장치의 네트워크 접속 또는 작업 실행이 제한되도록 Endpoint Policy를 적용한다.

• 반입 장치 승인 절차 운영

- 외부에서 반입되는 장치는 보안 검사 도구(AntiVirus, Asset Scanner 등)로 사전 검사하며, 관리자 승인 후만 연결되도록 구성한다.
- 임시 등록 장치는 VLAN 또는 격리망으로 분리하여 검증 후 본망으로 이동되도록 구성한다.
- 하드웨어 구성 요소에 복제하기 어려운 라벨을 부착하여, 하드웨어가 무단으로 교체되거나 변조되지 않았는지 확인한다.

항목	적용 기술 또는 방식
하드웨어 무결성 검증	TPM, BIOS/UEFI Secure Boot, Hash 비교, Boot Integrity 검증
펌웨어 보호 및 검증	Write Protection, Signed Firmware Update, Secure Boot, 무결성 검증
장치 식별 및 인벤토리 관리	MAC/Serial 수집, 자산 인벤토리 시스템, 비인가 장치 탐지 및 알림
외부 입출력 장치 제어	USB/SD 제어, 읽기전용 설정, DLP 연동, 입출력 포트 통제
장치 자동 잠금 및 비사용 제어	자동 잠금 정책, 시간 기반 접근 제어, Endpoint 정책
반입 장치 승인 및 격리	외부 장치 검사 도구, 관리자 승인 절차, VLAN 격리 구성

3. 정보시스템 구성요소 (Information System Component, IN)

정의

정보시스템의 구성요소는 중앙화된 저장소를 통해 목록화하고, 설치·제거·업데이트 시 이를 정기적으로 갱신, 자동화된 메커니즘으로 최신성, 완전성, 정확성을 유지하여 불필요한 기능, 포트, 프로토콜, 소프트웨어를 비활성화 또는 제거하기 위한 통제항목이다.

■ 보안통제 항목

N2SF ID		보안통제 설명
N2SF-IN-1	C S	구성요소 목록 중앙관리
		정보시스템 내의 모든 구성요소가 포함되도록 정보시스템 구성요소 목록을 작성하고 정기적으로 검토 및 최신 상태로 업데이트 한다.
N2SF-IN-1(1)	C S	정보시스템 구성요소 최신상태 유지
		정보시스템 내의 모든 구성요소가 포함되도록 정보시스템 구성요소 목록을 작성하고 정기적으로 검토 및 최신 상태로 업데이트 한다.
	C S	구성요소 목록 현행화
		정보시스템 구성요소 설치, 제거, 또는 정보시스템 업데이트 시 목록을 갱신한다.
N2SF-IN-1(2)	C	구성요소 목록 자동관리
		자동화된 메커니즘을 통해 정보시스템 구성요소 목록의 최신성, 완전성, 정확성, 가용성을 유지한다.
N2SF-IN-2	C S	비인가 구성요소 식별
		정보시스템 내 비인가 하드웨어, 소프트웨어 및 펌웨어 구성요소를 검사하여 식별한다.
N2SF-IN-3	C	물리적 위치 식별
		자동화된 메커니즘을 통해 정보시스템 구성요소의 물리적 위치를 식별한다.
N2SF-IN-4	C S	변경 사항 테스트 및 검증
		변경 사항을 최종 적용하기 전에 테스트 및 검증을 통해 안전성을 확보한다.
N2SF-IN-5	C S	비인가 변경 방지
		인가되지 않은 정보시스템 구성요소 변경을 방지한다.
N2SF-IN-6	C S	불필요한 구성요소 제거
		필요 기능만 제공하도록 구성하고, 사용하지 않는 기능, 포트, 프로토콜, 소프트웨어, 서비스의 사용을 제거하거나 비활성화한다.
N2SF-IN-7	C S	주기적인 구성요소 제거 상태 점검
		주기적으로 사용하지 않는 기능, 포트, 프로토콜, 소프트웨어 및 서비스의 활성화 여부를 점검한다.
N2SF-IN-8	C S	비인가 소프트웨어 실행 차단
		허가되지 않은 소프트웨어(응용프로그램)가 실행되지 않도록 차단한다.
N2SF-IN-9	C S O	소프트웨어 기술지원 유지
		개발자, 공급업체 또는 제조업체에서 기술지원이 종료된 구성요소는 교체하거나 지속적 기술지원이 가능하도록 조치한다.
N2SF-IN-10	C S	소프트웨어 설치 권한 제한
		소프트웨어 설치 권한은 필요한 사용자에게만 부여한다.

N2SF ID	보안통제 설명	
N2SF-IN-11	C S O	재기동 서비스 신뢰성 확보
	정보시스템 구성요소와 서비스가 재기동(재부팅) 할 때 소프트웨어와 데이터는 신뢰된 곳으로부터 획득한다.	
N2SF-IN-12	C S O	신뢰성이 보장된 구성요소 설치
	신뢰할 수 있는 외부 기관·제조사 또는 기관이 자체 서명한 구성요소를 설치 및 활용한다.	
N2SF-IN-13	C S	정보의 비지속성
	정보시스템이 종료되거나 재부팅될 때 관련 정보(데이터 등)는 자동 삭제하여 유지되지 않도록 한다.	
N2SF-IN-14	C S	연결의 비지속성
	일시적으로 사용된 연결은 사용이 종료되면 자동으로 연결을 끊어 연결이 유지되지 않도록 한다.	
N2SF-IN-15	C S	구성요소 해시/서명 무결성 검증
	설치된 구성요소의 해시 또는 디지털 서명을 검증한다.	
N2SF-IN-16	C S O	악성코드 감염 차단
	악성코드 유입 및 실행 등으로 인한 악성코드 감염을 실시간 탐지하고 차단한다.	

■ 구현 방법 예시

• 구성요소 자산 식별 및 중앙 인벤토리 구축

- 정보시스템의 하드웨어, 소프트웨어, 펌웨어 자산을 자동 수집 도구를 통해 식별하고 중앙 자산 관리 시스템에 등록한다.
- 수집 항목에는 장비명, 모델명, MAC/Serial 번호, 소프트웨어 버전, OS 패치 정보 등을 포함한다.
- 자산 등록 시 자동 분류(서버, 네트워크 장비, 보안 장비 등)를 통해 가시성을 확보하고, 물리 위치와 논리 위치도 함께 연계한다.

• 구성요소 무결성 및 상태 점검

- 설치된 시스템 구성요소의 상태를 주기적으로 점검하며, 변경된 파일은 무결성 검사 도구(FIM 등)로 감시한다.
- 구성요소 변경은 승인 절차 후 테스트 환경에서 사전 검증 후 운영 시스템에 반영하도록 한다.
- 자동화된 변경 관리 시스템과 연동하여 구성요소 변경 로그를 기록하고 관리자에게 경고를 제공한다.

• 비인가 구성요소 및 소프트웨어 실행 차단

- 백신, EDR, 보안 에이전트를 통해 비인가 실행 파일 또는 프로세스의 실행을 차단하고 경고한다.
- 사용자 설치가 불가하도록 관리자 권한으로만 설치 가능하도록 정책을 설정한다.

- 샌드박스나 가상화 환경에서 의심 구성요소를 실행시켜 악성 여부를 탐지하고 격리할 수 있도록 구성한다.

• 구성요소 설치·삭제 권한 관리 및 기술지원 검증

- OS 또는 소프트웨어 설치 시 제조사 서명 검증을 통해 위변조 여부를 판별하며, 인증된 저장소만 통해 설치하도록 제한한다.
- 기술지원이 종료된 구성요소는 목록에서 식별하고, 대체 가능한 구성요소 또는 보안 업데이트 우회 방안을 마련한다.
- 불필요한 포트/서비스는 제거하며, 사용하지 않는 구성요소는 비활성화하여 공격 표면을 줄인다.

• 정보 비지속성 및 해지 검증

- 구성요소 삭제 또는 연결 해제 시 관련 데이터가 디스크에 남지 않도록 데이터 영구 삭제 알고리즘을 적용한다.
- 디지털 서명 검증 또는 구성요소 제거 로그 수집을 통해 해지 상태를 명확히 검증하고 감사기록으로 보관한다.

항목	적용 기술 또는 방식
자산 식별 및 인벤토리	ASM, 자동 자산 수집 에이전트, MAC/Serial 관리
무결성 및 상태 점검	FIM, 구성요소 변경 모니터링, 변경 승인 및 테스트 자동화
비인가 요소, 악성코드 탐지/차단	백신, EDR, 보안 에이전트
설치/삭제 및 지원 관리	서명 검증, 기술지원 종료 식별, 비활성화, 취약 구성요소 제거
비지속성 및 해지 검증	영구 삭제 알고리즘, 디지털 서명 확인, 구성요소 해지 로그 관리



1.0

국가 망 보안체계 보안 가이드라인

보안통제 항목 해설서

부록 1